

Manual de Segurança da Informação

Do básico ao avançado — fundamentos, ataque, defesa e governança

Vitor Mattos

30/07/2026

Índice

Apresentação	1
Para quem é este manual	1
Como o manual está organizado	2
Seções fixas de cada capítulo	3
Política editorial	3
Licença	3
I. Volume 1 — Fundamentos da Segurança da Informação	5
1. O que é segurança da informação	7
1.1. Uma definição de trabalho	7
1.2. Dado, informação e ativo: o que exatamente se protege	8
1.3. Segurança não é um estado, é um processo	9
1.4. Pessoas, processos e tecnologia	10
1.5. O adversário não é só o hacker	10
1.6. Quem ataca, e por que o pequeno também é alvo	11
1.7. Os princípios que sustentam qualquer defesa	12
1.8. O vocabulário mínimo	13
1.9. Como se sabe se está funcionando	13
1.10. Brasil em Foco	14
1.11. No Campo	15
1.12. Resumo	16
2. Os pilares: confidencialidade, integridade e disponibilidade	17
2.1. As três propriedades, com precisão	17
2.2. Confidencialidade	17
2.3. Integridade	19
2.4. Disponibilidade	20
2.5. As três colidem	21
2.6. A ordem de prioridade muda com o contexto	22
2.7. Além da tríade	22
2.8. Brasil em Foco	23
2.9. No Campo	23
2.10. Resumo	25
3. Autenticidade, não repúdio e responsabilização	27
3.1. Quatro coisas diferentes que se confundem	27
3.2. Autenticidade	28
3.3. Não repúdio	29
3.4. Responsabilização	30
3.5. Como as seis propriedades se encaixam	31
3.6. Brasil em Foco	32
3.7. No Campo	33

3.8. Resumo	35
4. Ativos, ameaças, vulnerabilidades e risco	37
4.1. A cadeia que liga os quatro termos	37
4.2. Ativos: o inventário é o alicerce	38
4.3. Ameaças: quem ou o quê, e com que capacidade	39
4.4. Vulnerabilidades: quatro tipos, não um	39
4.5. Risco: juntando tudo	41
4.6. Brasil em Foco	43
4.7. No Campo	44
4.8. Resumo	45
5. Modelagem de ameaças: STRIDE, árvores de ataque e abuse cases	47
5.1. O que é, e quando fazer	47
5.2. Pergunta 1: desenhar o sistema	48
5.3. Pergunta 2: o que pode dar errado	49
5.4. Outras abordagens, e quando usá-las	51
5.5. Pergunta 3: o que fazer, e pergunta 4: fizemos bem?	51
5.6. Brasil em Foco	52
5.7. No Campo	53
5.8. Resumo	54
6. Gestão de risco: análise qualitativa e quantitativa	55
6.1. O processo	55
6.2. Análise qualitativa	56
6.3. Análise quantitativa	57
6.4. Lidando com a incerteza: intervalos em vez de pontos	58
6.5. Escolher entre as duas	60
6.6. Tratamento e risco residual	60
6.7. Brasil em Foco	61
6.8. No Campo	62
6.9. Resumo	63
7. Ética, legalidade e a fronteira do escopo autorizado	65
7.1. A linha é jurídica, não técnica	65
7.2. O mapa legal brasileiro	66
7.3. Autorização: como ela é feita de verdade	67
7.4. Divulgação de vulnerabilidade	68
7.5. Bug bounty e programas de recompensa	69
7.6. Ética profissional além da lei	69
7.7. Onde praticar sem risco	70
7.8. Brasil em Foco	70
7.9. No Campo	71
7.10. Resumo	72
II. Volume 2 — Redes e Sistemas: a Base Técnica	75
8. A pilha TCP/IP sob a ótica do atacante e do defensor	77
9. Endereçamento, roteamento e NAT	79
10. Protocolos de aplicação e seus riscos: HTTP, DNS, SMTP e SNMP	81

11. Fundamentos de sistemas operacionais: processos, permissões e memória	83
12. Linux essencial para segurança	85
13. Windows e Active Directory essencial	87
14. Virtualização e montagem do laboratório de estudos	89
 III. Volume 3 — Criptografia Aplicada	 91
15. História e princípios da criptografia	93
16. Criptografia simétrica: AES, modos de operação e AEAD	95
17. Funções hash, HMAC e integridade	97
18. Criptografia assimétrica: RSA, Diffie-Hellman e curvas elípticas	99
19. PKI, certificados digitais e cadeias de confiança	101
20. TLS na prática: handshake, versões e configuração segura	103
21. Erros clássicos: criptografia mal empregada	105
 IV. Volume 4 — Identidade, Autenticação e Controle de Acesso	 107
22. Modelos de controle de acesso: DAC, MAC, RBAC e ABAC	109
23. Senhas: armazenamento, políticas e ataques	111
24. Autenticação multifator e fatores de autenticação	113
25. Federação de identidade: SAML, OAuth 2.0 e OpenID Connect	115
26. Gestão de identidades e de acessos privilegiados (IAM e PAM)	117
27. Arquitetura Zero Trust	119
 V. Volume 5 — Segurança de Redes	 121
28. Arquitetura segura e segmentação de redes	123
29. Firewalls: tipos, políticas e boas práticas	125
30. VPNs: IPsec, WireGuard e acesso remoto seguro	127
31. IDS, IPS e detecção em rede	129
32. Segurança de DNS: ataques, DNSSEC e DoH	131
33. Segurança do roteamento e BGP: sequestros, vazamentos e RPKI	133
34. Segurança em redes sem fio e enlaces de rádio	135

35. Ataques de negação de serviço e estratégias de mitigação	137
VI. Volume 6 — Endpoints e Sistemas Operacionais	139
36. Hardening de servidores Linux	141
37. Hardening de Windows e Active Directory	143
38. Antivírus, EDR e XDR	145
39. Gestão de vulnerabilidades e ciclo de patches	147
40. Segurança de dispositivos móveis e BYOD	149
41. Criptografia de disco e proteção de dados em repouso	151
VII. Volume 7 — Segurança de Aplicações	153
42. Ciclo de desenvolvimento seguro e DevSecOps	155
43. OWASP Top 10: panorama e como usar	157
44. Injeção: SQL, NoSQL e comandos de sistema	159
45. Cross-site scripting e ataques no lado do cliente	161
46. Falhas de autenticação e gestão de sessão	163
47. Falhas de controle de acesso: IDOR, SSRF e escalonamento	165
48. Segurança de APIs REST e GraphQL	167
49. SAST, DAST, SCA e automação de testes de segurança	169
VIII. Volume 8 — Nuvem e Contêineres	171
50. Modelo de responsabilidade compartilhada	173
51. IAM em nuvem e os erros de configuração mais caros	175
52. Segurança de contêineres e de imagens	177
53. Segurança em Kubernetes	179
54. Infraestrutura como código e segurança de pipeline	181
55. Segredos, cofres e gestão de chaves	183
IX. Volume 9 — Testes de Invasão	185
56. Metodologias e definição de escopo: PTES, OSSTMM e NIST SP 800-115	187

57.Reconhecimento passivo e OSINT	189
58.Varredura e enumeração	191
59.Análise de vulnerabilidades	193
60.Exploração: conceitos e anatomia de uma falha	195
61.Pós-exploração, persistência e movimentação lateral	197
62.Teste de invasão em aplicações web na prática	199
63.Relatório técnico e comunicação de achados	201
 X. Volume 10 — Fator Humano	 203
64.Engenharia social: os princípios psicológicos da persuasão	205
65.Phishing, spear phishing e fraude do e-mail corporativo	207
66.Fraudes digitais no Brasil: Pix, clonagem e golpes por mensageria	209
67.Segurança física e ataques presenciais	211
68.Cultura de segurança e programas de conscientização	213
 XI. Volume 11 — Malware e Inteligência de Ameaças	 215
69.Taxonomia de malware	217
70.Anatomia de um ataque de ransomware	219
71.Análise estática em laboratório	221
72.Análise dinâmica e sandboxing	223
73.MITRE ATT&CK e o mapeamento de TTPs	225
74.Inteligência de ameaças e indicadores de comprometimento	227
 XII. Volume 12 — Blue Team, SOC e Detecção	 229
75.Estrutura e operação de um SOC	231
76.Logging: o que registrar, por quanto tempo e por quê	233
77.SIEM: arquitetura, ingestão e correlação	235
78.Escrita de regras de detecção com Sigma e YARA	237
79.Threat hunting: caçando o que a regra não pegou	239
80.Deception: honeypots, honeytokens e canários	241

81. Métricas e maturidade da detecção	243
 XIII Volume 13 — Resposta a Incidentes e Forense Digital	 245
82. O ciclo de resposta a incidentes	247
83. Preparação: plano, papéis e playbooks	249
84. Contenção, erradicação e recuperação	251
85. Fundamentos de forense digital e cadeia de custódia	253
86. Forense de disco e sistemas de arquivos	255
87. Forense de memória	257
88. Forense de rede e análise de tráfego	259
 XIV Volume 14 — Continuidade e Resiliência	 261
89. Backup: estratégias e a regra 3-2-1-1-0	263
90. Recuperação de desastres e continuidade de negócio	265
91. Testes de continuidade e exercícios de mesa	267
92. Alta disponibilidade e resiliência de infraestrutura	269
93. Recuperação após um ataque de ransomware	271
 XV Volume 15 — Governança, Risco e Conformidade	 273
94. Governança de segurança e o papel do CISO	275
95. ISO/IEC 27001 e 27002	277
96. NIST Cybersecurity Framework e CIS Controls	279
97. LGPD na prática: bases legais, incidentes e a ANPD	281
98. Marco Civil, Lei 12.737 e o direito penal digital brasileiro	283
99. Obrigações regulatórias de provedores de internet	285
100 PCI-DSS e requisitos setoriais	287
101 Auditoria, conformidade e gestão de riscos de terceiros	289
 XVI Volume 16 — Fronteira e Carreira	 291
102 Segurança de sistemas de IA e modelos de linguagem	293

103	Criptografia pós-quântica	295
104	Segurança de OT, IoT e sistemas embarcados	297
105	Segurança da cadeia de suprimentos de software	299
106	Privacidade, anonimato e vigilância	301
107	Carreira, certificações e aprendizado contínuo	303
	Referências	305

Apresentação

Este manual cobre segurança da informação do básico ao avançado, em português, com foco em construir entendimento real em vez de decorar siglas. Ele nasce da premissa de que segurança não é uma disciplina isolada: é a consequência de entender profundamente como redes, sistemas operacionais, criptografia e pessoas realmente funcionam — e onde essas engrenagens se desencaixam.

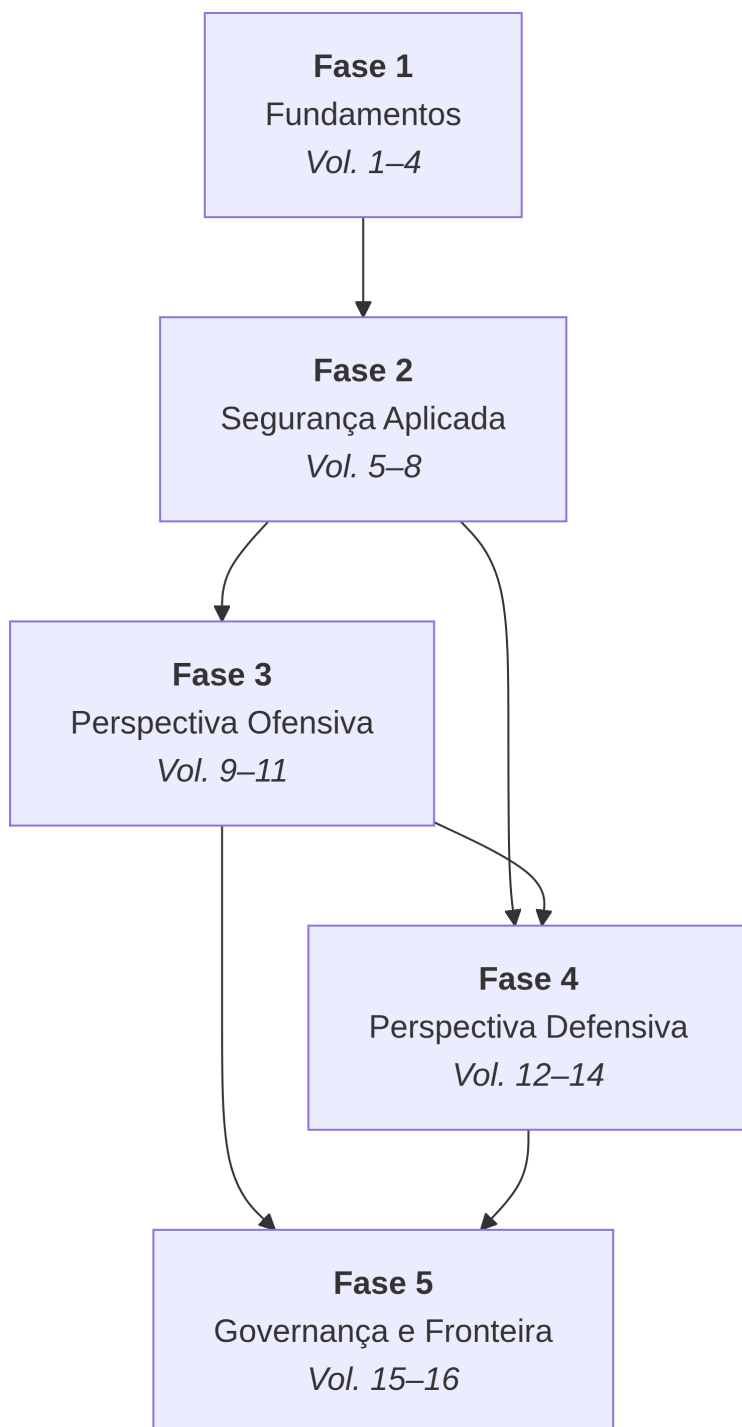
São **107 capítulos** distribuídos em **16 volumes** e **5 fases**, escritos para serem lidos em sequência por quem está começando, e consultados por assunto por quem já atua na área.

Para quem é este manual

- Quem está entrando na área e quer uma trilha ordenada em vez de tutoriais soltos
- Profissionais de infraestrutura e redes que precisam incorporar segurança ao dia a dia
- Desenvolvedores que querem entender as falhas que produzem sem perceber
- Estudantes preparando-se para certificações (Security+, CEH, CISSP, OSCP) que precisam da base conceitual antes do material de prova

Não é preciso conhecimento prévio de segurança. É preciso, sim, disposição para acompanhar os fundamentos técnicos do Volume 2 antes de correr para as partes mais chamativas.

Como o manual está organizado



Dependências entre as fases do manual

A **Fase 1** estabelece o vocabulário e a base técnica: o que é risco, como funcionam redes e sistemas, criptografia e controle de acesso. A **Fase 2** aplica isso aos domínios concretos — redes, endpoints, aplicações e nuvem. As fases **3** e **4** apresentam os dois lados da mesma moeda: como se ataca e como se detecta e responde. A **Fase 5** fecha com governança, conformidade brasileira e os temas de fronteira.

Ataque e defesa aparecem nesta ordem por um motivo pedagógico: não se detecta o que não se

compreende. Mas as duas fases são complementares, não sequenciais — quem só quer defender pode ler a Fase 4 antes da 3, aceitando algumas referências para frente.

Seções fixas de cada capítulo

Todo capítulo traz duas seções obrigatórias ao final:

i **Brasil em Foco** — como o tema se conecta à legislação e às instituições brasileiras: LGPD e ANPD, Marco Civil, Lei 12.737, Anatel, CERT.br, Gov.br, Banco Central e Pix.

💡 **No Campo** — a tradução do conceito para a operação real de infraestrutura: o que muda no dia a dia de quem administra rede, servidores e clientes.

Política editorial

! Escopo, ética e legalidade

Este manual é material educacional com orientação defensiva. Técnicas ofensivas são apresentadas para que se possa **entender, detectar e mitigar** ataques — nunca como receita operacional.

Na prática, isso significa: explicamos mecanismos, usamos ferramentas públicas e consagradas em laboratório isolado, e mostramos as contramedidas correspondentes. Não publicamos exploits armados, payloads prontos para uso, nem código de malware funcional.

Testar sistemas sem autorização formal e por escrito é crime no Brasil (Lei 12.737/2012, art. 154-A do Código Penal). O Volume 9 trata escopo e autorização como pré-requisito, não como formalidade. Monte seu laboratório (Capítulo 14) e pratique apenas nele ou em plataformas que autorizam explicitamente.

Licença

Conteúdo sob licença [CC BY-SA 4.0](#). Código e scripts sob licença MIT. Contribuições, correções e sugestões são bem-vindas via issues no repositório.

Parte I.

**Volume 1 — Fundamentos da
Segurança da Informação**

1. O que é segurança da informação

Numa terça-feira de março, às 6h40, o técnico de plantão de um provedor regional atende o primeiro chamado do dia: um assinante não consegue emitir a segunda via da fatura. Às 7h10 são doze chamados. Às 7h30 fica claro que o problema não é o portal de faturas — é o sistema de gestão inteiro, o ERP que emite boleto, controla contrato e guarda o cadastro de quatro mil assinantes. A tela de login abre. A senha do administrador não é aceita. No servidor, os arquivos do banco de dados continuam todos lá, com uma extensão nova grudada no fim. Na raiz do disco há um arquivo de texto com um endereço de carteira de criptomoeda e um prazo.

Vale olhar primeiro o que **não** falhou naquela manhã. O link de saída estava perfeito, com 6 ms de latência para o PTT. Nenhum alarme do monitoramento disparou, porque o monitoramento vigiava latência, perda de pacote, potência óptica e temperatura de rack — e os quatro estavam normais. O firewall de borda seguia bloqueando exatamente aquilo que alguém havia configurado para bloquear, sem errar um pacote. Toda a infraestrutura funcionou conforme especificada. E a empresa parou por seis dias.

O caminho, reconstruído depois, foi banal. Uma conta de VPN criada dois anos antes para um consultor, com senha reaproveitada de outro serviço que havia vazado, sem segundo fator. De dentro da VPN, uma porta de área de trabalho remota alcançável e uma conta de administrador local repetindo a mesma senha em três servidores. O backup existia — em um compartilhamento de rede montado permanentemente como unidade Z: no próprio servidor do ERP, e por isso foi cifrado junto.

No mesmo mês, essa empresa teve outros dois incidentes que ninguém chamou de incidente. Um notebook do comercial foi furtado de dentro de um carro, com uma planilha de 1.200 assinantes — nome, CPF, endereço, telefone — em disco sem cifragem. E um técnico desligado em janeiro seguiu com acesso administrativo à OLT por 40 dias, porque o desligamento passou pelo RH e pela folha, mas não por ninguém que soubesse quais credenciais aquela pessoa carregava.

Os três episódios são incidentes de segurança da informação. Nenhum dos três se resolve comprando um equipamento. É desse desconforto que a disciplina nasce.

1.1. Uma definição de trabalho

A norma ISO/IEC 27000 define segurança da informação como a **preservação da confidencialidade, da integridade e da disponibilidade da informação** (International Organization for Standardization, 2018a). É uma frase curta e bem mais densa do que parece.

Preservação implica continuidade: não é estado que se alcança e se declara, é algo que se mantém contra uma tendência natural de degradação. *Informação* — não servidor, não rede, não software. E as três propriedades, que o próximo capítulo abre em detalhe:

- **Confidencialidade** — a informação só é acessível a quem tem direito a ela.
- **Integridade** — a informação está correta e completa, e alterações não autorizadas são impedidas ou, no mínimo, detectáveis.
- **Disponibilidade** — quem tem direito à informação a alcança quando precisa.

1. O que é segurança da informação

Os três pilares são necessários, mas não bastam: uma transação bancária exige também que a origem seja comprovadamente quem afirma ser (autenticidade) e que depois não possa negar tê-la feito (não repúdio) — assunto do capítulo seguinte ao próximo.

A definição operacional que este manual carrega é esta:

Segurança da informação é o conjunto de decisões — técnicas, organizacionais e humanas — que mantém a informação disponível para quem tem direito a ela, íntegra para quem depende dela e inalcançável para quem não deveria chegar até ela, dentro de um custo que a organização consegue sustentar de forma contínua.

A última cláusula é a que separa segurança de teatro de segurança: um controle que a empresa não consegue pagar, operar e manter por três anos não é controle, é linha de relatório.

Vale notar desde já que os três pilares **entram em conflito entre si**. Cifrar o backup protege a confidencialidade e cria um risco novo de disponibilidade: chave perdida significa backup inútil. Exigir troca de senha a cada 30 dias parece reforçar o controle de acesso e, na prática, produz **Verão2026!** escrito num post-it colado no monitor da recepção. Segurança da informação é, em boa medida, escolher esses tradeoffs conscientemente em vez de tropeçar neles.

1.2. Dado, informação e ativo: o que exatamente se protege

10.20.0.42 é um dado. “Endereço de gerência da OLT do distrito de Santa Rita, acessível apenas pela VLAN 900” é informação: o dado mais o contexto que o torna útil — e, no mesmo movimento, útil para um atacante.

Ativo é qualquer coisa que tenha valor para a organização, e separá-los em dois níveis é prático:

- **Ativos primários** — a informação em si e os processos de negócio que dependem dela. O cadastro de assinantes. A base de contratos. A capacidade de faturar no dia 5.
- **Ativos de suporte** — o que sustenta os primários: hardware, software, rede, instalações, e as pessoas. O servidor do ERP, a fibra do backbone, a torre de rádio, o técnico que sabe reconfigurar a OLT.

A inversão que a disciplina propõe é esta: o objeto de proteção é o ativo primário, mas os controles quase sempre se aplicam aos de suporte. Ninguém cifra “o cadastro de assinantes” em abstrato — cifra-se o disco, restringe-se a conta, segmenta-se a VLAN.

E a informação não fica parada: percorre um ciclo, e cada etapa tem controles próprios (Figura 1.1).

O descarte é a etapa esquecida com mais frequência, e a que produz vazamentos mais silenciosos: o disco do servidor trocado por defeito que vai para o ferro-velho com o banco de dados legível; o roteador de borda vendido em marketplace com a configuração completa da rede, incluindo chaves de BGP. Nenhum desses casos tem atacante, exploração ou malware. Todos são falhas de confidencialidade.

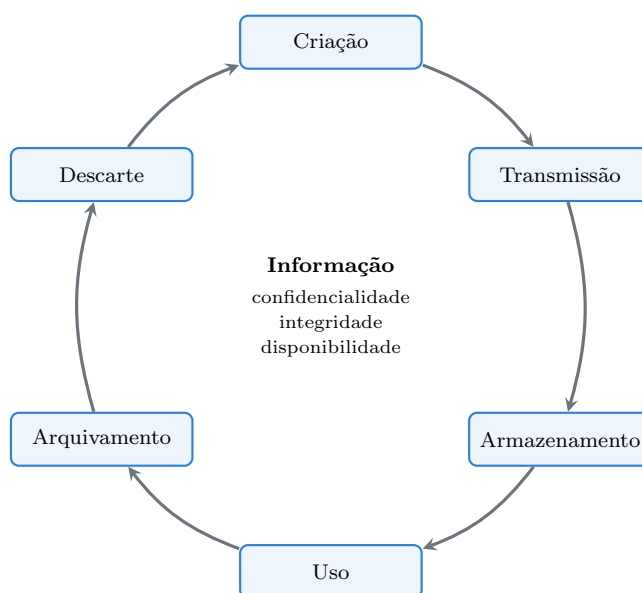


Figura 1.1.: O ciclo de vida da informação. Um controle que só cobre uma etapa deixa as outras cinco expostas.

1.3. Segurança não é um estado, é um processo

A frase é de Bruce Schneier e virou clichê justamente porque resolve uma confusão persistente (Schneier, 2000). Segurança absoluta é alcançável: desliga-se o equipamento, retira-se o disco, lacra-se num cofre. O sistema fica perfeitamente seguro e perfeitamente inútil. Todo sistema real opera num ponto intermediário, e o nome desse ponto é **risco residual**.

O que a disciplina persegue não é risco zero, é risco residual *conhecido e aceito conscientemente* — decidido por quem tem autoridade, documentado e revisitado. A diferença entre uma empresa madura e uma imprudente raramente está no número de controles: está em saber, ou não saber, o que ficou descoberto.

Existe uma razão econômica para isso, esboçada em Figura 1.2.

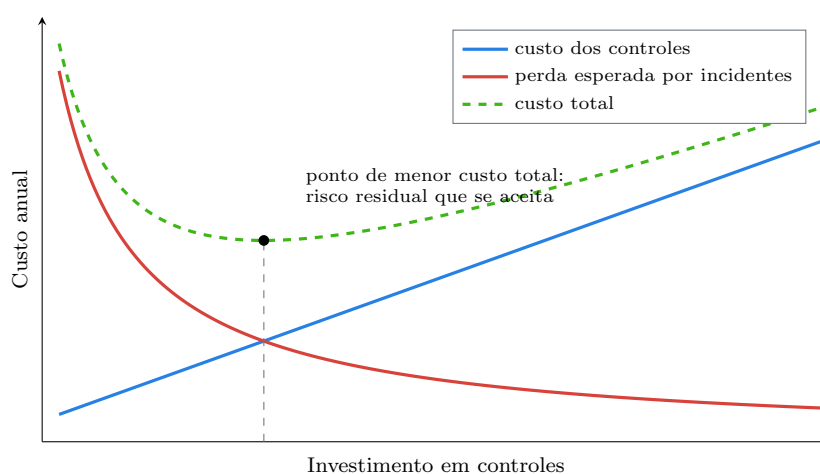


Figura 1.2.: A lógica econômica do controle. Passado certo ponto, cada real gasto em segurança compra menos redução de perda esperada do que custa.

1. O que é segurança da informação

O gráfico é uma idealização didática: na vida real não se conhecem os valores das curvas com precisão, e é por isso que existe gestão de risco como método — tema do sexto capítulo deste volume. O que importa é a *forma*: há um ponto além do qual gastar mais destrói valor, e um ponto abaixo do qual economizar destrói a empresa.

Há uma segunda razão para tratar segurança como processo: **as configurações envelhecem**. Um servidor perfeitamente endurecido em 2023 acumula, até 2026, bibliotecas com falhas conhecidas, cifras que deixaram de ser aceitáveis e regras de firewall abertas “temporariamente” para um teste que ninguém fechou. Toda base de regras com cinco anos contém alguma liberação cuja justificativa ninguém sabe mais explicar, e que ninguém remove por medo de derrubar algo.

1.4. Pessoas, processos e tecnologia

O incidente da abertura é um exemplo didático de por que a tecnologia isolada não fecha a conta. Vale reler o caso separando as camadas:

Tabela 1.1.: As três camadas do incidente de abertura.

Camada	O que falhou
Tecnologia	VPN sem segundo fator, rede interna plana, senha de administrador local repetida, backup em unidade montada
Processo	desligamento sem revogação de credencial, nenhuma revisão periódica de contas, backup nunca testado por restauração
Pessoas	senha reaproveitada de outro serviço, conta de terceiro esquecida ativa por dois anos

Nenhuma das três falhas de processo custa dinheiro para corrigir; todas custam disciplina, que é mais escassa. E o investimento típico vai no sentido inverso — 90% do orçamento em tecnologia —, o que explica por que empresas bem equipadas continuam sendo comprometidas por caminhos elementares.

1.5. O adversário não é só o hacker

A palavra “ameaça” evoca uma pessoa mal-intencionada, e essa associação estreita indevidamente o campo. Convencionalmente, separam-se três origens:

Deliberadas. Ação intencional de um agente: fraude, extorsão por ransomware, sabotagem, espionagem, furto de equipamento.

Acidentais. Erro humano sem intenção: o comando DROP no banco de produção em vez do de teste; a rota redistribuída por engano que anuncia prefixo de terceiro; o e-mail com anexo de dados pessoais enviado para a lista errada. Em volume de incidentes, esta categoria rivaliza com a primeira — e em algumas organizações a supera.

Ambientais e naturais. Descarga atmosférica na torre de rádio que leva switch, conversor e fonte no mesmo estouro. Falta de energia de nove horas num site remoto cujo banco de baterias tem autonomia de duas. Roçadeira de trator que rompe o ramal de fibra do distrito na época da

colheita. Furto de bateria de nobreak em site sem cerca — que, para quem opera rede rural, é ameaça deliberada e ambiental ao mesmo tempo.

Para quem administra infraestrutura, essa terceira categoria é com frequência a maior fonte de horas de indisponibilidade do ano — e disponibilidade é um dos três pilares. Não é curiosidade taxonômica: o mesmo arcabouço (inventariar ativos, estimar risco, implantar controle, exercitar resposta) serve para o raio e para o ransomware. Plano de resposta que só sabe lidar com atacante é metade de um plano.

1.6. Quem ataca, e por que o pequeno também é alvo

Entre os agentes deliberados, os perfis diferem tanto em capacidade quanto em motivação, e a diferença muda a defesa apropriada:

- **Oportunista automatizado.** Não escolheu você. Varre faixas inteiras de endereços procurando serviço exposto com credencial padrão ou falha conhecida. É a esmagadora maioria do que se vê nos logs.
- **Crime organizado.** Opera como negócio, com divisão de trabalho: quem obtém o acesso inicial vende para quem executa a extorsão, que aluga o programa de cifragem de um terceiro. É a economia que tornou ransomware viável contra empresas de qualquer porte.
- **Pessoa interna.** Do funcionário insatisfeito com acesso privilegiado ao terceirizado negligente que reutiliza senha. Não precisa vencer perímetro nenhum: já está dentro.
- **Ativismo.** Motivação ideológica, alvo escolhido pelo que representa e busca de visibilidade: pichação de site, vazamento seletivo, indisponibilidade em data simbólica.
- **Estado-nação.** Recursos altos, paciência longa, alvo deliberadamente escolhido. Raro como adversário direto de uma empresa média — mas provedores de telecomunicações e cadeias de suprimento são alvos de interesse justamente por serem caminho para outros.

Um servidor SSH recém-exposto coleta tentativas de acesso em minutos, sempre com esta cara:

```
Mar 12 03:11:44 borda sshd[2291]: Failed password for invalid user admin from
↪ 203.0.113.47 port 51344 ssh2
Mar 12 03:11:46 borda sshd[2293]: Failed password for invalid user ubnt from
↪ 203.0.113.47 port 51402 ssh2
Mar 12 03:11:49 borda sshd[2295]: Invalid user support from 198.51.100.12 port
↪ 44120
Mar 12 03:11:52 borda sshd[2297]: Failed password for root from 198.51.100.12
↪ port 44188 ssh2
Mar 12 03:12:03 borda sshd[2301]: Failed password for invalid user pi from
↪ 203.0.113.190 port 33012 ssh2
```

Os nomes de usuário entregam o jogo: **admin**, **ubnt**, **support** e **pi** são credenciais de fábrica de equipamentos de rede e placas embarcadas. Ninguém decidiu atacar aquele endereço — um programa varre a internet inteira, e o endereço apareceu na lista. O custo marginal de tentar em um alvo a mais é zero, e é por isso que “sou pequeno, ninguém vai me atacar” é premissa falsa por construção.

Há um segundo motivo, mais específico. Uma empresa pequena que administra rede guarda dados pessoais em volume (CPF, endereço, meio de pagamento) e opera equipamentos de cliente que, tomados em massa, valem como capacidade de ataque: milhares de roteadores domésticos com credencial padrão são ativo de mercado para quem monta rede de ataque distribuído. Nessa configuração, a infraestrutura não é apenas alvo — é vetor contra os próprios assinantes.

1.7. Os princípios que sustentam qualquer defesa

Em 1975, Saltzer e Schroeder publicaram oito princípios de projeto para proteção da informação (Saltzer; Schroeder, 1975). Cinco décadas depois, com toda a tecnologia trocada, seguem sendo o melhor filtro para avaliar uma decisão de segurança:

1. **Economia de mecanismo.** O desenho mais simples que resolve. Complexidade é onde erro se esconde.
2. **Padrões à prova de falha.** Negar por padrão; permitir por exceção explícita. Se o mecanismo falhar, deve falhar fechado.
3. **Mediação completa.** Toda requisição verificada, sempre. Atalhos de desempenho que reaproveitam decisões antigas de autorização são a origem de uma classe inteira de falhas.
4. **Desenho aberto.** A segurança não deve depender do segredo do desenho, apenas do segredo da chave. Criptografia proprietária “secreta” é sinal de alerta, não de força.
5. **Separação de privilégios.** Exigir mais de uma condição independente para a operação crítica — a lógica das duas chaves do cofre, e a razão de ser da autenticação em dois fatores.
6. **Menor privilégio.** Cada sujeito com o mínimo de permissão necessário, pelo menor tempo necessário. É o princípio mais violado da lista: quase toda rede tem contas de serviço com privilégio administrativo porque “assim funciona”.
7. **Mecanismo menos comum.** Evitar compartilhar mecanismo e estado entre usuários diferentes; o que é compartilhado se torna caminho entre eles.
8. **Aceitação psicológica.** O controle precisa ser utilizável. Controle que atrapalha o trabalho é controle burlado — e a criatividade do usuário para burlar é ilimitada.

Desses princípios decorre a estratégia que organiza tudo o que vem nos volumes seguintes: **defesa em profundidade**. Nenhuma camada é considerada confiável o suficiente para ser a única, e o comprometimento de uma não deve implicar o comprometimento das demais (Figura 1.3).

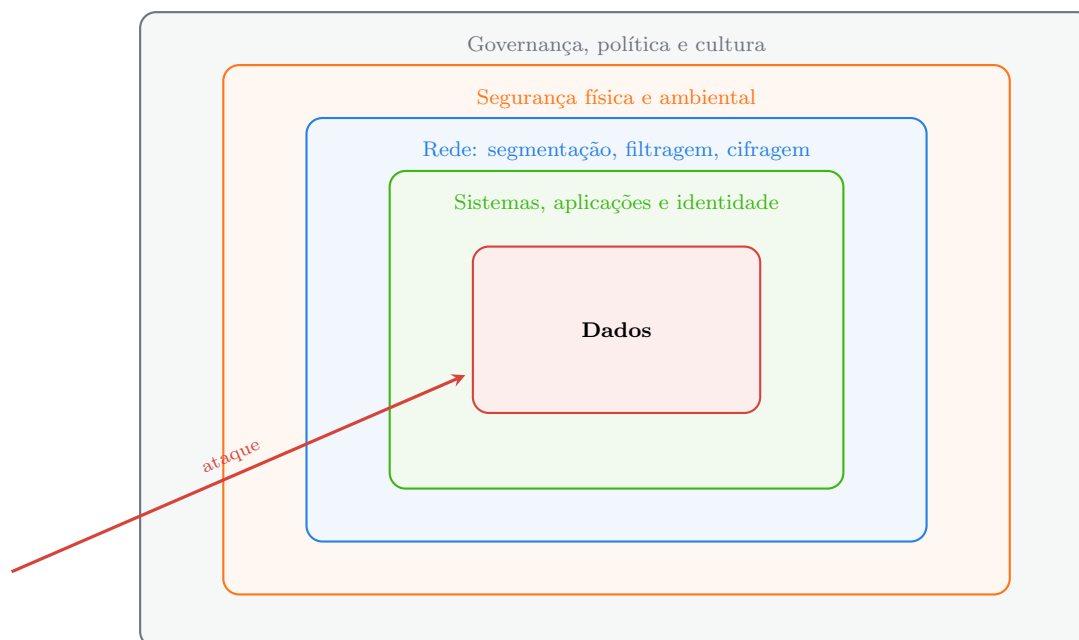


Figura 1.3.: Defesa em profundidade. Cada camada compra tempo e gera registro; nenhuma é suficiente sozinha.

Duas ressalvas importam desde já. Camadas precisam ser **independentes**: cinco que aceitam a mesma senha de administrador são, na prática, uma. E camadas servem para *detectar*, não

só para bloquear — o valor de uma camada intermediária costuma estar menos em barrar o atacante do que em produzir o registro que revela sua passagem enquanto há tempo de reagir. Assumir que o comprometimento vai acontecer e projetar para detectá-lo rápido atravessa toda a parte defensiva deste manual.

1.8. O vocabulário mínimo

Segurança da informação tem vocabulário próprio, em que palavras do uso cotidiano ganham sentido técnico estrito. Confundi-las produz conversas em que ninguém está errado e ninguém se entende. A Tabela 1.2 fixa o mínimo para seguir adiante; o quarto capítulo deste volume aprofunda cada termo.

Tabela 1.2.: Vocabulário mínimo de segurança da informação.

Termo	Sentido técnico	No caso de abertura
Ativo	Aquilo que tem valor e que se quer proteger	O cadastro dos quatro mil assinantes
Vulnerabilidade	Fraqueza que pode ser explorada	VPN sem segundo fator; senha repetida entre servidores
Ameaça	Agente ou evento com potencial de causar dano	Grupo de extorsão que compra acesso inicial
Risco	Combinação de probabilidade e impacto de a ameaça explorar a vulnerabilidade	Alta chance de parada de faturamento por vários dias
Controle	Medida que reduz risco, por prevenção, detecção ou correção	Segundo fator na VPN; backup fora do alcance do servidor
Evento	Qualquer ocorrência observável no ambiente	Uma autenticação falha às 3h11
Incidente	Evento, ou série de eventos, que compromete um dos pilares	A cifragem do banco de dados do ERP
Superfície de ataque	Conjunto de pontos alcançáveis por um adversário	VPN, área de trabalho remota, portal do assinante
Risco residual	O que permanece depois dos controles aplicados	O que se decide conviver, sabendo que existe

Duas dessas distinções têm consequência operacional direta. Uma rede grande gera milhões de *eventos* por dia, e a função de um centro de operações é separar os poucos que são *incidentes*. E como não se elimina a *ameaça* — ninguém acaba com o crime organizado a partir do datacenter —, o trabalho recai sobre reduzir vulnerabilidade e impacto.

1.9. Como se sabe se está funcionando

“Nunca fomos invadidos” não é evidência de segurança; costuma ser evidência de ausência de detecção — comprometimentos que duram meses sem serem percebidos são a regra, e a descoberta vem com frequência de fora: um cliente, um pesquisador, ou o próprio atacante ao pedir resgate.

1. O que é segurança da informação

Medir é difícil justamente porque o resultado desejado é a não ocorrência de algo, mas alguns indicadores sobrevivem ao escrutínio:

- **Tempo até detectar e tempo até conter.** Se a resposta é “não sabemos”, esse é o primeiro problema a resolver.
- **Cobertura de controle sobre inventário.** Percentual de ativos inventariados, de contas com segundo fator, de servidores corrigidos no prazo, de backups cuja restauração foi testada no trimestre. Todas dependem de existir inventário.
- **Superfície exposta.** Quantidade de serviços administrativos alcançáveis da internet. A meta é zero, e o número é fácil de medir.
- **Resultado de exercícios.** Restauração real a partir do backup, simulação controlada de phishing, exercício de mesa. Exercício produz dado; opinião produz sensação.

Métrica que só sobe e nunca gera decisão é métrica de vaidade: contar ataques bloqueados pelo firewall mede o ruído de fundo da internet, não a qualidade da defesa. O Volume 12 retoma o assunto com o rigor devido.

1.10. Brasil em Foco

No Brasil, segurança da informação deixou de ser boa prática e passou a ser obrigação jurídica com nome, prazo e sanção.

A **Lei Geral de Proteção de Dados** (Lei 13.709/2018) é o eixo (Brasil, 2018). Seu art. 46 obriga os agentes de tratamento a adotar medidas de segurança técnicas e administrativas aptas a proteger dados pessoais — redação deliberadamente aberta, que remete ao estado da técnica e à natureza da informação, e não a uma lista fechada de produtos. O art. 48 estabelece o dever de comunicar à Autoridade Nacional de Proteção de Dados e aos titulares afetados a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante. A Resolução CD/ANPD nº 15/2024 regulamentou essa comunicação, fixando prazo de três dias úteis a contar do conhecimento do incidente e definindo o conteúdo mínimo do relato (Autoridade Nacional de Proteção de Dados, 2024). Na prática, a empresa precisa ser capaz de *saber* que foi comprometida, *avaliar* o alcance e *redigir* a comunicação em três dias — impossível sem registro adequado e plano prévio. No caso da abertura, a planilha do notebook furtado é tratamento de dados pessoais, e o furto é potencialmente um incidente comunicável.

O **Marco Civil da Internet** (Lei 12.965/2014) trata da guarda de registros (Brasil, 2014). O art. 13 obriga o provedor de conexão a manter registros de conexão por um ano; o art. 15 obriga o provedor de aplicações constituído como pessoa jurídica e com fins econômicos a guardar registros de acesso por seis meses. Os arts. 10 e 11 impõem sigilo e condicionam a disponibilização a ordem judicial. A leitura é dupla: o registro é obrigação e é ativo sensível — quem guarda log de conexão de milhares de pessoas custodia um alvo de valor.

A **Lei 12.737/2012** inseriu no Código Penal o art. 154-A, que tipifica invadir dispositivo informático alheio para obter, adulterar ou destruir dados, ou instalar vulnerabilidade para obter vantagem ilícita (Brasil, 2012). As penas foram agravadas pela Lei 14.155/2021. Essa é a fronteira jurídica que sustenta a política editorial deste manual: testar sistema de terceiro sem autorização formal e por escrito é crime, ainda que a intenção seja “só verificar”. O sétimo capítulo deste volume trata exclusivamente dessa fronteira.

Para quem opera telecomunicações há camada regulatória adicional: a **Anatel** editou a Resolução nº 740/2020, com requisitos de segurança cibernética para produtos de telecomunicações, o que alcança diretamente as ONUs e roteadores entregues ao assinante (Agência Nacional

de Telecomunicações, 2020). O Volume 15 dedica um capítulo às obrigações regulatórias de provedores.

No lado institucional, o **CERT.br**, mantido pelo NIC.br, é o ponto nacional de tratamento de incidentes em redes conectadas à internet no Brasil: recebe notificações, publica estatísticas e mantém material de boas práticas usado por operadores de rede. Manter contato de abuso atualizado no WHOIS do seu bloco e responder de fato a essas notificações é um dos controles mais baratos e menos praticados do país.

Por fim, o **Banco Central** trata fraude como matéria de segurança regulada: instituições financeiras e de pagamento estão sujeitas a política obrigatória de segurança cibernética (Resolução CMN nº 4.893/2021), e o Pix conta com o Mecanismo Especial de Devolução para casos de fraude — o que faz da engenharia social contra o titular, e não do ataque à instituição, o vetor dominante no país. O Volume 10 volta ao tema.

1.11. No Campo

Traduzindo tudo para a primeira semana de quem assume a responsabilidade por uma infraestrutura, na ordem em que compensa fazer:

1. Inventário, antes de qualquer controle. Não se protege o que não se conhece, e a maior parte das surpresas está em ativo esquecido: o servidor de teste de 2019 ainda ligado com endereço público, a câmera com firmware de fábrica. Vale a varredura do próprio bloco — sua rede, sua autorização:

```
# Descoberta de hosts e serviços no PRÓPRIO bloco de endereços
nmap -sS -Pn --top-ports 200 --open -oA inventario-borda 198.51.100.0/24

# O que este servidor realmente escuta, e qual processo responde
ss -tulnp | sort -k5

# Contas locais com shell de login válido
awk -F: '$7 !~ /(nologin|false)$/ {print $1, $3, $7}' /etc/passwd
```

2. Reduzir a superfície de gerência. Painel de administração acessível da internet é o achado mais comum e mais caro. Winbox, interface web de OLT, SNMP com comunidade `public`, Telnet, área de trabalho remota — nada disso deve estar alcançável do mundo. O padrão é VLAN de gerência separada do tráfego de assinante, alcançável apenas por VPN com segundo fator, com filtro por origem no equipamento além do filtro na borda.

3. Senhas individuais e nomeadas. A senha compartilhada entre a equipe técnica destrói o menor privilégio e a responsabilização de uma vez: quando todos entram como `admin`, o log de auditoria não responde à única pergunta que importa depois de um incidente. Cofre de senhas da equipe, contas nomeadas e revogação como parte formal do desligamento — inclusive chaves SSH, VPN e acesso ao WhatsApp do suporte.

4. Backup que sobrevive ao próprio servidor. O critério é implacável: o backup precisa estar fora do alcance de quem comprometeu o servidor — compartilhamento montado permanentemente não atende, cópia que a máquina de origem pode apagar não atende. E backup nunca restaurado é hipótese, não backup; a restauração de teste trimestral é o que transforma um em outro.

1. O que é segurança da informação

5. Relógio e registro. Sem NTP consistente em todos os equipamentos, os logs não podem ser correlacionados e perdem valor tanto na investigação técnica quanto no atendimento a ordem judicial. É configuração de dez minutos com efeito permanente:

```
timedatectl set-ntp true
timedatectl status | grep -E 'synchronized|NTP service'

# Autenticações falhas por origem, últimas 24 h
journalctl -u ssh --since "24 hours ago" \
  | grep -oE 'from [0-9.]+' | sort | uniq -c | sort -rn | head
```

6. Escrever o plano antes de precisar dele. Uma folha por cenário, resposta a três perguntas: quem decide, a quem se avisa (interno, cliente, ANPD, delegacia), e qual é a primeira ação técnica. Faça para ransomware no sistema de gestão, para vazamento de base de assinantes e para rompimento de fibra do enlace principal. Às 3h da manhã, com o telefone tocando, ninguém improvisa bem.

7. Fechar o ciclo no descarte. Disco que sai da empresa é apagado de forma verificável ou destruído fisicamente. Equipamento devolvido por assinante ou retirado de operação volta a padrão de fábrica antes de ir para o estoque, para venda ou para doação.

Nenhum dos sete itens exige orçamento significativo; todos exigem que alguém seja nomeado responsável — e essa nomeação, mais do que qualquer aquisição, é o que dá início a um programa de segurança.

1.12. Resumo

- Segurança da informação é a **preservação contínua** de confidencialidade, integridade e disponibilidade: processo que se mantém, não estado que se compra. As três propriedades conflitam entre si, e escolher os tradeoffs conscientemente é parte do trabalho.
- O que se protege é a **informação**; servidores, links e equipamentos são ativos de suporte, e é neles que os controles se aplicam — em todo o ciclo de vida, inclusive no descarte, a etapa mais esquecida.
- Ameaça não é sinônimo de atacante: falhas **acidentais** e eventos **ambientais** produzem incidentes de disponibilidade em volume, e cabem no mesmo arcabouço de gestão de risco.
- A maior parte do que se vê nos logs é **varredura automatizada e indiscriminada** — o que invalida a premissa de que porte pequeno confere proteção. Além de alvo, uma infraestrutura mal protegida se torna vetor contra os próprios clientes.
- Os oito princípios de Saltzer e Schroeder, com meio século de idade, seguem sendo o melhor filtro para avaliar decisões; deles decorre a **defesa em profundidade**, com camadas independentes que bloqueiam e também produzem registro.
- No Brasil, o dever de segurança é jurídico: LGPD (arts. 46 e 48) com prazo de três dias úteis para comunicar incidente relevante, Marco Civil para guarda de registros, Lei 12.737/2012 tipificando o acesso não autorizado, mais camada setorial de Anatel e Banco Central.

2. Os pilares: confidencialidade, integridade e disponibilidade

O provedor havia feito tudo certo com o backup. Rotina diária às 2h, retenção de trinta dias, cópia replicada para um segundo site a 40 km, alerta por e-mail em caso de falha do job. Em quatro anos, nenhum alerta.

Em novembro, a equipe descobriu que a tabela de contratos estava com os campos de vencimento embaralhados: assinantes com vencimento no dia 10 apareciam com dia 25, e uma fatia menor tinha vencimento nulo. A causa foi uma migração mal-feita nove meses antes, que rodou uma atualização sem cláusula **WHERE** correta e afetou 3.100 dos 4.000 registros. O sistema não caiu. Ninguém foi invadido. Nada vazou.

E o backup não ajudou: a retenção era de trinta dias, e o dano tinha nove meses. As trinta cópias disponíveis continham, todas, os mesmos dados errados — fielmente preservados, replicados com integridade de arquivo perfeita, disponíveis a qualquer hora. Reconstruir o cadastro exigiu conferir contrato por contrato em papel, um trabalho de sete semanas.

Esse incidente ilustra o ponto central deste capítulo: as três propriedades que definem segurança da informação são **independentes**. Um sistema pode ser exemplar em duas e catastrófico na terceira, e nenhum controle protege as três de graça. Este capítulo abre confidencialidade, integridade e disponibilidade uma a uma — o que cada uma significa com precisão, como cada uma falha, o que a defende e onde as três colidem.

2.1. As três propriedades, com precisão

A tríade CID (em inglês, *CIA triad*) organiza a disciplina desde os anos 1970 e sobrevive porque é ao mesmo tempo curta e completa o bastante para servir de checklist (International Organization for Standardization, 2018a). A Figura 2.1 resume as definições e as tensões.

Vale notar que os três termos têm sentido técnico mais estreito que o do uso corrente. “Confidencial” na linguagem comum sugere sigilo absoluto; em segurança da informação, confidencialidade é um controle *relacional* — sempre em relação a um conjunto definido de sujeitos autorizados, nunca sigilo em abstrato.

2.2. Confidencialidade

Confidencialidade é a garantia de que a informação só é acessível a quem tem direito a ela. A definição embute uma pergunta prévia que costuma ficar sem resposta: *quem* tem direito? Sem classificação de informação e sem uma decisão explícita sobre quem precisa de que acesso, “proteger a confidencialidade” não tem conteúdo operacional.

2. Os pilares: confidencialidade, integridade e disponibilidade

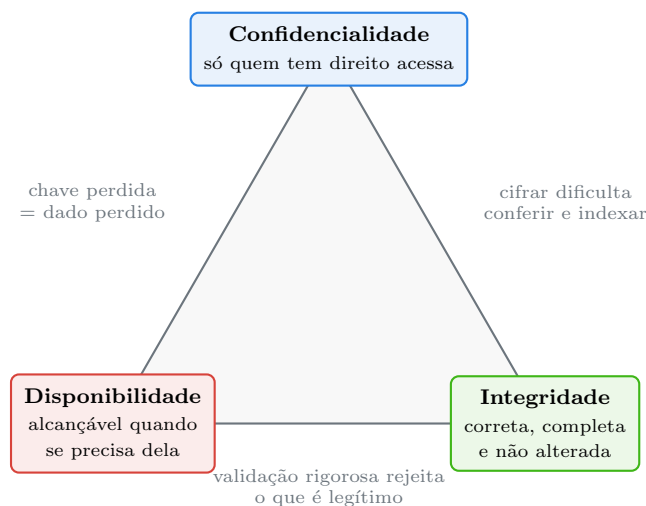


Figura 2.1.: A tríade CID e as tensões entre cada par. Reforçar um vértice quase sempre pressiona os outros dois.

2.2.1. Como a confidencialidade falha

O vazamento por invasão é o caso mais visível e o menos frequente. Os caminhos reais são mais prosaicos:

- **Excesso de permissão.** O compartilhamento de rede com acesso a “todos”, o *bucket* de armazenamento em nuvem com listagem pública, o grupo de mensagens da equipe técnica com cliente dentro. Ninguém invadiu nada: o acesso estava concedido.
- **Perda física.** Notebook furtado, pen drive esquecido, disco de servidor trocado por defeito e devolvido ao fornecedor com os dados legíveis.
- **Canal lateral e metadado.** A informação não vaza, mas se deduz. Um formulário de recuperação de senha que responde “e-mail não cadastrado” confirma quem é cliente. Tráfego cifrado revela, pelo padrão de tamanho e horário dos pacotes, qual serviço está sendo usado. Registro de conexão sem conteúdo ainda revela com quem alguém falou e quando — e é por isso que o Marco Civil trata log como dado sob sigilo.
- **Agregação e inferência.** Nome sozinho é público. Nome com CEP, data de nascimento e plano contratado identifica uma pessoa específica com precisão desconfortável. Bases anonimizadas por remoção de nome frequentemente reidentificam quando cruzadas com outra base.
- **Vazamento pelo canal legítimo.** O log de aplicação que grava o corpo da requisição, senha incluída. A mensagem de erro que devolve o rastro de execução com a *string* de conexão do banco. O relatório em PDF distribuído com texto “tarjado” por retângulo preto sobreposto — que o *pdftotext* recupera integralmente.

2.2.2. O que a defende

Quatro famílias de controle, em ordem de eficácia por real gasto:

1. **Minimização.** Dado que não se coleta não vaza; dado que se apaga no fim do prazo legal não vaza depois. É o único controle cuja eficácia é de 100% e cujo custo é negativo. A LGPD faz disso princípio jurídico (necessidade, art. 6º, III).
2. **Controle de acesso.** Autenticação, autorização e o princípio do menor privilégio. Cobre o caso do excesso de permissão, que é o mais comum. O Volume 4 é inteiro sobre isso.

3. **Cifragem.** Em repouso (disco, banco, backup) e em trânsito (TLS, VPN). Note o que a cifragem realmente faz: transfere o problema do dado para a **chave**. É uma troca excelente — proteger uma chave de 32 bytes é muito mais fácil que proteger 400 GB —, mas é uma troca, não uma solução mágica.
4. **Controles de descarte.** Sobrescrita verificável, apagamento criptográfico em disco autocifrante, destruição física. Fecha a última etapa do ciclo de vida da informação, apresentado no Capítulo 1.

2.3. Integridade

Integridade é a garantia de que a informação está correta e completa, e de que alterações não autorizadas são impedidas ou, no mínimo, detectáveis. Convém separar três níveis que costumam ser confundidos:

- **Integridade de bits.** Os bytes gravados são os bytes lidos. Ataca corrupção silenciosa de disco, erro de transmissão, falha de memória. Ferramentas: soma de verificação, memória com correção de erro, sistemas de arquivos com verificação de bloco (ZFS, Btrfs).
- **Integridade semântica.** O dado faz sentido segundo as regras do negócio. Vencimento entre 1 e 31, CPF válido, contrato ativo com endereço preenchido, saldo que nunca fica negativo sem lançamento correspondente. Ferramentas: restrições no banco, validação de entrada, transações com garantia ACID, conciliação.
- **Integridade de origem.** O dado veio de quem se afirma — que é autenticidade, tema do Capítulo 3, e se apoia em assinatura digital e código de autenticação de mensagem.

O incidente de abertura foi uma falha de integridade **semântica** com integridade de bits perfeita. É a categoria mais perigosa porque não dispara alarme: os sistemas continuam consistentes consigo mesmos, propagando o erro para relatórios, faturas e backups.

2.3.1. Por que a integridade é a mais difícil das três

Confidencialidade e disponibilidade têm sinais externos claros: o vazamento aparece, a queda aparece. A perda de integridade é silenciosa por construção. Some-se a isso o fato de que o dano se **propaga** — dado errado alimenta cálculo, que alimenta relatório, que alimenta decisão — e que a **detecção tardia inviabiliza a correção**, porque o backup íntegro já saiu da janela de retenção.

Daí três consequências práticas frequentemente ignoradas:

- Retenção de backup deve ser dimensionada pelo **tempo esperado até a detecção**, não pelo tempo de recuperação. Trinta dias cobrem exclusão accidental; não cobrem corrupção lenta.
- Vale manter, além das diárias de curto prazo, cópias **mensais e anuais de longa retenção** — o esquema avô-pai-filho existe justamente para isso.
- Conciliação periódica com uma fonte independente (contagem física, extrato bancário, base de outro sistema) é o único mecanismo que detecta erro semântico consistente.

2.3.2. O que a defende

Soma de verificação e hash criptográfico para detecção; assinatura digital para detecção e atribuição; controle de versão e registro de alterações para reconstrução; transações e restrições de integridade referencial para prevenção; armazenamento imutável (WORM, bloqueio de objeto, cópia instantânea com retenção travada) para impedir sobrescrita — que é, hoje, o controle mais eficaz contra ransomware, porque ataca a estratégia do adversário de apagar as cópias antes de cifrar o original.

2.4. Disponibilidade

Disponibilidade é a garantia de que quem tem direito à informação a alcança quando precisa. É a propriedade mais fácil de medir e a que consome mais orçamento de infraestrutura.

A métrica canônica é o percentual de tempo em operação num período. A Figura 2.2 mostra o que cada patamar significa em minutos por ano — e é o argumento mais eficiente que existe contra a promessa de “99,99%” feita sem cálculo.

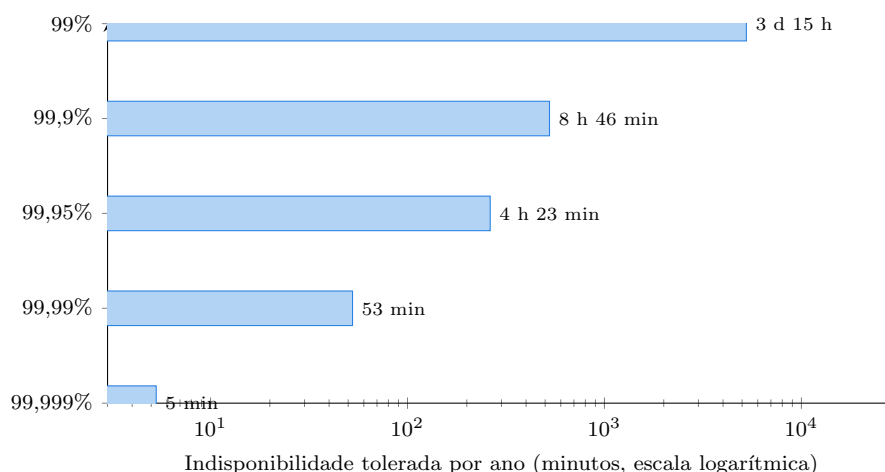


Figura 2.2.: Indisponibilidade anual tolerada por patamar de disponibilidade. Cada nove adicional custa aproximadamente uma ordem de grandeza a mais.

Dois cuidados de leitura. Primeiro, disponibilidade **composta**: se um serviço depende de quatro componentes em série, cada um com 99,9%, a disponibilidade do conjunto é $0,999^4 \approx 99,6\%$ — quatro vezes mais tempo fora do ar que o de cada peça isolada. Segundo, o número sozinho não descreve a experiência: 52 minutos fora do ar distribuídos em paradas de 30 segundos durante a madrugada e 52 minutos contínuos numa terça às 10h são o mesmo 99,99% e situações incomparáveis.

2.4.1. RTO e RPO

Disponibilidade em regime é uma coisa; recuperação depois de um desastre é outra, e tem duas métricas próprias, ilustradas na Figura 2.3.

O **RPO** (*recovery point objective*) é a quantidade máxima aceitável de dados perdidos, expressa em tempo: backup diário às 2h implica RPO de até 24 horas. O **RTO** (*recovery time objective*) é o tempo máximo aceitável até o serviço voltar. Ambos são definidos pela área de negócio e

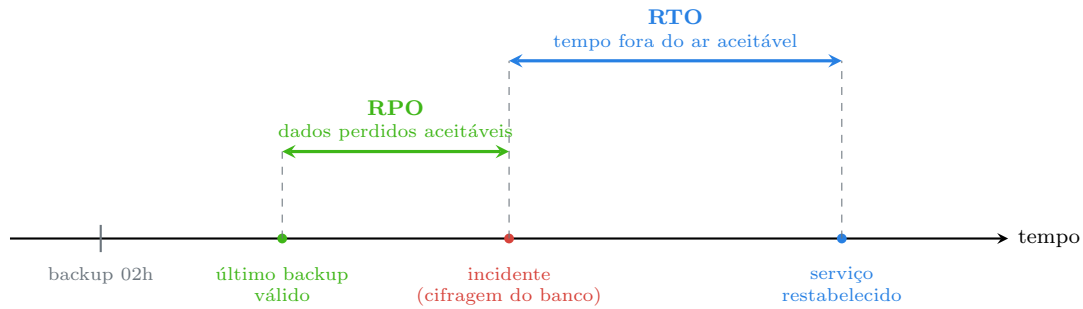


Figura 2.3.: RPO mede quanto trabalho se perde; RTO mede quanto tempo se fica parado. São decisões de negócio, não de infraestrutura.

depois traduzidos em arquitetura — a inversão comum, em que a infraestrutura existente define o RPO por acidente, é a razão de tantas surpresas no dia do incidente.

2.4.2. O que a ameaça e o que a defende

Contra disponibilidade jogam falha de hardware, erro humano, esgotamento de capacidade, dependência externa (energia, link, fornecedor de nuvem), evento ambiental e, por último na lista de frequência, ataque deliberado. Defendem-na redundância sem ponto único de falha, capacidade folgada, backup testado, monitoramento com alarme antes do limite, e — o item mais barato e mais esquecido — **procedimento escrito de recuperação que alguém já executou pelo menos uma vez**.

2.5. As três colidem

A Tabela 2.1 reúne os tradeoffs mais comuns. Reconhecê-los como escolhas, e não como falhas de projeto, é o que separa uma decisão de segurança de um reflexo.

Tabela 2.1.: Conflitos típicos entre os pilares. Nenhum tem resposta universal; todos têm resposta correta *dado o contexto*.

Decisão	Ganha	Pressiona
Cifrar backups	Confidencialidade	Disponibilidade (chave perdida = backup inútil)
Bloquear a conta após 3 erros de senha	Confidencialidade	Disponibilidade (negação de serviço trivial contra usuários)
Validação rigorosa de entrada	Integridade	Disponibilidade (rejeita o legítimo atípico)
Replicação síncrona entre sites	Disponibilidade e integridade	Custo e desempenho; propaga o erro lógico instantaneamente
Retenção longa de log	Integridade e responsabilização	Confidencialidade (mais dado sensível guardado por mais tempo)
Segundo fator em tudo	Confidencialidade	Disponibilidade (celular perdido trava o acesso) e aceitação do usuário

2. Os pilares: confidencialidade, integridade e disponibilidade

Decisão	Ganha	Pressiona
Alta disponibilidade por múltiplas cópias	Disponibilidade	Confidencialidade (mais lugares de onde vazar)

2.6. A ordem de prioridade muda com o contexto

Não existe hierarquia fixa entre os três pilares — existe a hierarquia daquele ambiente, e ela precisa ser declarada, porque é ela que resolve os conflitos da tabela anterior.

Tabela 2.2.: A ordem de prioridade é uma decisão de contexto e precisa estar escrita.

Contexto	Ordem típica	Por quê
Hospital, prontuário eletrônico	$D > I > C$	Prontuário inacessível na emergência custa vidas; o sigilo é gravíssimo, mas cede
Instituição financeira, núcleo bancário	$I > D > C$	Saldo errado destrói a instituição; a operação para até conciliar
Provedor de acesso, rede de transporte	$D > I > C$	O produto vendido é a conectividade; a métrica contratual é o tempo em operação
Provedor de acesso, base cadastral	$C > I > D$	CPF, endereço e meio de pagamento, sob a LGPD
Automação industrial e OT	$D > I > C$	Parada de linha e risco físico a pessoas
Órgão de inteligência e defesa	$C > I > D$	Vazamento é irreversível; indisponibilidade é contornável

Repare que o mesmo provedor aparece duas vezes com ordens opostas. Não é contradição: são **ativos diferentes**, e é exatamente por isso que a classificação da informação precede a escolha de controle.

2.7. Além da tríade

A tríade não é a última palavra. Duas extensões merecem registro.

Donn Parker propôs o **hexágono parkeriano**, acrescentando três propriedades que a tríade não captura bem (Parker, 1998): **posse ou controle** (perder o disco é dano ainda que ele esteja cifrado e nada tenha sido lido), **autenticidade** (a origem é quem afirma ser) e **utilidade** (o dado existe, íntegro e acessível, mas está num formato que ninguém consegue mais abrir — a fita sem leitor, o arquivo do sistema descontinuado). A distinção “posse” é a mais útil na prática: notificar um incidente à ANPD não depende de provar que alguém leu os dados.

A segunda extensão é a que este manual adota: **autenticidade, não repúdio e responsabilização** como propriedades de primeira classe, tratadas no Capítulo 3. Sem elas, não se descreve corretamente nem uma transação financeira nem uma trilha de auditoria.

2.8. Brasil em Foco

As três propriedades aparecem no direito brasileiro com nome próprio e consequência distinta para cada uma.

A **LGPD** trata a tríade explicitamente. O art. 6º lista entre os princípios do tratamento a **qualidade dos dados** (inciso V — exatidão, clareza, relevância e atualização, que é integridade em linguagem jurídica), a **segurança** (inciso VII — proteção contra acessos não autorizados e situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão, que cobre os três pilares de uma vez) e a **prevenção** (inciso VIII) (Brasil, 2018). O art. 46 impõe o dever de adotar medidas técnicas e administrativas, e o art. 18 dá ao titular o direito de exigir **correção de dados incompletos, inexatos ou desatualizados** — um direito subjetivo de integridade, exercível contra a empresa. No incidente de abertura deste capítulo, cada assinante com vencimento trocado tinha esse direito.

Vale sublinhar o alcance do art. 48: o dever de comunicar incidente à ANPD e aos titulares **não se restringe a vazamento**. A redação fala em incidente de segurança que possa acarretar risco ou dano relevante, e a Resolução CD/ANPD nº 15/2024 detalha o rito e o prazo de três dias úteis (Autoridade Nacional de Proteção de Dados, 2024). Destruição acidental de base e indisponibilidade prolongada de dados pessoais são hipóteses de comunicação — a leitura de que “só notifica quem vaza” é incorreta e comum.

Do lado da **disponibilidade**, quem presta serviço de telecomunicações tem obrigação regulatória direta: a Anatel fixa indicadores de qualidade e disponibilidade no RQUAL (Resolução nº 717/2019), com coleta, meta e possibilidade de sanção (Agência Nacional de Telecomunicações, 2019). Disponibilidade, nesse caso, não é apenas expectativa do cliente — é indicador reportado ao regulador.

Do lado da **integridade**, o Marco Civil exige a guarda de registros de conexão por um ano e de acesso a aplicações por seis meses (arts. 13 e 15), sob sigilo e com disponibilização mediante ordem judicial (Brasil, 2014). Um log só cumpre sua função probatória se for íntegro e se o horário for confiável: sem NTP sincronizado e sem proteção contra alteração, o registro perde valor exatamente quando é necessário. O art. 13, §2º prevê ainda a requisição cautelar de guarda por prazo maior — o que só se atende se o dado ainda existir quando o pedido chegar.

No setor financeiro, a Resolução CMN nº 4.893/2021 exige política de segurança cibernética com controles de confidencialidade, integridade e disponibilidade dos dados e sistemas, além de plano de continuidade e de testes periódicos (Banco Central do Brasil, 2021). Para o Pix, a disponibilidade do arranjo é acompanhada pelo Banco Central com indicadores próprios, e a instituição responde pela indisponibilidade que afete a liquidação.

2.9. No Campo

O que muda concretamente para quem administra rede e servidores, organizado por pilar.

Confidencialidade. Cifragem de disco em todo equipamento que sai do prédio, sem exceção — notebook do comercial incluído. Cifragem também no backup, com a chave guardada em local independente do servidor (cofre de senhas da equipe, com cópia impressa em envelope lacrado, é solução legítima). TLS obrigatório em tudo, inclusive na rede interna. Revisão trimestral de quem tem acesso a quê:

2. Os pilares: confidencialidade, integridade e disponibilidade

```
# Quem consegue autenticar via SSH nesta máquina
grep -E '^(AllowUsers|AllowGroups|PermitRootLogin|PasswordAuthentication)'
↪ /etc/ssh/sshd_config
getent group sudo wheel adm 2>/dev/null

# Compartilhamentos Samba abertos a convidado - achado clássico
grep -rniE 'guest ok *= *yes|public *= *yes' /etc/samba/smb.conf

# Arquivos de configuração legíveis por qualquer usuário (senhas costumam morar
↪ aqui)
find /etc /opt /srv -type f \( -name '*.conf' -o -name '*.env' -o -name '*.ini'
↪ \) \
    -perm -o=r 2>/dev/null | head -40
```

Integridade. Verificação periódica de mídia e de backup, agendada e com alerta em caso de divergência:

```
# ZFS: varredura completa de blocos com verificação de soma
zpool scrub tank && zpool status tank

# Verificação de integridade do repositório de backup (restic)
restic -r /mnt/backup check --read-data-subset=10%

# Conferência de um artefato baixado, antes de instalar
sha256sum -c imagem.iso.sha256

# Saúde do disco antes de ele falhar - atributos que antecipam corrupção
smartctl -A /dev/sda | grep -Ei 'reallocated|pending|uncorrect|crc'
```

Três hábitos valem mais que qualquer ferramenta: **restaurar de verdade** um backup por trimestre e conferir o conteúdo, não só o código de retorno do comando; manter **retenção longa** (mensal por 12 meses, anual por 5) para cobrir detecção tardia; e **conciliar** mensalmente uma amostra do cadastro contra uma fonte independente.

Disponibilidade. Redundância que resolve ponto único de falha real, e não redundância decorativa: dois links do mesmo provedor entrando pela mesma canaleta são um link. Monitorar tendência, não só limiar — disco a 78% crescendo 2% ao dia é um incidente agendado para daqui a onze dias:

```
# Uso de disco por sistema de arquivos, dos mais cheios para os mais vazios
df -h --output=pcent,size,used,target -x tmpfs -x devtmpfs | sort -rn | head

# Reinicializações e quedas registradas
last -x reboot shutdown | head

# Serviços que falharam desde o último boot
systemctl --failed --no-pager
```

E a checagem que fecha o ciclo: escrever, para os três serviços mais críticos, o RTO e o RPO **acordados com quem responde pelo negócio**, comparar com o que a infraestrutura atual

entrega de fato, e levar a diferença para a mesa como decisão consciente de risco — que é o assunto do Capítulo 6.

2.10. Resumo

- Confidencialidade, integridade e disponibilidade são propriedades **independentes**: excelência em duas não compensa falha na terceira, e cada uma falha por caminhos próprios.
- A confidencialidade quase nunca falha por invasão — falha por excesso de permissão, perda física, metadado, inferência e vazamento pelo canal legítimo. Minimizar o dado coletado é o controle mais eficaz e o de menor custo.
- A integridade é a mais difícil das três porque falha em silêncio, propaga o dano e pode ser detectada tarde demais para o backup ajudar. Retenção deve ser dimensionada pelo tempo até a detecção, e conciliação com fonte independente é o que revela erro semântico.
- Disponibilidade é composta e se degrada em série: quatro componentes de 99,9% entregam 99,6%. **RPO** mede dados perdidos, **RTO** mede tempo parado, e ambos são decisão de negócio traduzida depois em arquitetura.
- Os pilares **conflitam**, e a ordem de prioridade depende do contexto e do ativo — hospital, banco e provedor ordenam de formas diferentes, e o mesmo provedor ordena diferente para a rede de transporte e para a base cadastral.
- No Brasil, os três têm âncora normativa: LGPD (arts. 6º, 18, 46 e 48, com comunicação de incidente em três dias úteis e direito de correção), Marco Civil (guarda íntegra de registros), Anatel RQUAL (disponibilidade como indicador regulado) e Resolução CMN 4.893/2021 no setor financeiro.

3. Autenticidade, não repúdio e responsabilização

Numa quinta-feira de junho, o setor financeiro de um provedor recebeu um e-mail do fornecedor de equipamentos ópticos com quem trabalhava havia seis anos. A mensagem vinha na mesma cadeia de respostas de uma negociação real em andamento, com o histórico completo abaixo, a assinatura de sempre e o mesmo tom. Informava mudança de banco e anexava a nota reemitida com os novos dados. O pagamento de R\$ 118 mil saiu no dia seguinte.

O domínio remetente não era `fornecedor.com.br`, e sim `fornecedor-com.br`. Nada mais no e-mail era falso: o histórico era autêntico, porque a caixa de um vendedor do fornecedor havia sido comprometida semanas antes e a conversa fora copiada dali. Não houve invasão do provedor, não houve malware, não houve nenhuma falha nos três pilares do Capítulo 2. Confidencialidade, integridade e disponibilidade da mensagem estavam preservadas: ela chegou íntegra, no horário, a quem devia. O que faltou foi uma propriedade diferente — **a garantia de que a origem é quem afirma ser**.

Dentro do mesmo provedor, na mesma semana, um segundo episódio menor: alguém executou no `ip route 0.0.0.0/0` no roteador de borda às 14h20 de uma quarta e derrubou a saída por dezenove minutos. O log do equipamento registrou o comando com precisão de segundo. Registrou também o usuário: `admin`. Como as sete pessoas da equipe técnica usavam `admin`, o log respondeu o que aconteceu e quando, e não respondeu a única pergunta que faltava.

Este capítulo trata das três propriedades que os pilares clássicos não cobrem: **autenticidade** (a origem é quem afirma ser), **não repúdio** (a origem não pode negar depois) e **responsabilização** (cada ação é atribuível a um sujeito identificado).

3.1. Quatro coisas diferentes que se confundem

Antes das três propriedades, é preciso separar quatro conceitos que a linguagem cotidiana funde e cuja confusão produz erros de arquitetura recorrentes. A Figura 3.1 mostra a cadeia.

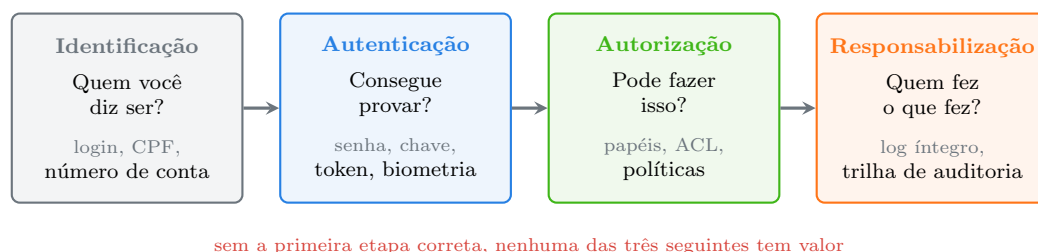


Figura 3.1.: Identificação, autenticação, autorização e responsabilização. Quatro perguntas distintas, quatro mecanismos distintos.

Identificação é a alegação: “sou o usuário `mmatos`”. É pública e não prova nada. **Autenticação** é a verificação dessa alegação contra uma evidência. **Autorização** é a decisão sobre o que aquele

3. Autenticidade, não repúdio e responsabilização

sujeito, já autenticado, pode fazer. E **responsabilização** é a capacidade, *depois*, de atribuir cada ação a um sujeito.

Duas confusões custam caro na prática. A primeira é tratar identificação como autenticação — é o que faz uma central de atendimento liberar mudança cadastral porque a pessoa “sabe o CPF”, quando o CPF é dado de identificação, presente em dezenas de bases e amplamente vazado. A segunda é presumir que autenticação forte resolve a responsabilização: se sete pessoas compartilham a credencial, o segundo fator apenas garante que *alguém do grupo* entrou.

3.2. Autenticidade

Autenticidade é a garantia de que uma entidade, mensagem ou dado é genuinamente o que ou de quem se afirma. Vem em três recortes:

- **Autenticidade de entidade.** Quem está do outro lado da conexão é mesmo aquele servidor, aquele usuário, aquele equipamento. É o que o certificado TLS resolve para o servidor e o que a autenticação resolve para o usuário.
- **Autenticidade de mensagem ou de dado.** Aquele arquivo, e-mail ou pacote realmente foi produzido pela origem alegada. É o que faltou no caso de abertura.
- **Autenticidade de origem em tempo real.** Além de vir da origem certa, a mensagem é *desta* conversa e não a repetição de uma anterior — o problema do frescor, tratado adiante.

Note que autenticidade e integridade caminham juntas mas não são a mesma coisa. Integridade responde “isto foi alterado?”; autenticidade responde “quem produziu isto?”. Um hash SHA-256 publicado ao lado de um arquivo dá integridade contra corrupção acidental, e não dá autenticidade nenhuma: quem alterou o arquivo altera o hash publicado na mesma página. A diferença é a existência de um **segredo** que só a origem legítima possui.

3.2.1. Os dois mecanismos, e por que não são intercambiáveis

Existem duas famílias criptográficas para autenticidade de mensagem, e a diferença entre elas é a diferença entre ter e não ter não repúdio (Figura 3.2).

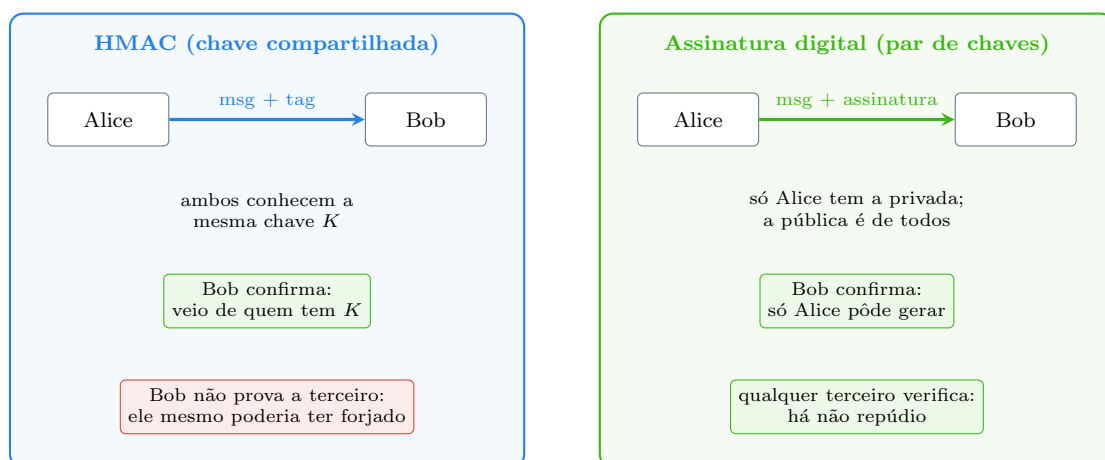


Figura 3.2.: Chave simétrica compartilhada dá autenticidade entre as partes; só o par de chaves assimétrico sustenta não repúdio perante terceiros.

Um **código de autenticação de mensagem** (MAC, tipicamente HMAC) usa uma chave secreta compartilhada entre remetente e destinatário. É rápido, simples e suficiente quando as duas partes confiam uma na outra e o objetivo é apenas detectar adulteração e impostor. Mas, como *ambos* possuem a chave, o destinatário poderia ter produzido a mesma tag — logo não consegue provar a um juiz que a mensagem veio do remetente.

Uma **assinatura digital** usa um par de chaves: a privada, que só a origem possui, gera a assinatura; a pública, que todos podem ter, a verifica. Isso permite que *qualquer terceiro* verifique, e é a base do não repúdio. A mecânica de ambas é assunto do Volume 3.

3.2.2. Autenticidade no e-mail: o caso de abertura resolvido

O correio eletrônico nasceu sem autenticidade nenhuma: o campo **From:** é preenchido livremente por quem envia, como o remetente escrito no verso de um envelope. Três mecanismos foram acrescentados depois:

- **SPF** declara, em registro DNS do domínio, quais servidores estão autorizados a enviar em seu nome. Verifica o envelope, não o **From:** que o usuário vê.
- **DKIM** assina criptograficamente cabeçalhos e corpo da mensagem com uma chave cujo par público está publicado no DNS do domínio. Dá autenticidade de origem e integridade, e sobrevive a encaminhamentos.
- **DMARC** amarra os dois ao domínio que o usuário efetivamente lê, define a política para quem falha na verificação (**none**, **quarantine**, **reject**) e produz relatórios.

E aqui está o ponto desconfortável do caso de abertura: **os três teriam passado**. O domínio **fornecedor-com.br** era real, registrado pelo atacante, com SPF e DKIM próprios corretamente configurados. A mensagem era autêntica — de um domínio que não era o esperado. Autenticidade criptográfica prova a origem; não prova que a origem é a *certa*. É por isso que o controle que resolve esse ataque não é técnico, e sim de processo: **mudança de dados bancários de fornecedor só vale com confirmação por canal independente**, telefone conhecido de cadastro anterior, nunca o número que veio no próprio e-mail.

3.2.3. Frescor: autenticidade não basta

Uma mensagem legítima, capturada e retransmitida depois, continua sendo autêntica — e é um ataque. É a **repetição** (*replay*): o comando de abertura de cancela gravado por rádio e reenviado à noite; a requisição de transferência interceptada e repetida cinco vezes.

Os antídotos são três, e quase todo protocolo sério usa alguma combinação deles: **nonce** (valor único por transação, que o destinatário recusa se repetido), **carimbo de tempo** com janela estreita de aceitação, e **contador de sequência** monotônico. É por isso que a sincronização de relógio (Capítulo 2) é requisito de segurança e não conveniência operacional: com relógios divergindo minutos, a janela de aceitação precisa ser alargada, e a janela alargada é exatamente a brecha para repetição.

3.3. Não repúdio

Não repúdio é a garantia de que quem praticou um ato não consiga negar tê-lo praticado, de forma sustentável perante um terceiro. É a propriedade mais mal-empregada do vocabulário da área, porque exige muito mais do que criptografia.

3. Autenticidade, não repúdio e responsabilização

Para que o não repúdio se sustente, cinco condições precisam valer ao mesmo tempo:

1. **Controle exclusivo da chave.** Se a chave privada estava num servidor a que cinco pessoas tinham acesso administrativo, ou numa planilha, “só o titular poderia ter assinado” é falso. Daí o uso de módulo de segurança em hardware e de cartão com chave não exportável.
2. **Vínculo confiável entre chave e pessoa.** Alguém precisa ter verificado a identidade do titular antes de emitir o certificado, e essa cadeia precisa ser auditável — é o papel de uma infraestrutura de chaves públicas, tema do Volume 3.
3. **Carimbo de tempo confiável.** Sem uma marca temporal de terceira parte, não se distingue uma assinatura feita antes da revogação da chave de outra feita depois.
4. **Integridade do que foi assinado.** A assinatura cobre um documento específico; o documento tem de ser preservado exatamente como assinado.
5. **Registro do processo.** Como a assinatura foi coletada, com que consentimento, sob que interface.

Falhando qualquer uma, o que resta é uma evidência forte — útil, muitas vezes decisiva — mas não uma impossibilidade de negar. Convém então distinguir dois níveis:

- **Não repúdio técnico:** a propriedade matemática de que só quem detém a chave privada poderia ter produzido aquela assinatura.
- **Não repúdio jurídico:** a aceitação, por um julgador, de que aquela pessoa praticou aquele ato. Admite contraprova — a alegação de chave roubada, de coação, de vício de consentimento.

Nenhum sistema entrega o segundo automaticamente. O que a engenharia entrega é a evidência que torna a negativa implausível, e o quanto de implausibilidade se consegue é proporcional ao cuidado com as cinco condições acima.

3.4. Responsabilização

Responsabilização (*accountability*) é a capacidade de atribuir cada ação relevante a um sujeito identificado, depois do fato. É a propriedade que sustenta investigação de incidente, auditoria, dissuasão interna e cumprimento de obrigação regulatória — e é a que o **admin** compartilhado do caso de abertura destrói por completo.

Seus requisitos são quatro:

Contas nomeadas e individuais. Não negociável. Toda credencial pertence a uma pessoa; contas de serviço pertencem a um sistema e têm dono humano registrado. Quando é tecnicamente necessário usar uma conta genérica — equipamento antigo que só aceita um usuário local —, o acesso deve passar por um intermediário que registre quem a usou: servidor de salto, ferramenta de acesso privilegiado, ou ao menos autenticação centralizada via RADIUS/TACACS+.

Registro suficiente. Quem, o quê, quando, de onde, com que resultado. Um log que registra “login bem-sucedido” sem o endereço de origem, ou “configuração alterada” sem dizer o quê, ocupa disco sem produzir responsabilização.

Horário confiável e uniforme. Correlacionar eventos entre firewall, servidor e aplicação exige que os três concordem sobre que horas são, e sobre qual fuso estão reportando.

Integridade do próprio registro. Este é o requisito mais negligenciado: um log que o administrador comprometido pode editar não responsabiliza ninguém. Quem invade um servidor limpa os rastros como parte da rotina. As defesas são o envio imediato para um coletor remoto

ao qual a máquina de origem não tem permissão de escrita retroativa, armazenamento imutável, e o **encadeamento por hash** ilustrado na Figura 3.3.

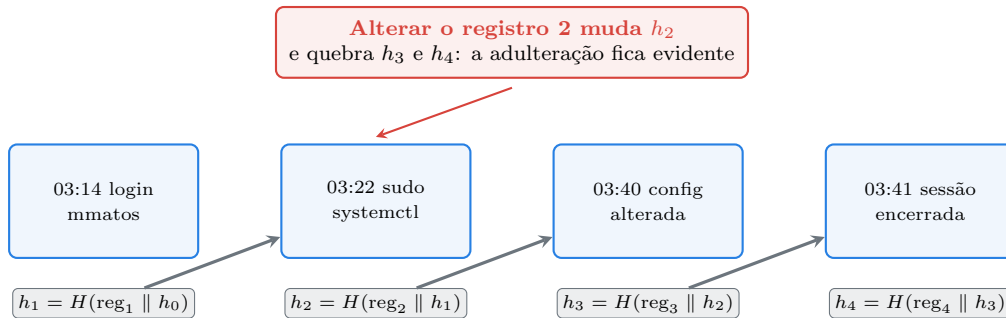


Figura 3.3.: Log encadeado por hash: cada registro incorpora o resumo do anterior, de modo que uma alteração isolada é detectável.

Vale registrar o limite dessa técnica: o encadeamento detecta alteração e remoção no meio da cadeia, mas não impede que um atacante com controle total *trunque* o log a partir de certo ponto e recomece a cadeia. Por isso o encadeamento se combina com publicação periódica da âncora — enviar o hash corrente para fora da máquina a cada intervalo — e com o envio remoto em tempo real. É a mesma lógica de defesa em profundidade do Capítulo 1: nenhuma camada isolada basta.

3.4.1. Segregação de funções

Responsabilização tem uma contraparte preventiva: **segregação de funções**. Quem executa não é quem aprova; quem administra o sistema não é quem audita os logs dele; quem cadastra o fornecedor não é quem libera o pagamento. É a aplicação direta do princípio de separação de privilégios de Saltzer e Schroeder (Saltzer; Schroeder, 1975), e é o que teria interrompido o golpe de abertura em duas frentes: alteração de dado bancário exigindo aprovação de segunda pessoa, e pagamento acima de um limite exigindo dupla assinatura.

Em equipes pequenas a segregação plena é impossível — três pessoas não se dividem em seis papéis. A alternativa aceita é **compensar por detecção**: se a mesma pessoa cadastra e paga, então um terceiro (o sócio, o contador) revisa mensalmente todos os cadastros bancários alterados. A regra sobrevive com custo diferente; o que não sobrevive é fingir que ela existe.

3.5. Como as seis propriedades se encaixam

A Tabela 3.1 reúne a tríade do Capítulo 2 e as três deste capítulo, com o mecanismo típico de cada uma.

Tabela 3.1.: As seis propriedades, a pergunta de cada uma e o mecanismo que a sustenta.

Propriedade	Pergunta que responde	Mecanismo típico
Confidencialidade	Quem consegue ler?	Controle de acesso, cifragem, minimização
Integridade	Foi alterado?	Hash, restrições, transações, armazenamento imutável

3. Autenticidade, não repúdio e responsabilização

Propriedade	Pergunta que responde	Mecanismo típico
Disponibilidade	Está acessível quando preciso?	Redundância, capacidade, backup testado
Autenticidade	Veio mesmo de quem diz?	HMAC, assinatura digital, certificados, DKIM
Não repúdio	A origem pode negar depois?	Assinatura com chave sob controle exclusivo, carimbo de tempo
Responsabilização	Quem fez o quê?	Conta nomeada, log íntegro, relógio sincronizado, segregação

A leitura mais útil dessa tabela é diagnóstica: diante de um incidente, perguntar qual das seis linhas falhou costuma apontar o controle ausente mais rápido do que qualquer outra heurística.

3.6. Brasil em Foco

O Brasil construiu, antes da maioria dos países, um arcabouço jurídico para autenticidade e não repúdio de documento eletrônico — e ele tem detalhes que mudam decisões técnicas.

A **Medida Provisória nº 2.200-2/2001** instituiu a ICP-Brasil e é a peça central (Brasil, 2001). Seu art. 10, §1º estabelece que declarações constantes de documento eletrônico assinado com certificado ICP-Brasil **presumem-se verdadeiras em relação aos signatários**. É presunção relativa — admite prova em contrário —, mas inverte o ônus: quem nega precisa provar que não assinou. O §2º do mesmo artigo é igualmente importante e menos citado: admite outros meios de comprovação de autoria e integridade, **desde que aceitos pelas partes ou pela pessoa a quem for oposto o documento**. Ou seja, assinatura fora da ICP-Brasil vale — só não carrega a presunção legal, e depende de acordo prévio ou de convencimento no caso concreto.

A **Lei nº 14.063/2020** organizou o campo em três níveis (Brasil, 2020):

Tabela 3.2.: Os três níveis de assinatura eletrônica da Lei 14.063/2020.

Nível	O que exige	Uso típico
Simples	Identifica o signatário e anexa dados em formato eletrônico	Interações de baixo risco; login em serviço público
Avançada	Controle exclusivo do signatário, detecção de alteração posterior, vínculo com a identidade — sem exigir ICP-Brasil	Atos de médio risco; assinatura gov.br
Qualificada	Certificado ICP-Brasil	Atos de maior risco, registro público, o que a lei exigir

O **Código de Processo Civil** completa o quadro: o art. 411 dispõe que se considera autêntico o documento quando assinado digitalmente na forma da lei, e o art. 441 admite documentos eletrônicos produzidos e conservados com observância da legislação específica. Na prática forense, log de servidor sem assinatura nem cadeia de custódia não é imprestável, mas seu peso probatório depende inteiramente da credibilidade do processo de coleta — assunto do Volume 13.

Para **responsabilização**, o Marco Civil impõe a guarda de registros (arts. 13 e 15) e submete sua disponibilização a ordem judicial (arts. 10 e 22), exigindo do requerente indícios do ilícito, identificação clara do usuário e período determinado (Brasil, 2014). O provedor precisa, portanto, conseguir responder *a quem pertencia aquele endereço IP naquele instante* — o que, num cenário de CGNAT, depende de registrar também a porta de origem e o horário com precisão. Registro sem porta em rede com NAT em larga escala responde por centenas de assinantes ao mesmo tempo e não individualiza ninguém.

A **LGPD** trata responsabilização como princípio expreso: o art. 6º, X exige a demonstração da adoção de medidas eficazes de cumprimento (*accountability*), e o art. 37 obriga o controlador e o operador a **manter registro das operações de tratamento** que realizarem (Brasil, 2018). Não é registro técnico apenas — é registro que precisa ser exibível à ANPD.

Do lado penal, a **Lei nº 12.737/2012** e a **Lei nº 14.155/2021** alcançam diretamente a falsidade de origem: o estelionato praticado por meio eletrônico ganhou forma qualificada no art. 171, §2º-A do Código Penal, com pena de reclusão de 4 a 8 anos, e o §2º-B agrava quando praticado contra idoso ou vulnerável (Brasil, 2021). A fraude do e-mail corporativo do caso de abertura é exatamente essa figura, e a investigação depende dos registros que o Marco Civil obriga a guardar.

Por fim, para quem opera telecomunicações: a Anatel exige identificação inequívoca do assinante no cadastro, e o **Pix** trouxe ao Banco Central um regime em que a autenticidade da ordem de pagamento é responsabilidade da instituição — com o Mecanismo Especial de Devolução para casos de fraude. É o Volume 10 que retoma o tema pelo lado da engenharia social.

3.7. No Campo

1. Acabar com a conta compartilhada. É a intervenção de maior retorno deste capítulo. Cada pessoa com sua conta em servidores, roteadores, OLTs, sistema de gestão e painel do provedor de nuvem. Em equipamento de rede, centralizar em RADIUS ou TACACS+ resolve simultaneamente a nomeação, a revogação no desligamento e o registro:

```
# Chaves SSH autorizadas - cada linha deve ter dono identificável no comentário
for u in $(awk -F: '$3>=1000 {print $1}' /etc/passwd); do
    f="/home/$u/.ssh/authorized_keys"
    [ -f "$f" ] && awk -v u="$u" '{print u, $NF}' "$f"
done

# Quem usou sudo nas últimas 24 h, e para quê
journalctl _COMM=sudo --since "24 hours ago" -o cat | grep -oP 'USER=\S+ ;
↳  COMMAND=.*'

# Contas com senha vazia ou sem expiração definida
awk -F: '($2 == "" ) {print "SEM SENHA:", $1}' /etc/shadow
```

2. Enviar o log para fora da máquina, no ato. Coletor remoto que a origem não pode reescrever. No **rsyslog**, uma linha basta; o essencial é o coletor **não** aceitar que o cliente apague o que já enviou:

3. Autenticidade, não repúdio e responsabilização

```
# /etc/rsyslog.d/90-remoto.conf - encaminha tudo, com fila em disco se o
↪ coletor cair
** action(type="omfwd" target="10.20.0.9" port="6514" protocol="tcp"
    StreamDriver="gtls" StreamDriverMode="1"
    queue.type="LinkedList" queue.filename="fwd"
    ↪ queue.saveOnShutdown="on")
```

3. Sincronizar o relógio em tudo. Servidor, roteador, switch, OLT, câmera, controlador de acesso. Diferença de fuso e horário de verão devem ser tratados registrando em UTC e convertendo na exibição:

```
timedatectl set-timezone America/Sao_Paulo
timedatectl set-ntp true
chronyc tracking | grep -E 'Reference ID|System time|Stratum'
```

4. Autenticar o e-mail do próprio domínio. SPF, DKIM e DMARC publicados, com política progressiva: começar em `p=none` para colher relatórios, corrigir os remetentes legítimos que falharem e só então subir para `quarantine` e `reject`:

```
dig +short TXT provedor.exemplo.br          # SPF
dig +short TXT _dmarc.provedor.exemplo.br    # DMARC
dig +short TXT seletor._domainkey.provedor.exemplo.br # DKIM
```

E o complemento defensivo contra o caso de abertura: registrar os domínios parecidos com o seu (troca de hífen, letras trocadas, `.com` por `.com.br`) e monitorar registros novos semelhantes ao seu domínio, que é o que viabiliza a fraude.

5. Um processo, não um produto, para pagamento. Alteração de dados bancários de fornecedor confirmada por telefone constante do cadastro anterior, nunca pelo contato informado na própria mensagem. Aprovação por segunda pessoa acima de um limite definido. Revisão mensal, por alguém de fora do processo, de todos os cadastros bancários alterados no período.

6. Assinar o que precisa sobreviver a uma disputa. Contrato com assinatura qualificada quando a lei exigir, avançada quando bastar. Pacote e imagem distribuídos para clientes assinados. Em repositório de código, assinar as versões publicadas:

```
# Verificar assinatura de um pacote antes de instalar
gpg --verify release-2.4.tar.gz.asc release-2.4.tar.gz

# Assinar as próprias tags de versão
git tag -s v2.4 -m "versão 2.4" && git tag -v v2.4
```

7. Testar a responsabilização com uma pergunta. Escolha uma alteração de configuração feita há três meses num equipamento de borda e tente responder, apenas com o que está registrado: quem fez, de onde, com que autorização, e quem aprovou. Se a resposta não sair em quinze minutos, o problema não é o log — é o desenho do processo.

3.8. Resumo

- **Identificação, autenticação, autorização e responsabilização** são quatro perguntas distintas. Tratar dado de identificação (CPF, número de contrato) como prova de identidade é a raiz de boa parte da fraude por atendimento.
- **Autenticidade** garante que a origem é quem afirma ser; integridade só garante que nada foi alterado. A diferença é a existência de um segredo detido pela origem — e é por isso que hash publicado ao lado do arquivo não autentica nada.
- **HMAC** dá autenticidade entre duas partes que compartilham a chave; só a **assinatura digital**, com chave privada sob controle exclusivo, sustenta **não repúdio** perante terceiros.
- SPF, DKIM e DMARC autenticam o *domínio*, não a *identidade comercial*: um domínio parecido, registrado pelo golpista e corretamente configurado, passa em todos os três. Contra isso, o controle é de processo — confirmação por canal independente.
- **Não repúdio técnico jurídico**. Exige controle exclusivo da chave, vínculo auditável com a pessoa, carimbo de tempo, preservação do documento e registro do processo; faltando um, resta evidência forte, não impossibilidade de negar.
- **Responsabilização** exige conta nomeada, registro suficiente, relógio sincronizado e log íntegro — encadeado por hash e enviado a um coletor remoto que a máquina de origem não pode reescrever. Conta **admin** compartilhada a destrói inteiramente.
- No Brasil: MP 2.200-2/2001 dá presunção de veracidade à assinatura ICP-Brasil e admite outros meios acordados entre as partes; a Lei 14.063/2020 estabelece os níveis simples, avançada e qualificada; o Marco Civil exige guarda de registros que individualizem o usuário (porta inclusa, sob CGNAT); a LGPD faz da *accountability* princípio e do registro de operações uma obrigação.

4. Ativos, ameaças, vulnerabilidades e risco

Numa sexta-feira à noite, o boletim do CERT.br e metade dos canais técnicos anunciam a mesma coisa: falha crítica de execução remota de código num servidor de aplicação amplamente usado, com exploração já observada na internet, nota máxima de severidade. O coordenador de TI do provedor lê o alerta e faz a única pergunta que importa: **nós temos isso rodando em algum lugar?**

Ninguém sabe responder. Há trinta e dois servidores em produção, três deles herdados de uma aquisição de 2021, dois em nuvem contratados diretamente pelo comercial sem passar pela TI, e um que “acho que só serve o portal antigo, mas ninguém desliga porque tem medo”. A resposta chega no domingo à tarde, depois de uma varredura improvisada: sim, dois servidores, um deles exposto à internet. O tempo entre a pergunta e a resposta — quarenta e uma horas — foi tempo de exposição pura, com exploração ativa acontecendo no mundo.

Essa é a diferença prática entre uma organização que gerencia risco e uma que reage a manchete. E ela começa não pela ferramenta de correção, mas pelo termo mais entediante do vocabulário: **inventário**.

O Capítulo 1 fixou o vocabulário mínimo numa tabela. Este capítulo abre cada um daqueles termos até o ponto em que eles viram método de trabalho: como levantar ativos, como caracterizar ameaças, como classificar vulnerabilidades com os identificadores que a indústria usa, e como combinar as três coisas em uma estimativa de risco que sustente uma decisão.

4.1. A cadeia que liga os quatro termos

Os quatro conceitos não são uma lista: são uma cadeia causal, e cada elo tem um tipo de controle que age sobre ele (Figura 4.1).

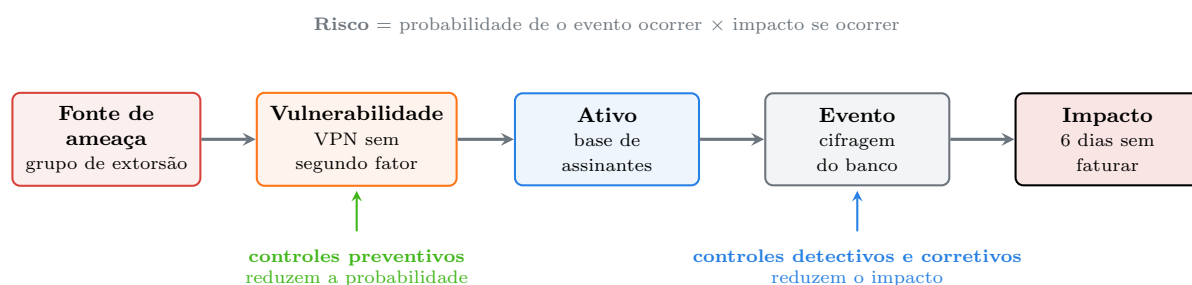


Figura 4.1.: A cadeia do risco. Não se elimina a fonte de ameaça; o trabalho recai sobre a vulnerabilidade (probabilidade) e sobre o impacto.

A leitura dessa cadeia responde a uma pergunta prática recorrente: onde investir? À esquerda, reduzindo a chance de o evento acontecer; à direita, reduzindo o estrago quando acontecer. Programas imaturos gastam quase tudo à esquerda. Programas maduros equilibram, porque a probabilidade nunca chega a zero e o custo marginal de reduzi-la cresce muito mais rápido que o de conter o impacto.

4.2. Ativos: o inventário é o alicerce

Ativo é qualquer coisa que tenha valor para a organização. O Capítulo 1 separou ativos **primários** (a informação e os processos de negócio) de ativos de **suporte** (hardware, software, rede, instalações, pessoas). Falta agora o método: como construir e manter o inventário que responde à pergunta de sexta-feira à noite.

4.2.1. O que precisa constar

Um inventário útil não é uma lista de nomes de máquina. Para cada ativo relevante, cinco campos fazem a diferença entre planilha decorativa e ferramenta de decisão:

Tabela 4.1.: Campos mínimos de um inventário de ativos que sustenta decisão.

Campo	Por que importa
Identificação e localização	Onde está fisicamente e logicamente (endereço, VLAN, provedor de nuvem, conta)
Dono	Pessoa nomeada que decide sobre ele — não “a TI”
Classificação	Qual informação trafega ou repousa ali, e sua sensibilidade
Dependências	De que depende e quem depende dele; alimenta a análise de impacto
Versões e fim de suporte	Sistema operacional, aplicação, firmware — é o campo que responde à pergunta do boletim

O campo **dono** é o que costuma faltar e o que mais paralisa a resposta a incidente: sem alguém nomeado, a decisão de desligar um servidor às 23h de domingo não tem quem a tome.

4.2.2. Como levantar, na prática

Nenhuma fonte isolada é completa; a interseção de várias é o que aproxima da realidade:

- **Varredura ativa** da própria faixa de endereços — encontra o que responde.
- **Escuta passiva** de ARP, DHCP e fluxos (NetFlow/sFlow) — encontra o que existe mas não responde a varredura, e o que aparece só de vez em quando.
- **Fontes administrativas** — faturas do provedor de nuvem, contratos de licença, notas fiscais de compra, registros de domínio. É onde aparecem os dois servidores que o comercial contratou sozinho.
- **Diretório e gerência de configuração** — objetos do Active Directory, agentes instalados, gerenciador de pacotes.
- **A conversa.** Perguntar a cada área “que sistema você usa que a TI talvez não conheça?” produz achados que nenhuma varredura produz, porque nuvem contratada por cartão de crédito não aparece na rede interna.

O que se descobre nesse cruzamento tem nome: **TI sombra** (*shadow IT*) e **ativos órfãos**. São, sistematicamente, os ativos com pior postura de segurança do ambiente, porque não estão em nenhuma rotina de correção, backup ou monitoramento.

4.2.3. Superfície de ataque

Do inventário deriva o conceito operacional mais útil deste capítulo: a **superfície de ataque** é o conjunto de pontos por onde um adversário pode interagir com o sistema. Reduzi-la é o controle de melhor retorno que existe, porque um serviço que não está exposto não precisa ser corrigido com urgência.

Ela tem três dimensões, e a terceira é a esquecida: a superfície de **rede** (portas e serviços alcançáveis), a de **software** (código, bibliotecas, dependências, funcionalidades habilitadas) e a **humana** (quem pode ser alvo de engenharia social, quantas pessoas têm privilégio administrativo, quantos terceiros têm acesso).

4.3. Ameaças: quem ou o quê, e com que capacidade

Ameaça é a causa potencial de um incidente indesejado. O Capítulo 1 apresentou as três origens (deliberada, accidental, ambiental) e os perfis de agente. O que falta é como *usar* isso: caracterizar uma ameaça com três atributos.

Fonte. Quem ou o quê. Para agentes deliberados, o perfil (oportunista automatizado, crime organizado, pessoa interna, ativismo, estado-nação); para os demais, o fenômeno (erro de operação, falha de equipamento, descarga atmosférica).

Capacidade e recursos. O oportunista automatizado usa exploração pública contra falha conhecida e desiste diante de qualquer atrito. O crime organizado compra acesso inicial, tem semanas de paciência e um orçamento. Um estado-nação desenvolve exploração própria para falha desconhecida. A capacidade determina quais controles fazem diferença: bloquear o primeiro é barato; conter o terceiro é outro orçamento.

Motivação e alvo. O oportunista não escolheu você; o crime organizado escolheu seu *setor*; a pessoa interna insatisfeita escolheu *você especificamente*. Isso muda a resposta: contra o indiscriminado, higiene básica resolve; contra o direcionado, é preciso assumir comprometimento e investir em detecção.

Catálogos ajudam a não depender de imaginação. O **MITRE ATT&CK** organiza táticas e técnicas efetivamente observadas em ataques reais, e serve tanto para modelar ameaça quanto para medir cobertura de detecção (MITRE Corporation, 2024); a ISO/IEC 27005 traz listas de fontes de ameaça e de vulnerabilidades típicas (International Organization for Standardization, 2022). O Volume 11 dedica um capítulo ao ATT&CK.

4.4. Vulnerabilidades: quatro tipos, não um

Vulnerabilidade é a fraqueza que pode ser explorada por uma ameaça. A palavra evoca falha de software, e essa associação estreita esconde três quartos do problema:

- **De software.** Erro de implementação ou de projeto no código: estouro de buffer, injeção, desserialização insegura. É a que recebe identificador CVE.
- **De configuração.** O software está correto; o modo como foi configurado, não. Credencial de fábrica, serviço administrativo exposto, permissão excessiva, cifra fraca habilitada, registro desligado. **É a categoria mais frequente em ambientes reais** e a que nenhum boletim avisa, porque não é falha do fornecedor.
- **De processo.** Não há revisão de acessos, o desligamento não revoga credenciais, o backup nunca é testado, não existe procedimento de resposta. Não aparece em varredura alguma.

4. Ativos, ameaças, vulnerabilidades e risco

- **Humana.** Suscetibilidade a engenharia social, senha reaproveitada, aprovação sem conferência. Tema do Volume 10.

Um programa de segurança que só trata a primeira categoria está tratando a minoria dos casos com a maior parte do orçamento.

4.4.1. O ciclo de vida de uma vulnerabilidade e a janela de exposição

Toda vulnerabilidade de software percorre uma linha do tempo, e o que importa nela são os intervalos, não os pontos (Figura 4.2).

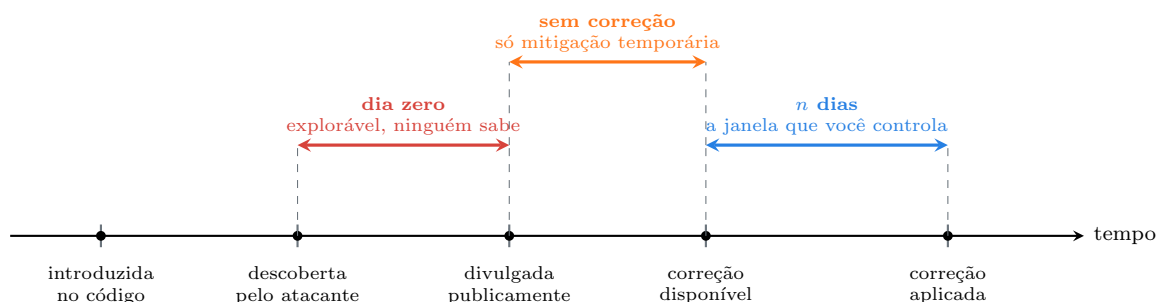


Figura 4.2.: A linha do tempo de uma vulnerabilidade. O intervalo de n dias é o único que depende inteiramente da organização.

O ponto central da figura é político, não técnico. Contra o dia zero há pouco a fazer além de defesa em profundidade e detecção. Mas a janela de n dias — entre a correção existir e a correção estar aplicada — é integralmente responsabilidade da organização, e é onde a esmagadora maioria dos comprometimentos reais acontece. Atacantes não gastam dia zero em provedor regional: usam falhas com correção publicada há meses.

Vale a distinção: **exploração** (*exploit*) é o código ou a técnica que tira proveito da falha; **prova de conceito** demonstra que é possível; **exploração armada** é a versão confiável e automatizada. O intervalo entre divulgação e exploração armada disponível encurtou de meses para dias, e às vezes horas.

4.4.2. Os identificadores que a indústria usa

Cinco siglas aparecem em todo boletim, e cada uma responde a uma pergunta diferente. Confundi-las leva a priorizar errado.

Tabela 4.2.: Os identificadores de vulnerabilidade e a pergunta de cada um.

Sigla	O que é	Pergunta que responde
CVE	Identificador único de uma vulnerabilidade concreta em um produto	<i>Qual</i> falha é essa?
CWE	Catálogo de tipos de fraqueza (ex.: CWE-89, injeção de SQL)	De que <i>classe</i> ela é?

Sigla	O que é	Pergunta que responde
CVSS	Pontuação de severidade de 0 a 10, com métricas base, de ameaça e ambientais	Quão <i>grave</i> ela é?
EPSS	Probabilidade estimada de exploração nos próximos 30 dias	Quão <i>provável</i> é ser explorada?
KEV	Catálogo de vulnerabilidades com exploração confirmada em ataques reais	Já está sendo <i>usada</i> ?

O erro mais comum e mais caro é tratar **CVSS como fila de prioridade**. O CVSS mede severidade *intrínseca*, sob a premissa do pior caso (Forum of Incident Response and Security Teams, 2023). Numa base típica, milhares de itens pontuam 7,0 ou mais — corrigir por ordem de nota significa gastar semanas em falhas que ninguém explora, enquanto uma de nota 6,5 com exploração ativa segue aberta.

A priorização que funciona combina três eixos, ilustrados na Figura 4.3: severidade (CVSS, ajustado pelas métricas ambientais que refletem *seu* contexto), probabilidade de exploração (EPSS e KEV) e **exposição real do ativo** — se o serviço vulnerável está atrás de VPN, sem alcance da internet, a urgência é outra.

4.5. Risco: juntando tudo

Risco é o efeito da incerteza sobre os objetivos (International Organization for Standardization, 2018b) — e, na formulação operacional que a segurança da informação usa, a combinação da probabilidade de um evento e do seu impacto:

$$\text{Risco} = P(\text{evento}) \times \text{Impacto}(\text{evento})$$

A fórmula é útil e é uma simplificação perigosa se levada ao pé da letra, por três motivos que valem registro desde já:

1. **Nem todo impacto é comparável.** Um evento com 1% de chance e R\$ 10 milhões de impacto e outro com 100% de chance e R\$ 100 mil de impacto têm o mesmo valor esperado e exigem decisões completamente diferentes: o segundo é custo operacional, o primeiro é ameaça à existência da empresa.
2. **As distribuições têm cauda pesada.** Perdas por incidente não se distribuem em torno de uma média bem-comportada; o valor esperado subestima sistematicamente o cenário ruim.
3. **A probabilidade raramente é conhecida.** É estimada, e a qualidade da estimativa é o que o Capítulo 6 trata em detalhe.

Duas distinções completam o quadro. **Risco inerente** é o risco antes de qualquer controle; **risco residual** é o que sobra depois deles aplicados — e é o número que a direção precisa conhecer e aceitar formalmente. E o impacto tem camadas: o **direto** (horas de indisponibilidade, custo de recuperação, dado perdido) costuma ser o menor; o **indireto** (multa da ANPD, ação de titulares, perda de assinantes, custo de aquisição para repor a base, reputação junto ao regulador) é que decide a sobrevivência da empresa.

4. Ativos, ameaças, vulnerabilidades e risco

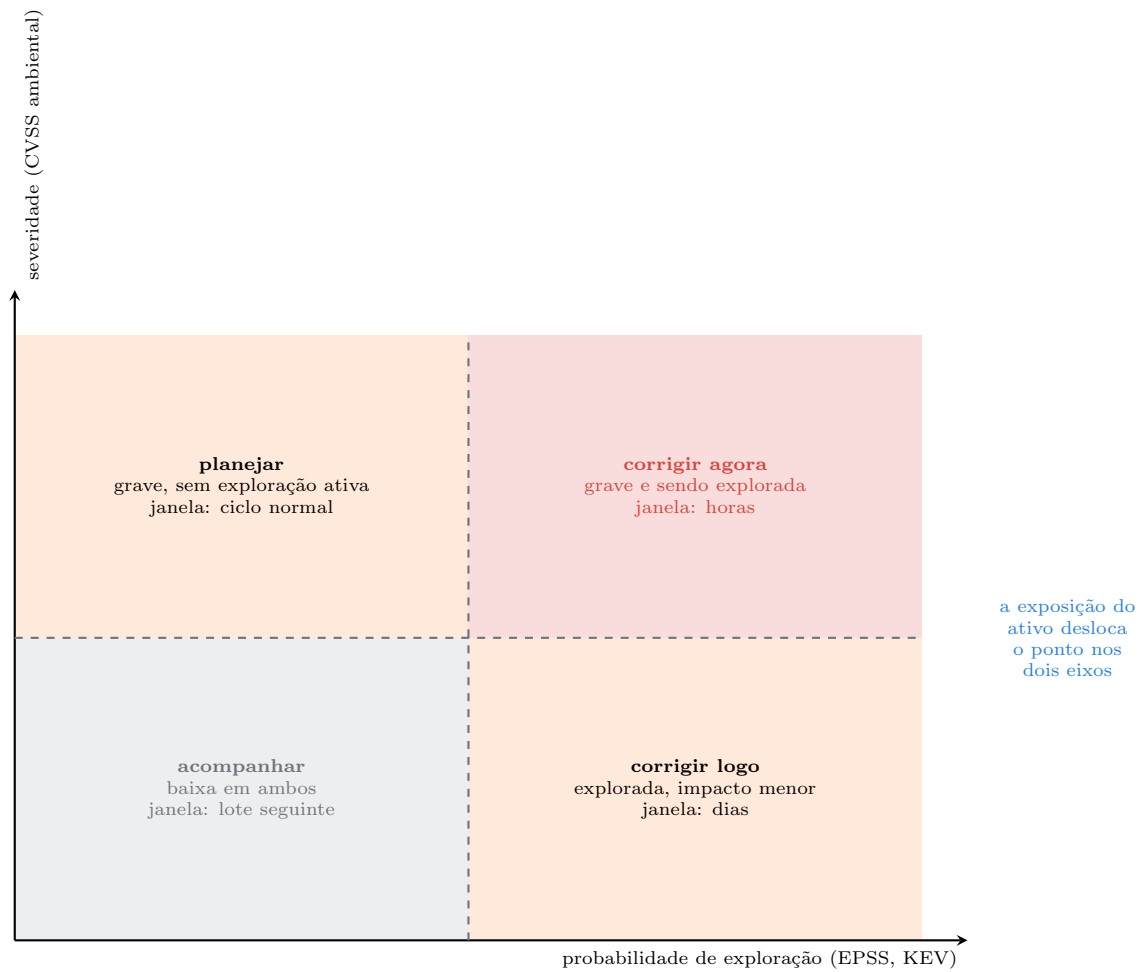


Figura 4.3.: Priorização por severidade e por probabilidade de exploração. A nota isolada do CVSS não distingue o quadrante superior esquerdo do superior direito.

4.5.1. Controles: três funções, três naturezas

Fechando a cadeia, **controle** é a medida que modifica o risco. Duas classificações que se cruzam e organizam qualquer conversa sobre o assunto:

Por **função**: **preventivo** (impede o evento — segundo fator, segmentação, menor privilégio), **detectivo** (revela que ocorreu — registro, alerta, integridade de arquivo), **corretivo** (restaura — backup, plano de resposta), e ainda **dissuasivo** (desestimula — aviso legal, câmera visível) e **compensatório** (substitui um controle inviável por outro de efeito equivalente).

Por **natureza**: **técnico** (firewall, cifragem), **administrativo** (política, procedimento, treinamento, contrato) e **físico** (fechadura, cerca, controle de acesso à sala).

A regra prática que decorre da Figura 4.1: um conjunto de controles só é defensável se cobrir as três funções. Só preventivos significa que, no dia em que um falhar, ninguém fica sabendo; só detectivos significa assistir ao incidente acontecer.

4.6. Brasil em Foco

A **LGPD** transformou inventário e análise de risco em obrigação documental. O art. 37 exige que controlador e operador **mantenham registro das operações de tratamento** de dados pessoais que realizarem — na prática, um inventário de ativos primários com finalidade, base legal, categorias de titulares, prazo de retenção e compartilhamentos (Brasil, 2018). O art. 38 faculta à ANPD determinar a elaboração de **relatório de impacto à proteção de dados pessoais**, documento que descreve os tratamentos, os riscos às liberdades civis e as medidas de mitigação — ou seja, exatamente a cadeia deste capítulo, escrita.

O art. 50 introduz as **regras de boas práticas e governança**, que a lei sugere considerando “a natureza, o escopo, a finalidade, a probabilidade e a gravidade dos riscos” — a linguagem é de gestão de risco, não de lista de controles obrigatórios. Isso tem consequência: no Brasil, não existe uma lista fechada de medidas que, cumprida, garante conformidade. O que se demonstra é o **processo**, e o processo começa por saber o que se tem.

Para agentes de tratamento de **pequeno porte**, a Resolução CD/ANPD nº 2/2022 flexibilizou obrigações, e a ANPD publicou guia orientativo de segurança da informação para esse público, com um conjunto mínimo de medidas — leitura recomendada para provedores regionais e empresas de suporte, por ser o parâmetro que a própria autoridade declara esperar (Autoridade Nacional de Proteção de Dados, 2023).

Do lado da telecomunicação, a Resolução Anatel nº 740/2020 exige que produtos de telecomunicações atendam a requisitos de segurança cibernética — sem senha padrão universal, com mecanismo de atualização de firmware e com correção de vulnerabilidades conhecidas (Agência Nacional de Telecomunicações, 2020). Para quem entrega ONU e roteador ao assinante, isso significa incluir o **parque de equipamentos de cliente no inventário**: são dezenas de milhares de ativos sob responsabilidade do provedor, e um firmware vulnerável em massa é simultaneamente risco ao assinante, risco à rede e questão regulatória.

No setor financeiro, a Resolução CMN nº 4.893/2021 exige classificação de dados e sistemas por relevância, avaliação de riscos e controles proporcionais, além de exigir a gestão de risco de **serviços de terceiros** relevantes (Banco Central do Brasil, 2021) — o que puxa fornecedores e integradores para dentro do escopo.

Institucionalmente, o **CERT.br** publica estatísticas de incidentes notificados e mantém material de boas práticas para redes; para órgãos federais, o **CTIR Gov** emite alertas de vulnerabilidade

4. Ativos, ameaças, vulnerabilidades e risco

e coordena resposta. Acompanhar essas fontes, mais o catálogo de vulnerabilidades exploradas conhecidas mantido pela CISA norte-americana, é o mínimo para não descobrir por manchetes.

4.7. No Campo

1. Construir o inventário em uma semana, não em um projeto de seis meses. A versão de 20% que existe vale infinitamente mais que a versão completa que nunca fica pronta. Uma planilha com os cinco campos da Tabela 4.1, preenchida com o cruzamento de varredura, faturas e conversa, já responde à pergunta de sexta-feira à noite:

```
# Ativos que respondem na rede, com serviço e versão detectados
nmap -sS -sV -Pn --top-ports 500 --open -oA inventario 10.20.0.0/22

# Aprendizado passivo: quem já falou na rede recentemente
ip neigh show | awk '$4=="lladdr" {print $1, $5}' | sort -V

# Concessões de DHCP ativas - pega o que não estava ligado durante a varredura
grep -E 'lease|binding state active' /var/lib/dhcp/dhcpd.leases | head -40
```

2. Registrar dono e classificação, não só endereço IP. É o que transforma inventário em ferramenta de decisão. Sem dono nomeado, nenhuma decisão urgente sai do lugar.

3. Medir a superfície exposta e persegui-la até zero. Serviço administrativo alcançável da internet é o achado mais comum e mais caro. A meta não é reduzir: é zerar.

```
# O que este servidor escuta, em quais interfaces, e qual processo responde
ss -tulnp | awk 'NR==1 || $5 !~ /^(127\.|\.|[::1\])/'

# Conferir de fora: o que o mundo enxerga do seu bloco
nmap -Pn -p- --open -T3 198.51.100.7

# Regras de firewall que permitem qualquer origem
iptables -S | grep -E '^-A (INPUT|FORWARD)' | grep -v ' -s '
```

4. Priorizar correção por exploração ativa, não por nota. A fila é: está no catálogo de exploração conhecida e o ativo está exposto → hoje. EPSS alto → esta semana. CVSS alto sem sinal de exploração e ativo interno → no ciclo mensal.

```
# Pacotes com atualização de segurança pendente (Debian/Ubuntu)
apt-get -s upgrade | grep -i security | awk '{print $2}' | sort -u

# Versões instaladas x fim de suporte - o campo que responde ao boletim
hostnamectl | grep -E 'Operating System|Kernel'
lsb_release -d 2>/dev/null; cat /etc/os-release | grep -E '^VERSION'
```

5. Manter um registro de risco de uma página. Dez linhas bastam: ativo, ameaça, vulnerabilidade, impacto estimado, probabilidade estimada, controle atual, controle proposto, dono, prazo, decisão. É o insumo do Capítulo 6 e o documento que a ANPD pede quando pergunta como a empresa avaliou seus riscos.

6. Incluir o parque de equipamentos de assinante. Modelo, versão de firmware, se aceita atualização remota, se tem credencial padrão. Dezenas de milhares de dispositivos com a mesma falha são o maior ativo de risco de um provedor — e o de maior potencial de dano a terceiros.

7. Assinar as fontes de alerta e definir quem lê. Boletins do CERT.br, avisos do fabricante dos equipamentos em uso, catálogo de vulnerabilidades exploradas. Um responsável nomeado, revisão semanal, e um caminho definido para escalar o que for urgente fora do horário. Alerta que chega numa caixa que ninguém abre é o mesmo que alerta que não chegou.

4.8. Resumo

- Os quatro termos formam uma **cadeia causal**: a fonte de ameaça explora uma vulnerabilidade de um ativo, produzindo um evento com impacto. Controles preventivos agem sobre a probabilidade; detectivos e corretivos, sobre o impacto — e um programa defensável cobre as duas pontas.
- **Inventário é o alicerce.** Sem dono nomeado, classificação e versões registradas, a pergunta “nós temos isso?” não tem resposta rápida, e a demora é exposição pura. TI sombra e ativos órfãos são sistematicamente os piores do ambiente.
- Vulnerabilidade não é só falha de software: as de **configuração, de processo e humanas** somam a maioria dos casos reais e não aparecem em boletim nem em varredura.
- A janela de *n dias* — entre a correção existir e estar aplicada — é a única inteiramente sob controle da organização, e é onde ocorre a maior parte dos comprometimentos. Dia zero é raro contra alvos comuns.
- **CVE, CWE, CVSS, EPSS e KEV** respondem perguntas diferentes. Priorizar pela nota do CVSS é o erro caro mais comum: a fila correta combina severidade ajustada ao contexto, probabilidade de exploração e exposição real do ativo.
- **Risco = probabilidade × impacto** é útil como organizador e enganoso como número único: impactos catastróficos e recorrentes não são intercambiáveis, as distribuições têm cauda pesada, e o impacto indireto costuma superar o direto.
- No Brasil, a LGPD converte inventário (art. 37) e avaliação de risco (arts. 38 e 50) em obrigação demonstrável; a Anatel 740/2020 traz o parque de equipamentos do assinante para dentro do escopo; e a Resolução CMN 4.893/2021 estende a gestão de risco aos fornecedores relevantes.

5. Modelagem de ameaças: STRIDE, árvores de ataque e abuse cases

O provedor lançou o portal do assinante em quatro meses de desenvolvimento. Funcionava: segunda via de fatura, alteração de plano, abertura de chamado, histórico de consumo. Autenticação por CPF e senha, sessão com expiração, tráfego em HTTPS com certificado válido, senhas armazenadas com hash forte. Os testes de aceitação passaram todos.

Três semanas depois do lançamento, um assinante mandou uma mensagem para o suporte, sem qualquer má intenção: ele havia percebido que a URL da fatura terminava em `/fatura/48213`, trocou o número por `48212` e apareceu a fatura de outra pessoa — nome, CPF, endereço, valor. Testou mais alguns. Todos abriam.

A falha é conhecida, tem nome (referência direta insegura a objeto), e leva talvez vinte minutos para corrigir. O que custou caro não foi a correção: foi que 4.000 assinantes ficaram com dados pessoais expostos por três semanas, e que o incidente virou comunicação à ANPD.

O detalhe que interessa a este capítulo é outro. Nenhum teste teria pego isso, porque todos os testes verificavam que **o sistema faz o que deve fazer**. Ninguém verificou que ele **não faz o que não deve**. A pergunta “e se o usuário trocar o número na URL?” não custa nada, não exige ferramenta e leva menos de um minuto — desde que alguém a faça. Fazer sistematicamente essa classe de pergunta, antes de construir, é o que se chama modelagem de ameaças.

5.1. O que é, e quando fazer

Modelagem de ameaças é o exercício estruturado de antecipar como um sistema pode ser atacado, antes de ele existir ou antes de ele mudar. Adam Shostack a resume em quatro perguntas (Shostack, 2014), e a virtude do método está inteiramente na disciplina de responder as quatro, na ordem:

1. **O que estamos construindo?** Um desenho do sistema que todos concordam que está correto.
2. **O que pode dar errado?** A parte criativa, guiada por um catálogo para não depender de inspiração.
3. **O que vamos fazer a respeito?** Cada ameaça vira uma decisão com dono e prazo.
4. **Fizemos um bom trabalho?** Revisão do próprio exercício.

A terceira e a quarta perguntas são as que separam modelagem de conversa. Um modelo que produz uma lista de ameaças e nenhuma decisão registrada não mudou nada.

Sobre **quando**: o retorno é máximo quando ainda é barato mudar — ao desenhar um sistema novo, ao alterar arquitetura, ao integrar um terceiro, ao expor algo que antes era interno, ao mudar quem pode acessar o quê. Não é ritual anual; é gatilho por mudança. E não precisa ser pesado: uma sessão de noventa minutos com quadro branco, a pessoa que desenvolve, a que opera a infraestrutura e alguém do negócio cobre a maior parte do valor.

5.2. Pergunta 1: desenhar o sistema

O formato que melhor sustenta o exercício é o **diagrama de fluxo de dados**, com cinco elementos e uma convenção visual estável:

- **Entidade externa** — quem interage e está fora do seu controle (assinante, integração de terceiro).
- **Processo** — código que executa e transforma dados (aplicação, API, serviço).
- **Armazenamento** — onde os dados repousam (banco, arquivo, fila, cache).
- **Fluxo de dados** — o que trafega, e por qual canal.
- **Fronteira de confiança** — a linha em que o nível de confiança muda. É o elemento mais importante do diagrama.

A regra prática que rende mais: **ameaças se concentram onde os fluxos cruzam fronteiras de confiança**. Um desenho sem fronteiras marcadas não é um modelo de ameaças, é um diagrama de arquitetura. A Figura 5.1 desenha o portal do caso de abertura.

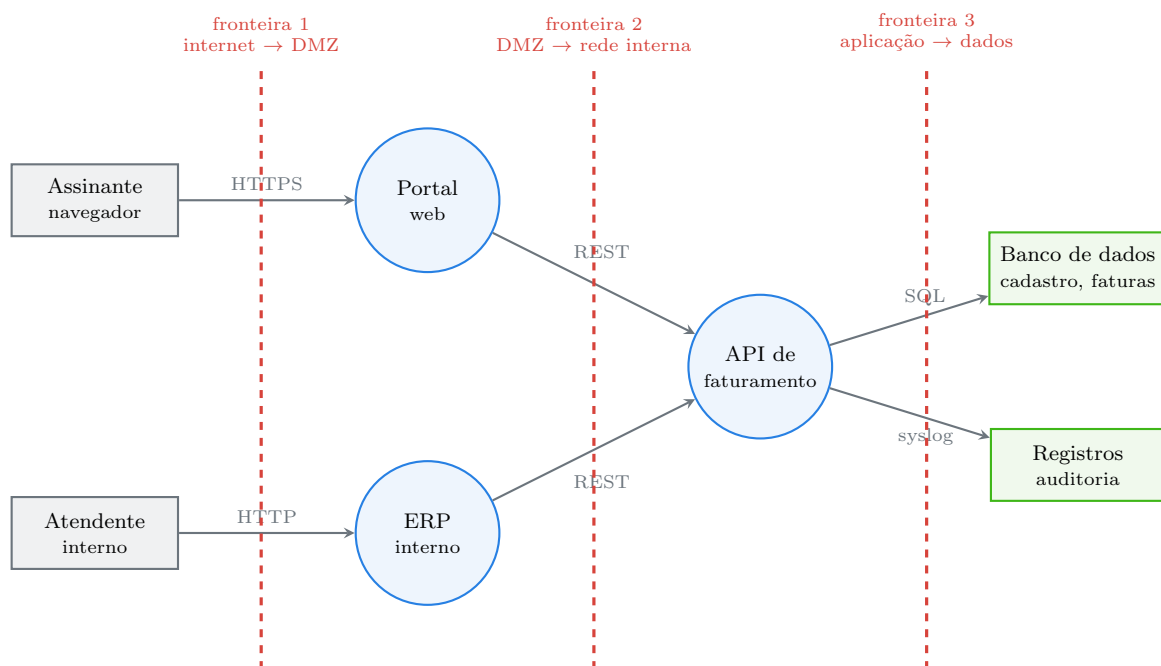


Figura 5.1.: Diagrama de fluxo de dados do portal do assinante. As três linhas vermelhas são onde o esforço de análise se concentra.

Duas dicas de execução. Primeira: desenhe no nível de detalhe em que as decisões são tomadas — um diagrama com trinta caixas não é analisado por ninguém. Segunda: valide o desenho com quem construiu o sistema. É frequente descobrir, nessa validação, um fluxo que não estava no desenho e que ninguém lembrava que existia — e esse fluxo esquecido é, com frequência desconfortável, exatamente onde está o problema.

5.3. Pergunta 2: o que pode dar errado

5.3.1. STRIDE

O **STRIDE** é o catálogo mais usado, e sua elegância está em ser o complemento exato das propriedades de segurança dos capítulos anteriores: cada letra é a violação de uma propriedade.

Tabela 5.1.: STRIDE e sua correspondência com as propriedades de segurança.

Letra	Ameaça	Propriedade violada	Exemplo no portal	Contramedida típica
S	<i>Spoofing</i> — falsificação de identidade	Autenticidade	Entrar como outro assinante com CPF vazado e senha fraca	Autenticação forte, segundo fator, TLS mútuo
T	<i>Tampering</i> — adulteração	Integridade	Alterar o valor da fatura num parâmetro da requisição	Validação no servidor, assinatura, restrições no banco
R	<i>Repudiation</i> — repúdio	Não repúdio	Negar que pediu a mudança de plano	Log íntegro, conta nomeada, carimbo de tempo
I	<i>Information disclosure</i> — vazamento	Confidencialidade	Trocar o número da URL e ver a fatura alheia	Autorização por objeto, minimização, cifragem
D	<i>Denial of service</i> — negação de serviço	Disponibilidade	Esgotar a API com requisições em massa	Limitação de taxa, cota, dimensionamento, filtragem
E	<i>Elevation of privilege</i> — elevação de privilégio	Autorização	Assinante alcançar função de atendente	Menor privilégio, verificação de papel no servidor

A falha do caso de abertura é um **I** clássico — e ela ilustra por que o catálogo funciona: bastava alguém percorrer as seis letras para o fluxo “assinante consulta fatura” e perguntar “como haveria vazamento de informação aqui?”.

A técnica que sistematiza isso chama-se **STRIDE por elemento**: em vez de olhar o sistema inteiro de uma vez, aplicar as letras relevantes a cada elemento do diagrama. Nem todas se aplicam a todos:

- **Entidade externa:** S, R
- **Processo:** todas as seis
- **Armazenamento:** T, I, D (e R, se for o armazenamento dos próprios logs)
- **Fluxo de dados:** T, I, D

Para o portal da Figura 5.1, isso significa cerca de trinta perguntas — algumas descartadas em segundos, outras rendendo achados. É trabalho de uma tarde, e é a razão pela qual a modelagem tem retorno tão desproporcional ao custo.

5.3.2. Árvores de ataque

O STRIDE responde “que categorias de coisa podem dar errado”. A **árvore de ataque**, proposta por Bruce Schneier, responde a uma pergunta diferente e complementar: *dado um objetivo do atacante, quais são todos os caminhos até ele?* (Schneier, 1999)

A raiz é o objetivo; os nós internos são submetas; as folhas são ações concretas. Os nós se combinam de duas formas: **OU** (qualquer filho basta) e **E** (todos os filhos são necessários). A Figura 5.2 monta a árvore para o objetivo mais realista no contexto de um provedor.

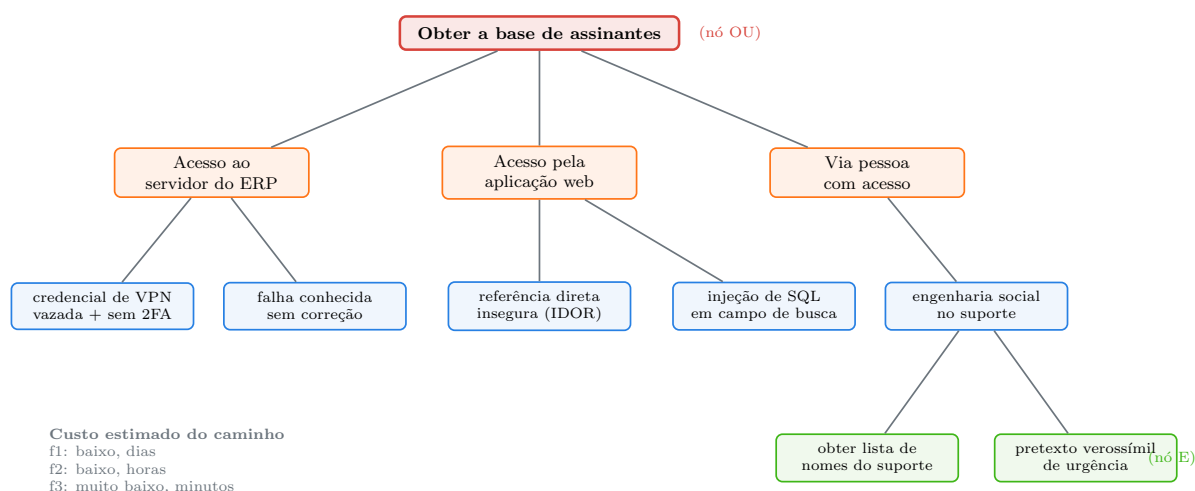


Figura 5.2.: Árvore de ataque para a base de assinantes. O caminho mais barato — não o mais sofisticado — é o que descreve o adversário real.

O valor da árvore aparece quando se anotam as folhas com **custo, tempo e habilidade requerida**. O caminho mais barato define o adversário mais provável, e é ali que o primeiro real de defesa rende mais. No exemplo, gastar em detecção sofisticada enquanto existe uma referência direta insegura explorável em minutos é investir no ramo errado da árvore.

Árvores também mostram onde um único controle corta vários caminhos ao mesmo tempo — segundo fator na VPN elimina f1 e encarece f5. Esse é o tipo de raciocínio que uma lista de vulnerabilidades ordenada por nota nunca produz.

5.3.3. Abuse cases

O terceiro instrumento parte do que a equipe já escreve. Para cada **caso de uso**, escreve-se o **caso de abuso** correspondente: o mesmo ator, com intenção hostil, ou um ator novo que ninguém previu.

Caso de uso. Como assinante autenticado, quero consultar minha fatura para pagá-la.

Caso de abuso. Como assinante autenticado, quero consultar a fatura de outro assinante alterando o identificador na URL.

Critério de aceitação derivado. A requisição de fatura cujo identificador não pertence ao assinante da sessão retorna 404, registra o evento com origem e identificador tentado, e dispara alerta após cinco tentativas.

O ganho dessa formulação é institucional: o caso de abuso vira **critério de aceitação** e depois **teste automatizado**, entrando no mesmo fluxo em que a equipe já trabalha. Segurança que vive numa planilha à parte é esquecida; segurança que vira teste que quebra o build sobrevive.

5.4. Outras abordagens, e quando usá-las

STRIDE, árvores e casos de abuso cobrem a grande maioria das necessidades. Vale conhecer quatro alternativas pelo que cada uma acrescenta:

- **PASTA** — processo de sete estágios centrado em risco de negócio, com simulação de ataque. Mais pesado; adequado quando a modelagem precisa dialogar com análise financeira de risco.
- **LINDDUN** — o análogo do STRIDE para **privacidade**: vinculabilidade, identificabilidade, não repúdio (aqui como problema, não como propriedade desejável), detectabilidade, divulgação, inconsciência e não conformidade. É o instrumento certo para o relatório de impacto exigido pela LGPD, porque olha ameaças ao titular dos dados, não à empresa.
- **OCTAVE** — orientado a organização e ativos críticos, mais que a sistemas; útil em nível de programa.
- **MITRE ATT&CK** — não é método de modelagem, e sim catálogo de táticas e técnicas reais (MITRE Corporation, 2024). Excelente como fonte de folhas para árvores de ataque e como régua de cobertura de detecção. O Volume 11 aprofunda.

Uma nota sobre a **cadeia de ataque** (*kill chain*): modelar o ataque como sequência de etapas — reconhecimento, acesso inicial, execução, persistência, movimentação lateral, exfiltração — tem valor defensivo próprio, porque cada etapa é uma oportunidade de detecção e interrupção. Um adversário precisa vencer todas; o defensor precisa pegar uma.

5.5. Pergunta 3: o que fazer, e pergunta 4: fizemos bem?

Cada ameaça identificada termina em uma de quatro decisões, e a decisão precisa estar **escrita, com dono e prazo**:

- **Mitigar** — implantar controle que reduza probabilidade ou impacto.
- **Eliminar** — remover a funcionalidade ou o dado que cria a exposição. Subestimada: a funcionalidade que ninguém usa e que só existe porque estava no escopo original é o alvo mais fácil.
- **Transferir** — passar o risco a um terceiro (seguro, contrato, fornecedor especializado). Transfere o custo financeiro, nunca a responsabilidade perante o titular dos dados.
- **Aceitar** — decidir conviver com ele, conscientemente, registrado, por quem tem autoridade para isso.

A quarta pergunta de Shostack — *fizemos um bom trabalho?* — se responde com três checagens: todos os elementos do diagrama receberam as letras aplicáveis do STRIDE; alguém que não participou revisou o modelo; e as ameaças mitigadas geraram teste que detecta regressão.

5.5.1. Erros que esvaziam o exercício

- **Modelar uma vez.** O modelo envelhece na primeira mudança de arquitetura. Revisar por gatilho, não por calendário.
- **Modelar sem quem constrói.** Modelo feito só por segurança produz achados que a equipe de desenvolvimento não reconhece como reais, e nada é implementado.
- **Buscar completude.** Não existe lista exaustiva de ameaças. Um modelo que cobre as fronteiras de confiança e os fluxos principais entrega quase todo o valor; perseguir os últimos 5% consome o tempo que faltará para corrigir os 95%.
- **Parar na lista.** Sem decisão, dono e prazo, o documento é um inventário de preocupações.
- **Confundir com teste de invasão.** A modelagem antecipa o que *pode* dar errado no desenho; o teste verifica o que *está* errado na implementação. São complementares e não se substituem — o Volume 9 trata do segundo.

5.6. Brasil em Foco

A LGPD incorporou modelagem de ameaças ao ordenamento sem usar essa expressão. O art. 46, §2º determina que as medidas de segurança deverão ser observadas **desde a fase de concepção do produto ou do serviço até a sua execução** (Brasil, 2018) — é a positivação do princípio de *security e privacy by design*, e a única forma prática de cumpri-la é analisar riscos antes de construir. Uma decisão de arquitetura tomada sem essa análise e que depois causa vazamento é, sob esse dispositivo, falha demonstrável de diligência.

O **relatório de impacto à proteção de dados pessoais** do art. 38 é o produto formal mais próximo de um modelo de ameaças no direito brasileiro. Sua estrutura pede descrição dos tratamentos, dos riscos às liberdades civis e aos direitos fundamentais, e das salvaguardas adotadas — exatamente as perguntas 1, 2 e 3 de Shostack, com o foco deslocado: o risco a analisar é o risco **ao titular dos dados**, não à empresa. É por isso que o LINDDUN é mais adequado que o STRIDE para esse documento: uma funcionalidade pode ser perfeitamente segura para a organização e ainda assim criar vinculabilidade ou identificabilidade indevida para as pessoas.

A distinção tem consequência concreta no caso de abertura. Sob a ótica da empresa, o incidente foi vazamento de dados de clientes. Sob a ótica do titular, foi a exposição de nome, CPF, endereço e valor de fatura de 4.000 pessoas a qualquer um com um navegador — situação que o art. 48 obriga a comunicar à ANPD e aos titulares afetados quando houver risco ou dano relevante, no prazo de três dias úteis fixado pela Resolução CD/ANPD nº 15/2024 (Autoridade Nacional de Proteção de Dados, 2024). Modelar antes custaria uma tarde.

No setor financeiro e de pagamentos, a Resolução CMN nº 4.893/2021 exige que a política de segurança cibernética contemple **avaliação prévia** de novas tecnologias e de mudanças relevantes, e que a instituição avalie riscos antes de contratar serviços de terceiros (Banco Central do Brasil, 2021). Para telecomunicações, a Resolução Anatel nº 740/2020 exige que produtos sejam concebidos com requisitos de segurança, o que pressupõe análise na fase de projeto (Agência Nacional de Telecomunicações, 2020).

Um ponto prático para provedores regionais: a **ANPD reconhece proporcionalidade**. Para agentes de pequeno porte, a autoridade não espera um processo formal de sete estágios — espera evidência de que os riscos foram considerados e as decisões registradas (Autoridade Nacional de Proteção de Dados, 2023). Uma ata de duas páginas por projeto, com o diagrama, as ameaças levantadas e as decisões tomadas, é documento suficiente e mais defensável que a ausência de qualquer registro.

5.7. No Campo

1. A sessão de noventa minutos. Quadro branco, três pessoas (quem desenvolve, quem opera, quem entende o negócio), um sistema por vez. Primeiros 20 minutos: desenhar o fluxo de dados e marcar as fronteiras de confiança. Próximos 45: percorrer STRIDE por elemento nos fluxos que cruzam fronteira. Últimos 25: decidir o que fazer com cada achado, com dono e prazo. Fotografar o quadro e anexar à ata é registro suficiente.

2. Modelar a rede, não só a aplicação. Para quem administra infraestrutura, o exercício mais valioso é sobre o **acesso de gerência**. Fluxo: técnico → VPN → VLAN de gerência → OLT. Aplicando STRIDE ao fluxo que cruza a fronteira internet–VPN:

Tabela 5.2.: STRIDE aplicado ao acesso de gerência de rede.

Letra	Pergunta	Achado típico
S	Alguém consegue se passar por técnico?	Conta compartilhada, sem segundo fator
T	Dá para alterar a configuração em trânsito?	Telnet ou SNMPv2 na gerência
R	Dá para negar que fez a alteração?	Login <code>admin</code> genérico no equipamento
I	Dá para ler configuração ou tráfego?	Comunidade SNMP <code>public</code> habilitada
D	Dá para derrubar a gerência?	Plano de gerência sem separação do de dados
E	Dá para sair de um acesso limitado para total?	Um único nível de privilégio no equipamento

3. Transformar cada achado em verificação executável. O caso de abuso vira teste. Para o incidente de abertura, a verificação é uma linha:

```
# Autentica como assinante A e tenta ler a fatura do assinante B.
# Esperado: 404. Qualquer 200 aqui é falha de autorização por objeto.
curl -s -o /dev/null -w '%{http_code}\n' \
  -H "Authorization: Bearer $TOKEN_ASSINANTE_A" \
  https://portal.exemplo.br/api/fatura/48212
```

4. Verificar as fronteiras que você acha que existem. Modelo desenhado é hipótese; a rede é o fato. Vale confirmar que a DMZ não alcança a rede interna e que o servidor de aplicação não alcança o que não precisa:

```
# A partir de um host da DMZ: o que da rede interna responde? (esperado: só o
↪ previsto)
nmap -Pn -n --top-ports 50 --open 10.20.0.0/24

# Rotas e regras que contradizem a fronteira desenhada
ip route show
nft list ruleset | grep -A3 -E 'chain (forward|input)'
```

5. Guardar o modelo junto do código. Um arquivo Markdown no repositório, versionado com o sistema que descreve, com o diagrama e a tabela de ameaças e decisões. Modelo em pasta compartilhada some; modelo no repositório aparece na revisão de código.

6. Reservar dez minutos da revisão de mudança para a pergunta. Antes de subir alteração relevante: *esta mudança cria fluxo novo que cruza fronteira de confiança?* Se sim, as seis letras. Se não, segue. É o formato mais barato de modelagem contínua que existe.

7. Fazer o exercício da funcionalidade removida. Percorrer o sistema perguntando o que pode ser **desligado**: relatório que ninguém abre há um ano, campo coletado e nunca usado, integração de um projeto abandonado, endereço de API sem consumidor. Eliminar é a única mitigação com eficácia de 100% e custo de manutenção zero — e conversa diretamente com o princípio da necessidade da LGPD.

5.8. Resumo

- Testes verificam que o sistema **faz o que deve**; modelagem de ameaças verifica que ele **não faz o que não deve**. Falhas como referência direta insegura passam por qualquer suíte de aceitação e são triviais de antecipar em uma sessão de quadro branco.
- O método são quatro perguntas: o que estamos construindo, o que pode dar errado, o que faremos, e fizemos bem. As duas últimas são o que separa modelagem de conversa.
- No diagrama de fluxo de dados, o elemento decisivo é a **fronteira de confiança** — é onde as ameaças se concentram e onde o esforço de análise deve se concentrar.
- **STRIDE** é o complemento exato das propriedades dos capítulos anteriores: cada letra viola uma delas. Aplicado **por elemento**, converte-se numa lista finita de perguntas concretas.
- **Árvores de ataque** partem do objetivo do adversário e revelam o caminho mais barato — que é o que descreve o atacante real — e os controles que cortam vários ramos de uma vez. **Casos de abuso** convertem achados em critério de aceitação e teste automatizado.
- Cada ameaça termina em mitigar, eliminar, transferir ou aceitar, sempre com dono e prazo. Transferir move o custo financeiro, nunca a responsabilidade perante o titular dos dados.
- No Brasil, o art. 46, §2º da LGPD exige segurança desde a concepção, e o relatório de impacto do art. 38 é o modelo de ameaças formalizado — com o foco deslocado para o risco ao **titular**, o que torna o LINDDUN mais adequado que o STRIDE nesse documento. Para agentes de pequeno porte, a ANPD espera proporcionalidade: registro das decisões, não processo formal pesado.

6. Gestão de risco: análise qualitativa e quantitativa

A reunião tem quarenta minutos e três itens na pauta. O terceiro é a proposta de contratar um segundo link de trânsito, de outra operadora, entrando por rota física distinta: R\$ 4.800 por mês, R\$ 57.600 no ano.

O coordenador de rede é a favor: já houve dois rompimentos de fibra em dezoito meses, um deles de onze horas. O diretor financeiro é contra: é o equivalente a três salários, num ano em que a meta é cortar custo. O sócio pergunta se não dá para negociar um desconto com a operadora atual. A discussão dura vinte minutos, sobe de tom duas vezes, e termina com “vamos deixar para revisar no próximo trimestre” — que é como se registra, em ata, a decisão de aceitar o risco sem nunca ter dito que se estava aceitando um risco.

O que faltou ali não foi um argumento melhor. Faltou um número. Onze horas fora do ar custam quanto? Qual a chance de acontecer de novo no ano? Quanto dessa perda o segundo link elimina de fato? Nenhuma dessas perguntas exige precisão contábil — exigem apenas uma estimativa honesta, com sua incerteza explícita. Com elas na mesa, a conversa deixa de ser sobre quem fala mais alto e passa a ser sobre se R\$ 57.600 compram ou não mais do que custam.

Gestão de risco é o método que produz esses números e as decisões que decorrem deles. Este capítulo cobre o processo, as duas famílias de análise — qualitativa e quantitativa —, suas armadilhas, e como escolher entre elas.

6.1. O processo

As normas convergem para o mesmo ciclo. A ISO 31000 dá o arcabouço geral de gestão de risco (International Organization for Standardization, 2018b), a ISO/IEC 27005 o especializa para segurança da informação (International Organization for Standardization, 2022) e o NIST SP 800-30 detalha a etapa de avaliação (National Institute of Standards and Technology, 2012). A Figura 6.1 resume.

Vale insistir em duas etapas que a prática costuma pular.

A **etapa 1** define os critérios *antes* de olhar qualquer risco específico — escala de impacto, escala de probabilidade, e o **apetite a risco**: quanto a organização está disposta a tolerar. Definir isso depois é como escolher a régua depois de ver o resultado, e o efeito é previsível: os riscos que dão trabalho corrigir acabam classificados como aceitáveis.

A **etapa 4** é distinta da 3 e frequentemente fundida com ela. Analisar é estimar probabilidade e impacto; avaliar é **comparar com o critério** e decidir se está dentro ou fora do aceitável. Sem critério declarado, não há avaliação — há opinião com aparência de método.

6. Gestão de risco: análise qualitativa e quantitativa

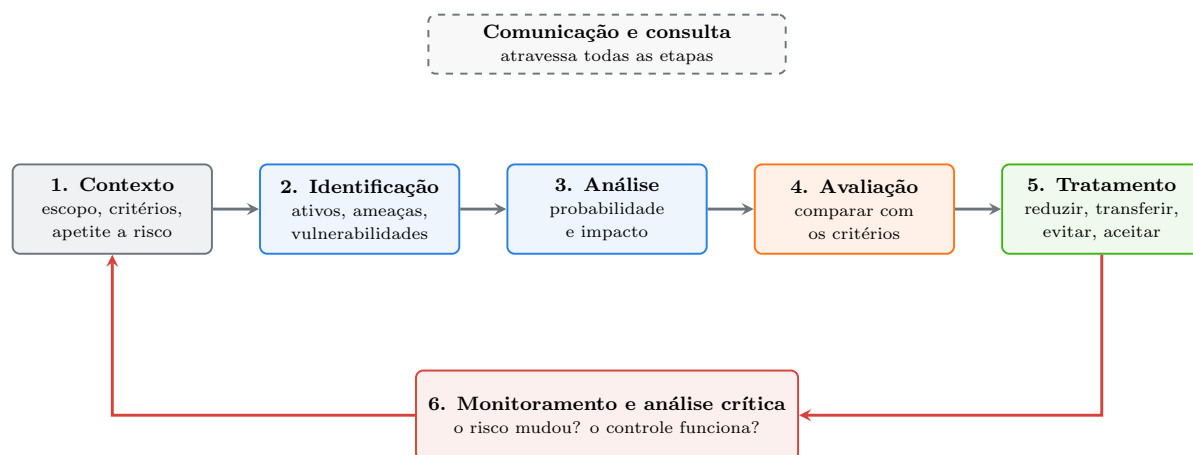


Figura 6.1.: O ciclo de gestão de risco. A sexta etapa é a que quase sempre falta: risco avaliado e nunca revisitado envelhece junto com o ambiente.

6.2. Análise qualitativa

A análise qualitativa classifica probabilidade e impacto em escalas ordinais e combina as duas numa matriz. É rápida, exige poucos dados e comunica bem — por isso domina a prática.

Também é onde mora a maior parte dos erros. E o principal deles não está na matriz: está nas escalas. Uma escala com rótulos vagos — “raro”, “possível”, “provável” — significa coisas diferentes para cada pessoa da sala. A correção é barata: **ancorar cada nível em número e em consequência concreta**.

Tabela 6.1.: Escalas ancoradas de probabilidade e impacto. Os valores são ilustrativos e devem ser calibrados ao porte de cada organização.

Nível	Probabilidade (ancorada)	Impacto (ancorado no contexto do provedor)
1 — Muito baixo	Menos de 1 vez em 10 anos	Até R\$ 5 mil; sem efeito perceptível ao assinante
2 — Baixo	Cerca de 1 vez em 5 anos	R\$ 5 mil a R\$ 30 mil; degradação localizada
3 — Médio	Cerca de 1 vez em 2 anos	R\$ 30 mil a R\$ 150 mil; parada de um serviço por horas
4 — Alto	Cerca de 1 vez por ano	R\$ 150 mil a R\$ 500 mil; parada geral por um dia, notificação à ANPD
5 — Muito alto	Mais de 1 vez por ano	Acima de R\$ 500 mil; risco de continuidade do negócio

Com as escalas ancoradas, a matriz de calor (Figura 6.2) vira instrumento de comunicação legítimo — um mapa que a direção lê em segundos.

6.2.1. As armadilhas da matriz

A matriz é útil e tem quatro problemas conhecidos que convém enfrentar de frente:

Multiplicar números ordinais. “Probabilidade 4 × impacto 3 = 12” trata rótulos de ordem como se fossem quantidades. Não são: o salto de 3 para 4 na escala de impacto da Tabela 6.1 é de R\$ 120 mil, e o de 4 para 5 é aberto e ilimitado. O produto é uma conveniência visual, não uma conta.

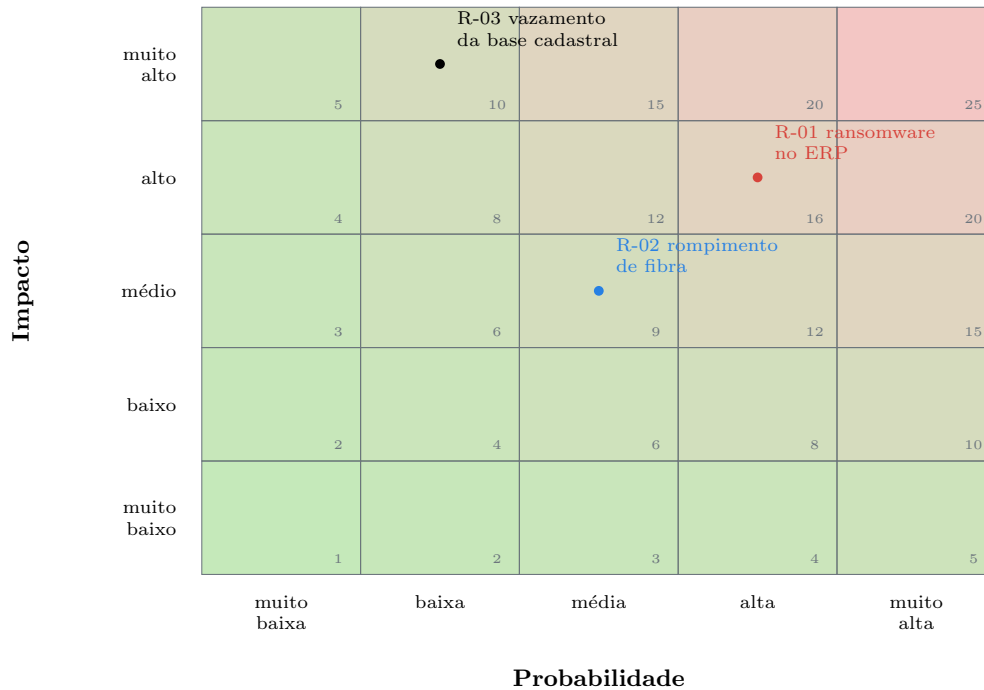


Figura 6.2.: Matriz de risco 5×5 com riscos posicionados. O número em cada célula é o produto dos índices — e é exatamente esse produto que exige cautela.

Nenhuma dessas críticas invalida a análise qualitativa. Elas definem seu uso correto: **triagem**. A matriz separa o que merece atenção do que não merece. Para o que sobe ao topo — e para toda decisão que envolve gastar dinheiro relevante — vale o esforço de quantificar.

6.3. Análise quantitativa

A análise quantitativa estima o risco em unidades monetárias. O vocabulário clássico tem quatro termos:

- **AV** (*asset value*) — valor do ativo.
- **EF** (*exposure factor*) — fração do valor perdida se o evento ocorrer.
- **SLE** (*single loss expectancy*) — perda esperada por ocorrência: $SLE = AV \times EF$.
- **ARO** (*annualized rate of occurrence*) — frequência anual esperada.
- **ALE** (*annualized loss expectancy*) — perda anual esperada: $ALE = SLE \times ARO$.

Aplicando ao caso de abertura. O provedor fatura R\$ 780 mil por mês. Um rompimento de fibra sem link redundante custa, por hora de parada, uma combinação de: crédito contratual e abatimento em fatura, chamados extras no suporte, cancelamentos atribuíveis nos trinta dias seguintes e horas extras da equipe de campo. A equipe estimou R\$ 3.900 por hora, e a duração média histórica em 6 horas.

$$SLE = 6 \text{ h} \times \text{R\$ } 3.900/\text{h} = \text{R\$ } 23.400$$

Com dois eventos em dezoito meses, $ARO \approx 1,33$ por ano:

$$ALE = \text{R\$ } 23.400 \times 1,33 \approx \text{R\$ } 31.100 \text{ por ano}$$

6. Gestão de risco: análise qualitativa e quantitativa

O segundo link não elimina a perda: rompimento continua havendo, mas a comutação leva minutos em vez de horas, e a parada residual foi estimada em 0,4 hora por evento — reduzindo a ALE para cerca de R\$ 2.100. O **retorno sobre o investimento em segurança** é então:

$$\text{ROSI} = \frac{(\text{ALE}_{\text{antes}} - \text{ALE}_{\text{depois}}) - \text{custo}}{\text{custo}} = \frac{(31.100 - 2.100) - 57.600}{57.600} \approx -0,50$$

O número é negativo. Pelo critério estrito de perda esperada, **o segundo link não se paga** — e essa conclusão, que contraria a intuição do coordenador de rede, é exatamente o tipo de resultado que justifica fazer a conta.

Mas a análise não termina aí, e é aqui que a maior parte das apresentações de gestão de risco erra. Três considerações mudam a decisão e precisam ir para a mesa junto com o número:

1. **A média esconde a cauda.** A conta usa 6 horas de duração média. Um rompimento em trecho de difícil acesso, num feriado, com equipe reduzida, é um evento de 30 horas — e a perda cresce mais que proporcionalmente, porque cancelamentos disparam a partir de certo limiar de paciência do assinante.
2. **Há benefício fora do cálculo.** Segundo link com operadora distinta protege também contra falha da operadora atual, permite manutenção programada sem janela noturna e é argumento comercial para contratos empresariais — receita nova que não entra na conta de perda evitada.
3. **O critério pode não ser o valor esperado.** Se uma parada longa ameaça contratos que representam parcela relevante da receita, a empresa pode racionalmente pagar acima do valor esperado para eliminar a cauda. É o mesmo raciocínio de comprar seguro, que tem valor esperado negativo por construção e ainda assim é decisão sensata.

A conclusão prática é que a quantificação **não substitui o julgamento** — ela o organiza. Com os números na mesa, a decisão passa a ser “estamos pagando R\$ 57,6 mil por ano para eliminar R\$ 29 mil de perda esperada e comprar proteção contra o cenário de cauda”, que é uma frase que a direção consegue aprovar ou recusar de forma consciente. Sem eles, decide-se por tom de voz.

6.4. Lidando com a incerteza: intervalos em vez de pontos

O ponto fraco de $\text{ALE} = \text{SLE} \times \text{ARO}$ é fingir precisão que não existe. “R\$ 3.900 por hora” é uma estimativa com incerteza grande, e o resultado herda essa incerteza sem mostrá-la.

A alternativa, defendida por Hubbard e Seiersen (Hubbard; Seiersen, 2016) e formalizada pelo método FAIR (Freund; Jones, 2014), é estimar **intervalos de confiança de 90%** em vez de valores únicos, e propagar a incerteza por simulação. Em vez de “custa R\$ 3.900 por hora”, a pergunta é: *qual intervalo você acredita, com 90% de confiança, que contém o custo horário real?* — digamos R\$ 1.800 a R\$ 9.000.

Sorteando milhares de cenários dentro desses intervalos, obtém-se não um número, mas uma distribuição de perda anual. Vinte linhas de Python bastam:

```
import numpy as np

rng = np.random.default_rng(42)
N = 100_000
```

```
# Intervalos de 90% de confiança, convertidos em lognormais.
# Para uma lognormal, o intervalo [lo, hi] de 90% implica:
def lognormal_90(lo, hi, n):
    mu = (np.log(lo) + np.log(hi)) / 2
    sigma = (np.log(hi) - np.log(lo)) / 3.29 # 3.29 = 2 x 1.645
    return rng.lognormal(mu, sigma, n)

custo_hora = lognormal_90(1_800, 9_000, N) # R$/hora de parada
duracao = lognormal_90(1.5, 30, N) # horas por evento
eventos = rng.poisson(1.33, N) # ocorrências no ano

perda_anual = eventos * custo_hora * duracao

for p in (50, 80, 90, 95, 99):
    print(f"P{p}: R$ {np.percentile(perda_anual, p):>12,.0f}")
print(f"média: R$ {perda_anual.mean():>10,.0f}")
print(f"P(perda > 57.600) = {(perda_anual > 57_600).mean():.1%}")
```

O resultado não é um número, é a **curva de excedência de perda** da Figura 6.3: para cada valor, a probabilidade de a perda anual superá-lo.

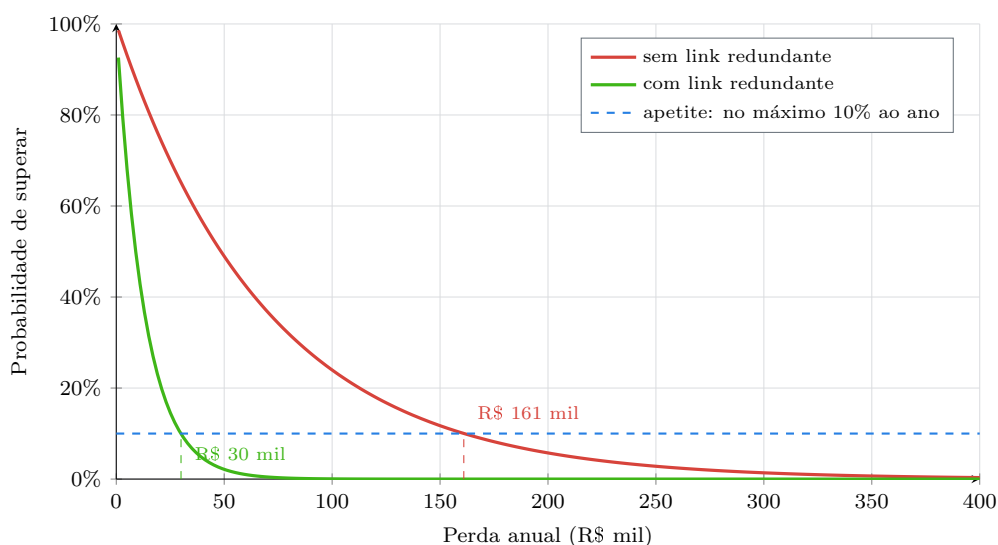


Figura 6.3.: Curva de excedência de perda. Onde a curva cruza a linha do apetite está a perda que se aceita ter 10% de chance de superar no ano.

A leitura é direta e é o que torna o método superior à matriz: com o link redundante, a perda que se tem 10% de chance de superar cai de R\$ 161 mil para R\$ 30 mil. A decisão deixa de ser sobre um valor esperado e passa a ser sobre **onde a cauda é cortada** — que é o que a diretoria de fato quer saber.

Uma objeção previsível: “não temos dados para isso”. A resposta é que o método não exige dados históricos, exige **estimativas calibradas** — e calibração é habilidade treinável. Pessoas treinadas para acertar 90% de suas faixas de 90% produzem intervalos honestos sobre grandezas que nunca mediram. E o ponto decisivo é comparativo: a alternativa não é uma estimativa melhor, é o palpite implícito de quem fala mais alto na reunião.

6.5. Escolher entre as duas

Tabela 6.2.: Quando usar cada abordagem.

Critério	Qualitativa	Quantitativa
Custo do exercício	Horas	Dias
Dado necessário	Julgamento de especialista	Julgamento calibrado, idealmente com histórico
Comparabilidade entre riscos	Frágil (escala ordinal)	Direta (mesma unidade monetária)
Suporta decisão de investimento	Mal	Bem (ROSI, curva de excedência)
Comunica à direção	Bem (mapa visual)	Muito bem (em reais)
Risco de falsa precisão	Baixo	Alto se a incerteza não for mostrada

Na prática, a combinação vence: **qualitativa para triar todo o inventário de riscos, quantitativa para os dez ou quinze do topo** e para toda decisão que envolva gasto relevante. É a proporção que respeita o custo do método.

6.6. Tratamento e risco residual

Analisado e avaliado o risco, restam quatro opções — as mesmas do Capítulo 5, agora com o número que as sustenta:

Reduzir. Implantar controle que diminua probabilidade ou impacto. É a escolha padrão. O critério de aceitação é a comparação entre custo do controle e redução de ALE, temperada pela análise da cauda.

Transferir. Seguro cibernético, cláusula contratual, terceirização para fornecedor especializado. Três ressalvas importam: apólices excluem o que a empresa deixou de fazer (ausência de segundo fator e de correção em dia são exclusões comuns); a indenização cobre prejuízo financeiro, não a obrigação perante a ANPD nem a confiança do assinante; e transferir exige demonstrar controles para conseguir preço razoável — o seguro pressupõe higiene, não a substitui.

Evitar. Não fazer, ou parar de fazer, a atividade que gera o risco. Desativar a funcionalidade pouco usada, não coletar o dado que não é necessário, encerrar a integração legada. É a opção mais subestimada e a única com eficácia integral.

Aceitar. Conviver conscientemente. Só é aceitação legítima se: estiver **registrada**, com o número que a justifica; for decidida por **quem tem autoridade** para comprometer a organização naquele valor; e tiver **data de revisão**. Aceitação sem esses três elementos é omissão com outro nome.

O que sobra depois do tratamento é o **risco residual** — e o produto final de todo o processo é uma lista curta de riscos residuais que a direção conhece e aceitou formalmente. Um programa de segurança maduro não se distingue por ter menos risco, mas por saber qual risco tem.

6.6.1. O registro de risco

O artefato que sustenta tudo isso cabe numa planilha. Dez colunas: identificador, descrição do cenário (ativo + ameaça + vulnerabilidade + consequência), impacto estimado, probabilidade estimada, risco inerente, controles existentes, risco residual, decisão de tratamento, dono, data de revisão.

Duas regras que decidem se o registro vive ou morre: descrever o **cenário completo**, não o rótulo — “ransomware” não é risco, “cifragem do banco do ERP por acesso via VPN sem segundo fator, com parada de faturamento por seis dias” é; e **cada linha tem um dono nomeado**, porque risco de todos é risco de ninguém.

6.6.2. Indicadores que antecipam

Monitoramento (etapa 6) não é reler a planilha em dezembro. São indicadores que se movem antes do incidente: percentual de servidores com correção crítica pendente há mais de 30 dias, contas privilegiadas sem segundo fator, restaurações de backup testadas no trimestre, tempo médio até detecção, serviços administrativos alcançáveis da internet. Cada um deles tem um limite que, ultrapassado, dispara reavaliação do risco correspondente — e essa é a diferença entre gestão de risco e documentação de risco.

6.7. Brasil em Foco

A gestão de risco é a espinha dorsal do modelo brasileiro de conformidade em proteção de dados, e entender isso muda a forma de investir.

A **LGPD** não traz lista fechada de controles obrigatórios. O art. 46 exige medidas “aptas a proteger” os dados, considerando o estado da técnica, a natureza da informação e os riscos; o art. 50 fala em regras de boas práticas que levem em conta “a natureza, o escopo, a finalidade, a probabilidade e a gravidade dos riscos”; o art. 38 prevê o relatório de impacto (Brasil, 2018). É um regime **baseado em risco**: a conformidade se demonstra pelo processo — inventário, avaliação, decisão registrada, revisão — e não pela posse de determinados produtos. Uma empresa com firewall de última geração e nenhum registro de avaliação de risco está em posição pior, diante da ANPD, que outra com controles modestos e um registro de risco bem mantido.

O art. 52, §1º da LGPD fixa os critérios de dosimetria das sanções, entre os quais figuram a **adoção de política de boas práticas e governança**, as **medidas adotadas para reverter ou mitigar** os efeitos do incidente e a **pronta adoção de medidas corretivas** — todos elementos que só existem se houver processo prévio. Na prática, o registro de risco é peça de defesa administrativa.

Para **agentes de pequeno porte**, a Resolução CD/ANPD nº 2/2022 e o guia orientativo da autoridade estabelecem tratamento proporcional (Autoridade Nacional de Proteção de Dados, 2023). A ANPD não espera de um provedor com quarenta funcionários o processo de uma instituição financeira — espera evidência de que os riscos foram identificados e as decisões tomadas de forma consciente. Uma planilha de dez linhas revisada semestralmente atende.

No **setor financeiro e de pagamentos**, a exigência é explícita e mais rígida: a Resolução CMN nº 4.893/2021 obriga política de segurança cibernética com avaliação de riscos, classificação de dados por relevância, controles proporcionais, plano de resposta a incidentes, testes e relatório anual submetido à alta administração — além de gestão de risco sobre serviços relevantes de terceiros (Banco Central do Brasil, 2021). Para telecomunicações, a Resolução Anatel nº 740/2020

6. Gestão de risco: análise qualitativa e quantitativa

exige tratamento de vulnerabilidades em produtos, o que pressupõe avaliação de criticidade (Agência Nacional de Telecomunicações, 2020).

Do lado das normas técnicas, as versões brasileiras estão disponíveis pela ABNT: a **NBR ISO 31000** para o arcabouço de gestão de risco e a **NBR ISO/IEC 27005** para a aplicação à segurança da informação. Adotar a terminologia dessas normas no registro de risco tem valor prático em auditoria e em processo administrativo: usa o vocabulário que o auditor e o regulador esperam.

Sobre **seguro cibernético**, o mercado brasileiro é regulado pela SUSEP e vem crescendo, com apólices que costumam cobrir custo de resposta, perícia, notificação a titulares e defesa administrativa. Duas cautelas: multa administrativa da ANPD tem cobertura limitada ou vedada em várias apólices, e o questionário de contratação funciona como auditoria — declarar controles que não existem compromete o pagamento do sinistro.

6.8. No Campo

1. Escrever os critérios antes de olhar o primeiro risco. Uma página: escala de impacto ancorada em reais e em consequência operacional, escala de probabilidade ancorada em frequência, e a linha do apetite (“não aceitamos risco com mais de 10% de chance de perda anual superior a R\$ 50 mil”). Aprovada pela direção, ela resolve antecipadamente metade das discussões.

2. Levantar dez riscos, não cem. Uma sessão de duas horas com a equipe técnica e alguém do negócio produz os dez cenários que importam. Descrever cada um como cenário completo. Os cem virão depois, se vierem.

3. Estimar o custo da hora parada — o número que falta em quase toda empresa. Ele destrava todas as demais contas:

```
# Insumos para a estimativa, a partir do que já se mede
# 1. Receita por hora
echo "scale=2; 780000 / (30*24)" | bc          # faturamento mensal / horas do mês

# 2. Histórico real de indisponibilidade dos últimos 12 meses
journalctl --list-boots | wc -l
last -x shutdown reboot | head -30

# 3. Volume de chamados por evento de parada (correlacionar com a data)
grep -c "" /var/log/suporte/chamados-2026-*.csv
```

Some receita não faturada, crédito contratual, horas extras, chamados extras e cancelamentos atribuíveis nos trinta dias seguintes. O resultado não precisa ser exato; precisa ser defensável.

4. Quantificar os três do topo, não todos. Para cada um: intervalo de 90% para o custo do evento, intervalo para a frequência, e a simulação de vinte linhas mostrada acima. O resultado em uma frase — “temos 10% de chance de perder mais de R\$ X este ano com este cenário” — é o que a direção compra ou recusa.

5. Levar decisões, não relatórios. A pauta certa tem três colunas: risco, opção recomendada com custo, e o que acontece se não fizermos nada. Uma página, três riscos. Relatório de quarenta páginas não é lido e não gera decisão.

6. Registrar a aceitação por escrito. Quando a decisão for aceitar — e será, com frequência —, uma linha na ata com o valor em risco, quem aceitou e a data de revisão. É proteção do técnico que alertou, é insumo de defesa administrativa, e é o que faz o assunto voltar à pauta antes de voltar como incidente.

7. Acompanhar cinco indicadores, e só cinco. Correções críticas pendentes há mais de 30 dias; contas privilegiadas sem segundo fator; restaurações testadas no trimestre; serviços administrativos alcançáveis da internet; tempo médio até detecção. Painel mensal, cada um com um limite que dispara reavaliação. Mais que cinco vira relatório que ninguém lê.

6.9. Resumo

- O ciclo é **contexto** → **identificação** → **análise** → **avaliação** → **tratamento** → **monitoramento**, com comunicação atravessando tudo. As etapas mais puladas são a primeira (definir critérios e apetite *antes*) e a última (revisitar).
- Na análise **qualitativa**, o erro não está na matriz e sim nas escalas: níveis com rótulos vagos significam coisas diferentes para cada pessoa. Ancorar cada nível em faixa numérica e consequência concreta é a correção mais barata que existe.
- A matriz sofre de multiplicação de ordinais, compressão da cauda, inversão de ordenação e vieses de estimativa. Isso a torna instrumento de **triagem**, não de decisão de investimento.
- A análise **quantitativa** usa $SLE = AV \times EF$ e $ALE = SLE \times ARO$, e o ROSI compara redução de perda esperada com custo do controle. O resultado pode contrariar a intuição — e é para isso que serve.
- Valor esperado esconde a cauda. Estimar **intervalos de 90%** e simular produz a **curva de excedência de perda**, que responde à pergunta que a direção realmente faz: quanto podemos perder no pior ano plausível, e quanto o controle corta disso.
- O tratamento é reduzir, transferir, evitar ou aceitar. Seguro transfere prejuízo financeiro, nunca a responsabilidade perante o titular; **evitar** é a opção mais subestimada; e aceitação só é legítima se registrada, decidida por quem tem autoridade e com data de revisão.
- No Brasil o regime é **baseado em risco**: a LGPD (arts. 38, 46, 50 e 52) demonstra conformidade pelo processo, não pela posse de produtos — e o registro de risco é peça de defesa administrativa. Setor financeiro (Res. CMN 4.893/2021) e telecomunicações (Res. Anatel 740/2020) acrescentam exigências específicas.

7. Ética, legalidade e a fronteira do escopo autorizado

Um técnico de suporte de um provedor está resolvendo um chamado de lentidão. No caminho, abre o portal de um provedor vizinho para comparar como eles apresentam o teste de velocidade. Nota que a URL da área do cliente termina em `?id=1042`. Por hábito profissional — o mesmo hábito que o Capítulo 5 elogia —, troca para 1041. Abre a página de outra pessoa: nome, CPF, plano, endereço de instalação.

O que ele faz nos próximos minutos define de que lado de uma linha ele está. Se fechar a aba e escrever um e-mail ao contato de abuso do provedor vizinho descrevendo o que viu, é um profissional agindo com responsabilidade. Se testar mais dez identificadores para “confirmar a extensão do problema”, já acessou dados de dez pessoas sem autorização. Se baixar a listagem para “provar” o achado, exfiltrou base de dados pessoais de terceiro. Se publicar no grupo de WhatsApp do setor, divulgou vulnerabilidade não corrigida de um concorrente.

A intenção é a mesma nos quatro casos. As consequências jurídicas não são.

Este é o capítulo mais importante do volume para quem pretende trabalhar com segurança, e é o que fecha a Fase 1. Os seis anteriores ensinaram a pensar como quem ataca para defender melhor. Este trata da fronteira que torna esse conhecimento legítimo: **a autorização**.

7.1. A linha é jurídica, não técnica

A confusão mais comum e mais cara na área é achar que a fronteira do lícito é definida pela dificuldade técnica ou pela intenção. Não é. É definida pela **autorização**, e a lei brasileira é explícita.

O art. 154-A do Código Penal, inserido pela Lei 12.737/2012 e agravado pela Lei 14.155/2021, tipifica:

Invadir dispositivo informático de uso alheio, conectado ou não à rede de computadores, com o fim de obter, adulterar ou destruir dados ou informações sem autorização expressa ou tácita do titular do dispositivo ou instalar vulnerabilidades para obter vantagem ilícita.

Três palavras merecem atenção. “**Invadir**” não exige violência, ferramenta sofisticada ou quebra de senha: trocar um número numa URL para acessar o que não é seu é acesso não autorizado. “**Sem autorização**” é o núcleo do tipo — a mesma ação, autorizada, é serviço profissional. E “**de uso alheio**” delimita: o dispositivo do próprio agente, ou aquele que ele foi contratado para testar, está fora.

O que a lei **não** exige também importa: não exige dano, não exige lucro, não exige que os dados sejam usados. A consumação se dá com o acesso.

Daí a regra prática deste manual, que vale para toda a carreira:

7. Ética, legalidade e a fronteira do escopo autorizado

Se você não tem autorização por escrito de quem pode dá-la, não toque. “Só olhei” é acesso. “Não usei nada” é irrelevante. “Foi para ajudar” é atenuante, não excludente.

7.2. O mapa legal brasileiro

O art. 154-A não está sozinho. A Tabela 7.1 reúne os dispositivos que alcançam atividade técnica em segurança da informação — e a coluna da direita é a que mais interessa, porque descreve o que transforma cada conduta em lícita.

Tabela 7.1.: Mapa das condutas técnicas e do que as torna lícitas no direito brasileiro.

Conduta	Enquadramento típico	O que a torna lícita
Acessar sistema de terceiro sem permissão	CP, art. 154-A (invasão de dispositivo informático)	Autorização expressa do titular, por escrito
Interromper serviço de telecomunicações ou de informação de utilidade pública	CP, art. 266, §1º	Janela de manutenção acordada; teste de carga contratado
Interceptar comunicação alheia	Lei 9.296/1996, art. 10	Ordem judicial; ou ser parte da comunicação; ou rede própria com aviso prévio (Brasil, 1996)
Fraude por meio eletrônico	CP, art. 171, §2º-A (estelionato)	Nada a torna lícita
Furto mediante dispositivo eletrônico	CP, art. 155, §4º-B	Nada a torna lícita
Inserir dados falsos em sistema da administração pública	CP, arts. 313-A e 313-B	Nada a torna lícita
Tratar dados pessoais de terceiros sem base legal	LGPD, arts. 7º e 42 (responsabilidade civil e sanção administrativa)	Base legal do art. 7º e finalidade legítima
Divulgar vulnerabilidade não corrigida de terceiro	Sem tipo penal próprio; risco civil e possível concurso com 154-A	Divulgação coordenada, com prazo e consentimento

Quatro observações completam o quadro.

As penas foram agravadas em 2021. A Lei 14.155/2021 elevou a pena do art. 154-A para reclusão de 1 a 4 anos e multa, com aumento se houver obtenção de conteúdo de comunicações privadas, segredos comerciais ou controle remoto do dispositivo — e majorantes adicionais quando praticado contra idoso ou vulnerável (Brasil, 2021). O estelionato eletrônico do art. 171, §2º-A tem reclusão de 4 a 8 anos.

A ação penal. O art. 154-B condiciona a persecução, em regra, a representação da vítima — procede-se mediante ação penal pública incondicionada apenas quando o crime é cometido contra a administração pública ou empresas concessionárias de serviços públicos. Isso significa que o provedor vizinho do caso de abertura decide se representa ou não; não significa que a conduta deixe de ser crime.

A LGPD age em paralelo. Acessar dados pessoais de terceiro sem base legal é tratamento irregular, com responsabilidade civil (art. 42) e sanção administrativa (art. 52) independentes da esfera penal. Quem “só olhou” a fatura de outro assinante tratou dado pessoal sem base legal.

A Convenção de Budapeste está em vigor no Brasil. O Decreto nº 11.491/2023 promulgou a Convenção sobre o Crime Cibernético (Brasil, 2023), que facilita a cooperação internacional e a preservação expedita de dados. O efeito prático é direto: a fronteira nacional deixou de ser obstáculo relevante à investigação, e o argumento de que “o servidor está fora do Brasil” não protege ninguém.

7.3. Autorização: como ela é feita de verdade

Autorização não é uma mensagem dizendo “pode testar”. É um documento, e faltando qualquer dos elementos abaixo, a proteção que ele oferece é parcial:

Tabela 7.2.: Elementos mínimos de uma autorização de teste.

Elemento	Por que é indispensável
Identificação das partes	Quem autoriza e quem executa, com CNPJ/CPF
Escopo positivo	Lista exata de domínios, faixas de IP, aplicações, contas de teste
Escopo negativo	O que está explicitamente fora — sistemas de terceiros, produção crítica, dados reais
Janela temporal	Data e hora de início e fim; fora dela não há autorização
Técnicas permitidas e proibidas	Negação de serviço, engenharia social contra funcionários, exploração destrutiva
Tratamento de dados encontrados	Que se faz ao encontrar dado pessoal: não copiar, registrar apenas evidência mínima, apagar ao fim
Contato de emergência	Quem atender às 3h se algo cair; e o gatilho para parar imediatamente
Sigilo e destinação do relatório	Quem recebe, por quanto tempo se guarda, como se destrói
Assinatura de quem tem poderes	Sócio, diretor ou procurador — não o gerente de TI que “aprovou por e-mail”

Dois pontos que causam problema com frequência.

Quem assina. A autorização precisa vir de quem pode comprometer a pessoa jurídica. O analista de TI que contrata o teste sem procuração não tem poder para autorizar acesso a dados de clientes da empresa. Verificar o contrato social ou a procuração é parte do trabalho, não formalidade.

Escopo com ativo de terceiro. Se o alvo está hospedado em nuvem ou em datacenter de terceiro, a autorização do cliente **não alcança** a infraestrutura do provedor. Os grandes provedores de nuvem publicam políticas de teste que permitem certas atividades sem aviso prévio e proíbem outras — notadamente teste de negação de serviço. Testar fora dessas políticas viola o contrato do cliente com o provedor e pode configurar acesso não autorizado a sistema do provedor.

7. Ética, legalidade e a fronteira do escopo autorizado

A Figura 7.1 condensa a decisão numa sequência que cabe na cabeça.

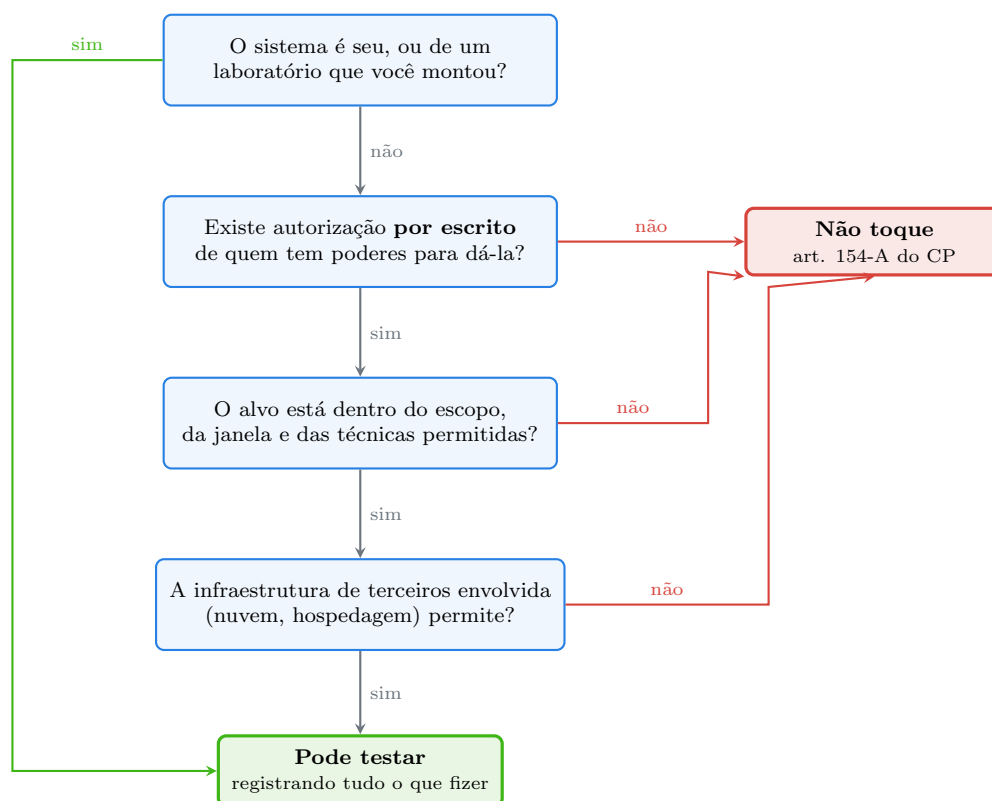


Figura 7.1.: A decisão de testar. Qualquer “não” nas três últimas perguntas leva ao mesmo lugar.

7.4. Divulgação de vulnerabilidade

Encontrada uma falha em sistema de terceiro — por acidente, como no caso de abertura, ou em pesquisa —, existe um caminho estabelecido. As normas ISO/IEC 29147 (divulgação) e 30111 (tratamento interno) descrevem o processo de ambos os lados (International Organization for Standardization, 2018c, 2019), e a Figura 7.2 mostra a linha do tempo típica.

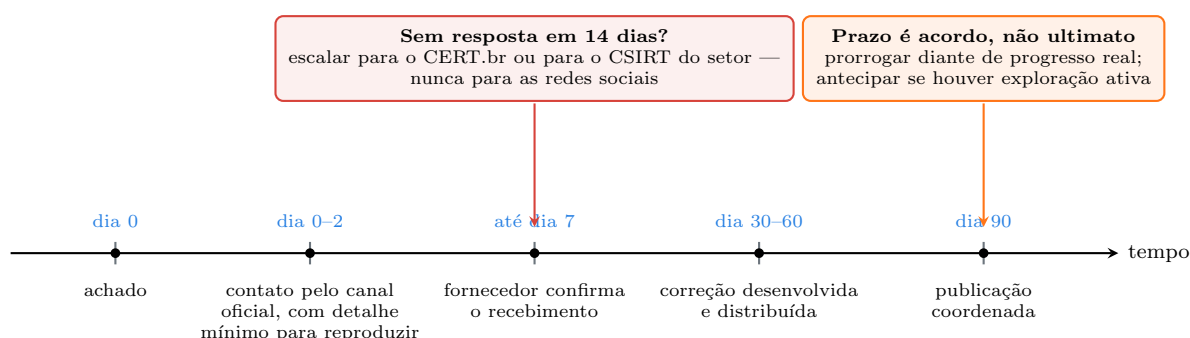


Figura 7.2.: Divulgação coordenada. O prazo de 90 dias é convenção de mercado, não regra jurídica.

Três posturas coexistem no mercado, e vale entender o argumento de cada uma. A **divulgação completa** publica tudo imediatamente, sob o argumento de que só a pressão pública faz fornecedores corrigirem e que defensores precisam da informação para se proteger. A **não divulgação**

nunca publica, e na prática protege o fornecedor às custas dos usuários. A **divulgação coordenada** — o padrão hoje — dá ao fornecedor um prazo razoável para corrigir e então publica, com ou sem correção pronta.

Cuidados que evitam transformar um ato de responsabilidade em problema:

- **Não teste além do mínimo.** Um caso comprova a falha. Dez casos “para confirmar a extensão” é acesso repetido não autorizado, e o relatório não fica melhor por isso.
- **Não copie dados.** Registre a evidência mínima — a URL, o código de resposta, uma captura com os dados tarjados. Baixar a base transforma o achado em exfiltração.
- **Documento o que fez, quando e como.** Se houver questionamento, a diferença entre pesquisador e invasor está nesse registro.
- **Use o canal oficial.** Procure `/.well-known/security.txt` no domínio, a página de contato de segurança, ou o contato de abuso no WHOIS do bloco. Não havendo canal, o CERT.br atua como intermediário.
- **Não peça pagamento.** Comunicar uma falha e sugerir que o silêncio tem preço é extorsão (CP, art. 158), independentemente de como a mensagem for redigida.

Uma nota importante sobre o Brasil: **não existe salvaguarda legal explícita para pesquisa de segurança**. Diferentemente da política do Departamento de Justiça norte-americano de 2022, que orienta não processar pesquisa de boa-fé, aqui a proteção do pesquisador depende de programas privados de recompensa com termos de porto seguro, ou da decisão da vítima de não representar. Reportar de boa-fé é o comportamento correto e ainda assim carrega risco jurídico residual. Quem pesquisa deve conhecer esse risco, minimizá-lo (não ir além do mínimo, documentar, usar canal oficial) e, em achados sensíveis, considerar orientação jurídica antes de fazer contato.

7.5. Bug bounty e programas de recompensa

Programas de recompensa resolvem juridicamente o problema: os termos publicados **são** a autorização, com escopo, técnicas permitidas e, nos bons programas, cláusula de porto seguro comprometendo a empresa a não acionar judicialmente quem cumprir as regras.

Três cuidados práticos: os termos são o limite exato — subdomínio fora da lista está fora, e “achei que estava incluído” não é defesa; testar um alvo do programa hospedado em nuvem ainda exige respeitar as políticas do provedor; e recompensa não é vínculo de trabalho, o que tem implicações fiscais para quem recebe com regularidade.

7.6. Ética profissional além da lei

A lei define o mínimo. A profissão exige mais, e três situações concentram os dilemas reais.

O poder do administrador. Quem administra sistemas pode ler o e-mail de qualquer pessoa da empresa, ver o histórico de navegação, acessar arquivos pessoais em pasta de rede. O acesso é tecnicamente possível e frequentemente autorizado *para fins específicos*. O uso além desses fins — a curiosidade sobre a conversa da colega, o interesse pelo salário do outro setor — é abuso, ainda que nenhum controle o impeça. A régua é simples: *este acesso é necessário para a tarefa que estou executando agora, e eu o registraria sem constrangimento?*

Monitoramento de funcionários. É lícito no Brasil quando há finalidade legítima, comunicação prévia e clara aos empregados, proporcionalidade e limite ao ambiente de trabalho. Não é lícito

7. Ética, legalidade e a fronteira do escopo autorizado

monitorar comunicação pessoal sem ciência, instalar captura de teclas de forma oculta ou vasculhar o dispositivo pessoal de alguém. A LGPD se aplica integralmente à relação de emprego, e a base legal costuma ser o legítimo interesse — que exige teste de proporcionalidade documentado, e não sobrevive a monitoramento excessivo.

O achado incidental. Durante um trabalho autorizado, encontra-se algo fora do escopo: indício de fraude interna, dados de outro cliente misturados, material manifestamente ilegal. A conduta correta é parar, não explorar, registrar o mínimo e comunicar imediatamente o contato definido no contrato. Diante de material de abuso infantil, a comunicação às autoridades é dever, e a preservação da evidência deve seguir orientação jurídica — não se copia, não se apaga, não se investiga por conta própria.

Os códigos de ética profissional da área — o da ISC2 é o mais citado — convergem em quatro deveres: proteger a sociedade e a infraestrutura; agir com honestidade e legalidade; prestar serviço diligente e competente; e promover a profissão (ISC2, 2024). O primeiro dever, quando conflita com os interesses de um cliente específico, prevalece: é ele que sustenta a recusa em ocultar um incidente que afeta terceiros.

7.7. Onde praticar sem risco

Aprender segurança ofensiva exige praticar. O caminho legítimo é abundante e gratuito:

- **Laboratório próprio.** Máquinas virtuais na sua máquina, rede isolada, alvos deliberadamente vulneráveis (DVWA, Metasploitable, Juice Shop, VulnHub). É o Volume 2 que monta esse ambiente.
- **Plataformas de treino.** Hack The Box, TryHackMe, PortSwigger Web Security Academy, PicoCTF. A autorização está nos termos de uso.
- **Competições CTF.** Autorização explícita, alvos preparados, comunidade ativa no Brasil.
- **Programas de recompensa,** respeitando o escopo.

E, para não errar em documentação, exemplos e testes, use os identificadores reservados: `example.com`, `example.org`, e as faixas de endereços de documentação 192.0.2.0/24, 198.51.100.0/24 e 203.0.113.0/24 (RFC 5737). Todo endereço IP que aparece neste manual vem dessas faixas, por isso mesmo.

7.8. Brasil em Foco

O capítulo inteiro é direito brasileiro; esta seção fixa o que muda no dia a dia de quem opera infraestrutura no país.

Provedor tem obrigações que se cruzam com a ética. O Marco Civil impõe guarda de registros (arts. 13 e 15) e, simultaneamente, sigilo (arts. 10 e 11): os dados só podem ser disponibilizados mediante ordem judicial, que precisa conter indícios do ilícito, identificação clara do usuário e período determinado (Brasil, 2014). Entregar registro a quem pede sem ordem — inclusive a delegado, a advogado ou ao “outro provedor que também foi atacado” — é violação de sigilo, com responsabilização civil e administrativa. A conduta correta é exigir a ordem, verificar sua abrangência e responder exatamente o que foi requisitado, nem mais.

Interceptação é linha vermelha. Capturar tráfego de assinante além do necessário para operação técnica esbarra na Lei 9.296/1996, cujo art. 10 tipifica a interceptação sem autorização

judicial (Brasil, 1996). Coleta de metadados de fluxo para engenharia de tráfego é operação legítima; inspeção de conteúdo é outra coisa, e exige base jurídica sólida.

A LGPD alcança o profissional, não só a empresa. O art. 42 estabelece a responsabilidade do controlador e do operador pelos danos causados; o art. 52 lista as sanções administrativas. Um prestador de serviço que trata dados do cliente é operador e responde nessa qualidade — o que torna o contrato de prestação, com cláusulas de finalidade, sigilo e devolução ou eliminação dos dados ao fim, instrumento de proteção do próprio prestador.

Sem porto seguro legal para o pesquisador. Vale repetir por ser a diferença mais relevante em relação a outros ordenamentos: no Brasil, quem reporta de boa-fé depende da representação da vítima e dos termos de programas privados. Não existe, hoje, dispositivo que exclua a tipicidade da conduta do pesquisador. O **CERT.br** é o intermediário estabelecido para notificar quem não tem canal — o que reduz o risco de o contato direto ser lido como ameaça.

A Convenção de Budapeste mudou a cooperação. Com o Decreto nº 11.491/2023, pedidos de preservação expedita e de cooperação internacional passaram a ter rito próprio (Brasil, 2023). Para provedores, isso significa maior volume de requisições e a necessidade de um procedimento interno definido para atendê-las corretamente — o Volume 15 detalha as obrigações regulatórias.

7.9. No Campo

1. Publicar um security.txt. Cinco minutos de trabalho que dão a quem encontrar uma falha no seu sistema um caminho responsável para avisar — e evitam que o achado vire postagem pública. Fica em `/.well-known/security.txt`:

```
Contact: mailto:seguranca@provedor.exemplo.br
Contact: https://provedor.exemplo.br/seguranca
Expires: 2027-12-31T23:59:00.000Z
Preferred-Languages: pt-BR, en
Policy: https://provedor.exemplo.br/politica-de-divulgacao
Acknowledgments: https://provedor.exemplo.br/agradecimentos
```

2. Manter o contato de abuso do bloco atualizado. É por ali que o CERT.br e outros operadores avisam sobre máquinas comprometidas na sua rede. Contato desatualizado significa não saber que seus clientes estão participando de um ataque:

```
# Contato de abuso registrado para o seu ASN e para o seu bloco
whois -h whois.registro.br AS64500 | grep -iE 'abuse|owner|responsible'
whois -h whois.registro.br 198.51.100.0/24 | grep -iE 'abuse|nserver'
```

3. Escrever a política de divulgação antes de precisar dela. Uma página: como reportar, o que a empresa se compromete a fazer (confirmar em X dias úteis, corrigir em Y), o que espera de quem reporta (não acessar dados além do mínimo, não divulgar antes do prazo), e a declaração de que não acionará judicialmente quem seguir as regras. Custa uma tarde e muda inteiramente o desfecho do dia em que alguém encontrar algo.

4. Formalizar a autorização, sempre — inclusive internamente. Vale para o teste contratado de terceiro e para a varredura da própria rede. Um documento de uma página com os elementos da Tabela 7.2, assinado por quem tem poderes, arquivado. A varredura do próprio bloco autorizada por escrito protege o técnico se o tráfego for questionado.

7. Ética, legalidade e a fronteira do escopo autorizado

5. Registrar o uso do acesso privilegiado. Quem administra pode tudo; o registro é o que separa poder de abuso. Sessão gravada ou ao menos registrada, revisão periódica por alguém que não seja o próprio administrador:

```
# Comandos executados com privilégio, por pessoa, nos últimos 7 dias
journalctl _COMM=sudo --since "7 days ago" -o cat \
  | grep -oP 'USER=\S+.*COMMAND=.*' | sort | uniq -c | sort -rn | head -20

# Acessos a arquivos sensíveis via auditd (regra prévia necessária)
auditctl -w /var/lib/erp/dados -p rwa -k dados-assinantes
ausearch -k dados-assinantes --start recent | head -40
```

6. Colocar as cláusulas certas no contrato de terceirizado. Quem presta suporte, quem administra a rede sob contrato, quem desenvolve o portal: finalidade do acesso, dever de sigilo que sobrevive ao fim do contrato, proibição de subcontratar sem anuência, obrigação de comunicar incidente em prazo curto, devolução ou eliminação dos dados ao término, e direito de auditoria. É o mesmo conjunto que a LGPD espera na relação controlador–operador.

7. Comunicar o monitoramento aos empregados. Política de uso aceitável assinada, com o que é monitorado, por quê e por quanto tempo se guarda. Monitoramento comunicado é lícito e eficaz; monitoramento oculto é risco trabalhista, risco sob a LGPD e destruição de confiança de uma vez só.

8. Treinar a resposta ao “encontrei uma falha em vocês”. Quem recebe a mensagem no suporte precisa saber que não deve responder com ameaça, não deve ignorar, e deve encaminhar imediatamente para o responsável definido. A reação hostil ao primeiro contato é o que transforma um aviso gratuito numa divulgação pública.

7.10. Resumo

- A fronteira do lícito é a **autorização**, não a dificuldade técnica nem a intenção. O art. 154-A do Código Penal não exige dano, lucro ou uso dos dados: consuma-se com o acesso não autorizado. Trocar um número numa URL é acesso.
- As penas foram **agravadas pela Lei 14.155/2021**, e o estelionato eletrônico (CP, art. 171, §2º-A) tem reclusão de 4 a 8 anos. Além da esfera penal, a LGPD gera responsabilidade civil e sanção administrativa autônomas.
- Autorização é **documento**, com escopo positivo e negativo, janela temporal, técnicas permitidas, tratamento de dados encontrados, contato de emergência e assinatura de quem tem poderes. Autorização do cliente não alcança a infraestrutura de terceiros que hospeda o alvo.
- Na **divulgação coordenada**, o essencial é não testar além do mínimo, não copiar dados, documentar tudo, usar o canal oficial e jamais condicionar o silêncio a pagamento — o que seria extorsão.
- **O Brasil não tem salvaguarda legal para pesquisa de boa-fé.** A proteção vem de programas privados com porto seguro ou da decisão da vítima de não representar. O CERT.br é o intermediário estabelecido quando não há canal de contato.
- A ética profissional vai além da lei em três frentes recorrentes: o **poder do administrador** (acesso possível não é acesso legítimo), o **monitoramento de empregados** (lícito com finalidade, comunicação prévia e proporcionalidade) e o **achado incidental** (parar, não explorar, comunicar).

- Praticar é obrigatório e há caminho legítimo abundante: laboratório próprio, plataformas de treino, competições e programas de recompensa — mais as faixas de documentação da RFC 5737 para exemplos.

Parte II.

**Volume 2 — Redes e Sistemas: a Base
Técnica**

8. A pilha TCP/IP sob a ótica do atacante e do defensor

(em elaboracao)

9. Endereçamento, roteamento e NAT

(em elaboracao)

10. Protocolos de aplicação e seus riscos: HTTP, DNS, SMTP e SNMP

(em elaboracao)

11. Fundamentos de sistemas operacionais: processos, permissões e memória

(em elaboracao)

12. Linux essencial para segurança

(em elaboracao)

13. Windows e Active Directory essencial

(em elaboracao)

14. Virtualização e montagem do laboratório de estudos

(em elaboracao)

Parte III.

Volume 3 — Criptografia Aplicada

15. História e princípios da criptografia

(em elaboracao)

16. Criptografia simétrica: AES, modos de operação e AEAD

(em elaboracao)

17. Funções hash, HMAC e integridade

(em elaboracao)

18. Criptografia assimétrica: RSA, Diffie-Hellman e curvas elípticas

(em elaboracao)

19. PKI, certificados digitais e cadeias de confiança

(em elaboracao)

20. TLS na prática: handshake, versões e configuração segura

(em elaboracao)

21. Erros clássicos: criptografia mal empregada

(em elaboracao)

Parte IV.

**Volume 4 — Identidade, Autenticação e
Controle de Acesso**

22. Modelos de controle de acesso: DAC, MAC, RBAC e ABAC

(em elaboracao)

23. Senhas: armazenamento, políticas e ataques

(em elaboracao)

24. Autenticação multifator e fatores de autenticação

(em elaboracao)

25. Federação de identidade: SAML, OAuth 2.0 e OpenID Connect

(em elaboracao)

26. Gestão de identidades e de acessos privilegiados (IAM e PAM)

(em elaboracao)

27. Arquitetura Zero Trust

(em elaboracao)

Parte V.

Volume 5 — Segurança de Redes

28. Arquitetura segura e segmentação de redes

(em elaboracao)

29. Firewalls: tipos, políticas e boas práticas

(em elaboracao)

30. VPNs: IPsec, WireGuard e acesso remoto seguro

(em elaboracao)

31. IDS, IPS e detecção em rede

(em elaboracao)

32. Segurança de DNS: ataques, DNSSEC e DoH

(em elaboracao)

33. Segurança do roteamento e BGP: sequestros, vazamentos e RPKI

(em elaboracao)

34. Segurança em redes sem fio e enlaces de rádio

(em elaboracao)

35. Ataques de negação de serviço e estratégias de mitigação

(em elaboracao)

Parte VI.

**Volume 6 — Endpoints e Sistemas
Operacionais**

36. Hardening de servidores Linux

(em elaboracao)

37. Hardening de Windows e Active Directory

(em elaboracao)

38. Antivírus, EDR e XDR

(em elaboracao)

39. Gestão de vulnerabilidades e ciclo de patches

(em elaboracao)

40. Segurança de dispositivos móveis e BYOD

(em elaboracao)

41. Criptografia de disco e proteção de dados em repouso

(em elaboracao)

Parte VII.

Volume 7 — Segurança de Aplicações

42. Ciclo de desenvolvimento seguro e DevSecOps

(em elaboracao)

43. OWASP Top 10: panorama e como usar

(em elaboracao)

44. Injeção: SQL, NoSQL e comandos de sistema

(em elaboracao)

45. Cross-site scripting e ataques no lado do cliente

(em elaboracao)

46. Falhas de autenticação e gestão de sessão

(em elaboracao)

47. Falhas de controle de acesso: IDOR, SSRF e escalonamento

(em elaboracao)

48. Segurança de APIs REST e GraphQL

(em elaboracao)

49. SAST, DAST, SCA e automação de testes de segurança

(em elaboracao)

Parte VIII.

Volume 8 — Nuvem e Contêineres

50. Modelo de responsabilidade compartilhada

(em elaboracao)

51. IAM em nuvem e os erros de configuração mais caros

(em elaboracao)

52. Segurança de contêineres e de imagens

(em elaboracao)

53. Segurança em Kubernetes

(em elaboracao)

54. Infraestrutura como código e segurança de pipeline

(em elaboracao)

55. Segredos, cofres e gestão de chaves

(em elaboracao)

Parte IX.

Volume 9 — Testes de Invasão

56. Metodologias e definição de escopo: PTES, OSSTMM e NIST SP 800-115

(em elaboracao)

57. Reconhecimento passivo e OSINT

(em elaboracao)

58. Varredura e enumeração

(em elaboracao)

59. Análise de vulnerabilidades

(em elaboracao)

60. Exploração: conceitos e anatomia de uma falha

(em elaboracao)

61. Pós-exploração, persistência e movimentação lateral

(em elaboracao)

62. Teste de invasão em aplicações web na prática

(em elaboracao)

63. Relatório técnico e comunicação de achados

(em elaboracao)

Parte X.

Volume 10 — Fator Humano

64. Engenharia social: os princípios psicológicos da persuasão

(em elaboracao)

65. Phishing, spear phishing e fraude do e-mail corporativo

(em elaboracao)

66. Fraudes digitais no Brasil: Pix, clonagem e golpes por mensageria

(em elaboracao)

67. Segurança física e ataques presenciais

(em elaboracao)

68. Cultura de segurança e programas de conscientização

(em elaboracao)

Parte XI.

**Volume 11 — Malware e Inteligência de
Ameaças**

69. Taxonomia de malware

(em elaboracao)

70. Anatomia de um ataque de ransomware

(em elaboracao)

71. Análise estática em laboratório

(em elaboracao)

72. Análise dinâmica e sandboxing

(em elaboracao)

73. MITRE ATT&CK e o mapeamento de TTPs

(em elaboracao)

74. Inteligência de ameaças e indicadores de comprometimento

(em elaboracao)

Parte XII.

**Volume 12 — Blue Team, SOC e
Detecção**

75. Estrutura e operação de um SOC

(em elaboracao)

76. Logging: o que registrar, por quanto tempo e por quê

(em elaboracao)

77. SIEM: arquitetura, ingestão e correlação

(em elaboracao)

78. Escrita de regras de detecção com Sigma e YARA

(em elaboracao)

79. Threat hunting: caçando o que a regra não pegou

(em elaboracao)

80. Deception: honeypots, honeytokens e canários

(em elaboracao)

81. Métricas e maturidade da detecção

(em elaboracao)

Parte XIII.

**Volume 13 — Resposta a Incidentes e
Forense Digital**

82. O ciclo de resposta a incidentes

(em elaboracao)

83. Preparação: plano, papéis e playbooks

(em elaboracao)

84. Contenção, erradicação e recuperação

(em elaboracao)

85. Fundamentos de forense digital e cadeia de custódia

(em elaboracao)

86. Forense de disco e sistemas de arquivos

(em elaboracao)

87. Forense de memória

(em elaboracao)

88. Forense de rede e análise de tráfego

(em elaboracao)

Parte XIV.

Volume 14 — Continuidade e Resiliência

89. Backup: estratégias e a regra 3-2-1-1-0

(em elaboracao)

90. Recuperação de desastres e continuidade de negócio

(em elaboracao)

91. Testes de continuidade e exercícios de mesa

(em elaboracao)

92. Alta disponibilidade e resiliência de infraestrutura

(em elaboracao)

93. Recuperação após um ataque de ransomware

(em elaboracao)

Parte XV.

**Volume 15 — Governança, Risco e
Conformidade**

94. Governança de segurança e o papel do CISO

(em elaboracao)

95. ISO/IEC 27001 e 27002

(em elaboracao)

96. NIST Cybersecurity Framework e CIS Controls

(em elaboracao)

97. LGPD na prática: bases legais, incidentes e a ANPD

(em elaboracao)

98. Marco Civil, Lei 12.737 e o direito penal digital brasileiro

(em elaboracao)

99. Obrigações regulatórias de provedores de internet

(em elaboracao)

100. PCI-DSS e requisitos setoriais

(em elaboracao)

101. Auditoria, conformidade e gestão de riscos de terceiros

(em elaboracao)

Parte XVI.

Volume 16 — Fronteira e Carreira

102. Segurança de sistemas de IA e modelos de linguagem

(em elaboracao)

103. Criptografia pós-quântica

(em elaboracao)

104. Segurança de OT, IoT e sistemas embarcados

(em elaboracao)

105. Segurança da cadeia de suprimentos de software

(em elaboracao)

106. Privacidade, anonimato e vigilância

(em elaboracao)

107. Carreira, certificações e aprendizado contínuo

(em elaboracao)

Referências

AGÊNCIA NACIONAL DE TELECOMUNICAÇÕES. Resolução n. 717, de 23 de dezembro de 2019. Regulamento de Qualidade dos Serviços de Telecomunicações — RQUAL., 2019.

AGÊNCIA NACIONAL DE TELECOMUNICAÇÕES. Resolução n. 740, de 21 de dezembro de 2020. Regulamento de Segurança Cibernética Aplicada aos Produtos de Telecomunicações., 2020.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. Guia orientativo: segurança da informação para agentes de tratamento de pequeno porte., 2023.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. Resolução CD/ANPD n. 15, de 24 de abril de 2024. Aprova o Regulamento de Comunicação de Incidente de Segurança., 2024.

BANCO CENTRAL DO BRASIL. Resolução CMN n. 4.893, de 26 de fevereiro de 2021. Política de segurança cibernética das instituições financeiras., 2021.

BRASIL. Lei n. 9.296, de 24 de julho de 1996. Regulamenta o inciso XII do art. 5º da Constituição Federal., 1996.

BRASIL. Medida Provisória n. 2.200-2, de 24 de agosto de 2001. Institui a Infraestrutura de Chaves Públicas Brasileira — ICP-Brasil., 2001.

BRASIL. Lei n. 12.737, de 30 de novembro de 2012. Tipificação criminal de delitos informáticos., 2012.

BRASIL. Lei n. 12.965, de 23 de abril de 2014. Marco Civil da Internet., 2014.

BRASIL. Lei n. 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais., 2018.

BRASIL. Lei n. 14.063, de 23 de setembro de 2020. Assinaturas eletrônicas em interações com entes públicos., 2020.

BRASIL. Lei n. 14.155, de 27 de maio de 2021. Agrava as penas dos crimes de invasão de dispositivo informático, furto e estelionato cometidos de forma eletrônica., 2021.

BRASIL. Decreto n. 11.491, de 12 de abril de 2023. Promulga a Convenção sobre o Crime Cibernético (Convenção de Budapeste)., 2023.

FORUM OF INCIDENT RESPONSE AND SECURITY TEAMS. Common Vulnerability Scoring System version 4.0: specification document., 2023.

FREUND, Jack; JONES, Jack. **Measuring and Managing Information Risk: A FAIR Approach**. [S.l.]: Butterworth-Heinemann, 2014.

HUBBARD, Douglas W.; SEIERSEN, Richard. **How to Measure Anything in Cybersecurity Risk**. [S.l.]: Wiley, 2016.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27000: information technology — security techniques — information security management systems — overview and vocabulary**. GenebraISO, a2018.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO 31000: risk management — guidelines**. GenebraISO, b2018.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 29147: information technology — security techniques — vulnerability disclosure**. GenebraISO, c2018.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 30111: information technology — security techniques — vulnerability handling processes**. GenebraISO, 2019.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27005: information security, cybersecurity and privacy protection — guidance on managing information security risks**. GenebraISO, 2022.

ISC2. **ISC2 Code of Ethics.**, 2024.

MITRE CORPORATION. **MITRE ATT&CK: adversarial tactics, techniques and common knowledge.**, 2024.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **Guide for Conducting Risk Assessments.**, 2012.

PARKER, Donn B. **Fighting Computer Crime: A New Framework for Protecting Information**. [S.l.]: Wiley, 1998.

SALTZER, Jerome H.; SCHROEDER, Michael D. The Protection of Information in Computer Systems. **Proceedings of the IEEE**, v. 63, n. 9, p. 1278–1308, 1975.

SCHNEIER, Bruce. Attack Trees. **Dr. Dobb's Journal**, v. 24, n. 12, p. 21–29, 1999.

SCHNEIER, Bruce. **Secrets and Lies: Digital Security in a Networked World**. [S.l.]: Wiley, 2000.

SHOSTACK, Adam. **Threat Modeling: Designing for Security**. [S.l.]: Wiley, 2014.